

Abdul Wahid

EC-Council CND (Certified Network Defender)

Endpoint Security for Windows Systems – RBAC, Hardening, SIEM & Active Response

Executive Summary

Module 5 focuses on Endpoint Security for Windows Systems and completes the defensive lifecycle on the existing lab domain (corp.local).

Two new VMs are introduced — SRV01 (Windows Server 2019 file/patch server) and CL02 (Windows 10 unauthorized-user client) — while IDS01 is upgraded to host the Wazuh SIEM.

Key controls implemented:

- Role-Based Access Control (RBAC) on the FinanceData share with least-privilege Share/NTFS permissions and Access-Based Enumeration
- Microsoft Security Compliance Toolkit baselines applied via LGPO on DC01 and SRV01
- Centralized patch management with BatchPatch
- Advanced hardening (NTLM disabled, Windows Firewall rules, advanced audit policies)
- Wazuh SIEM + Sysmon for real-time log collection, custom detection rules, and MITRE ATT&CK mapping
- Active Response that automatically blocks attacker IPs

All controls are validated through live attack simulations from Kali (network reconnaissance, SMB enumeration, brute-force, and credential attacks). The module demonstrates an end-to-end cycle of prevention, detection, and automated response for Windows endpoints.

Contents

Introduction 6

PHASE 1 — CREATE NEW VIRTUAL MACHINES 8

1. Creating and Configuring SRV01 (Windows Server 2019) 8

1.1 Configure Static IP on SRV01: 9

1.2 Rename SRV01 and Join Domain: 12

2. Creating and Configuring CL02 (Windows 10 — Unauthorized User Machine) 14

2.1 Configure Static IP on CL02: 16

2.2 Join CL02 to Domain: 17

PHASE 2 — ACTIVE DIRECTORY — RBAC USERS & GROUPS 20

1. CREATE MODULE 5 USERS IN ACTIVE DIRECTORY 20

1.1 Create Finance OU structure 20

1.2 Create user bob (authorized finance user): 22

1.3 Create user john (authorized finance user): 23

1.4 Create user martin (UNAUTHORIZED user — no finance access): 24

1.5 Create user alice (general client user): 25

1.6 Create the FinanceData Security Group: 27

1.7 Add bob and john to Finance Data group: 28

1.8 Move CL02 to appropriate OU: 30

PHASE 3 — SECURE FILE SHARING WITH RBAC ON SRV01 31

STEP 4 — CREATE AND CONFIGURE THE FINANCEDATA SHARE 31

Create the folder: 31

Configure Share Permissions: 33

Configure NTFS Permissions: 37

Enable Access-Based Enumeration: 41

Add some test files: 44

TEST RBAC ACCESS (Access Testing) 46

Test from CL02 as martin (SHOULD be DENIED): 47

PHASE 4 — MICROSOFT SECURITY COMPLIANCE TOOLKIT (MSCT) 48

DOWNLOAD AND INSTALL MSCT ON DC01 48

Download the toolkit: 48
Extract the files: 50
Install LGPO (Local Group Policy Object tool): 50
RUN POLICY ANALYZER ON DC01 51
Document Top 5 For Your Lab Report: 58
APPLY SECURITY BASELINE USING LGPO 59
On DC01 — Open PowerShell as Administrator: 59
Repeat the same process on SRV01: 61
PHASE 5 — PATCH MANAGEMENT WITH BATCHPATCH 62
INSTALL BATCHPATCH ON SRV01 62
STEP 10 — CONFIGURE BATCHPATCH FOR REMOTE PATCHING 64
Set credentials: 65
STEP 11 — SCAN FOR UPDATES AND PATCH REMOTELY 66
Scan all machines for missing patches: 66
Install patches remotely: 67
PHASE 6 — ADVANCED WINDOWS HARDENING 69
DISABLE NTLM AUTHENTICATION 69
ENABLE AND CONFIGURE WINDOWS FIREWALL 71
On SRV01 — same commands, plus add a specific rule to protect the file share: 71
ENABLE ADVANCED AUDIT POLICIES 72
PHASE 7 — WAZUH SIEM DEPLOYMENT 74
INSTALL WAZUH SERVER ON IDS01 74
Introduction 74
System Requirements 75
Installation Steps 75
Step 1: Update the System 75
Step 2: Curl and How to Install It 75
Installing curl 76
Step 3: Installing Wazuh Using the Automated Script 76
Downloads the installation script: 76

Executes the installation script: 76
Explanation of the Flags 76
Step 4: Accessing the Wazuh Dashboard 78
Accessing the Wazuh Dashboard 78
Troubleshooting & Fixes 80
Issue: Wazuh Manager Not Starting 80
Issue: Wazuh Dashboard Not Accessible 80
Issue: Wazuh Indexer Not Working 81
ACCESS WAZUH DASHBOARD 81
Connecting wazuh agent with the wazuh server 82
CONFIGURE WAZUH AGENT ON LINUX (IDS01 itself / ATTACKER monitoring) 3
Phase 8 – Sysmon Installation and Configuration with Wazuh 5
CONFIGURE LOG COLLECTION ON WAZUH AGENTS 15
CREATE CUSTOM DETECTION RULES IN WAZUH 17
PHASE 9 — MITRE ATT&CK MAPPING 22
UNDERSTAND AND VERIFY YOUR MITRE MAPPINGS 22
PHASE 10 — ATTACK SIMULATION FROM KALI 24
UPGRADE ATTACKER TOOLS 24
ATTACK 1: NETWORK RECONNAISSANCE (T1046) 25
ATTACK 2: SMB ENUMERATION (T1021.002) 27
ATTACK 3: BRUTE FORCE ATTACK (T1110) 29
ATTACK 4: CRACKMAPEXEC ADVANCED CREDENTIAL ATTACKS 31
PHASE 11 — ACTIVE RESPONSE (AUTO-BLOCK ATTACKER) 32
CONFIGURE ACTIVE RESPONSE IN WAZUH 32
Conclusion 35

Introduction

Module 5 focuses on Endpoint Security for Windows Systems, covering the full lifecycle of securing a Windows-based enterprise environment. This module builds on the existing lab infrastructure by adding new virtual machines, configuring role-based access control, applying Microsoft security baselines, deploying patch management, hardening Windows systems, and setting up a Wazuh SIEM for real-time threat detection and response. Attack simulations are performed from a Kali Linux machine to validate that all defensive controls are working correctly.

VIRTUAL MACHINES REQUIRED FOR MODULE 5

You need **2 new VMs** on top of what you already have:

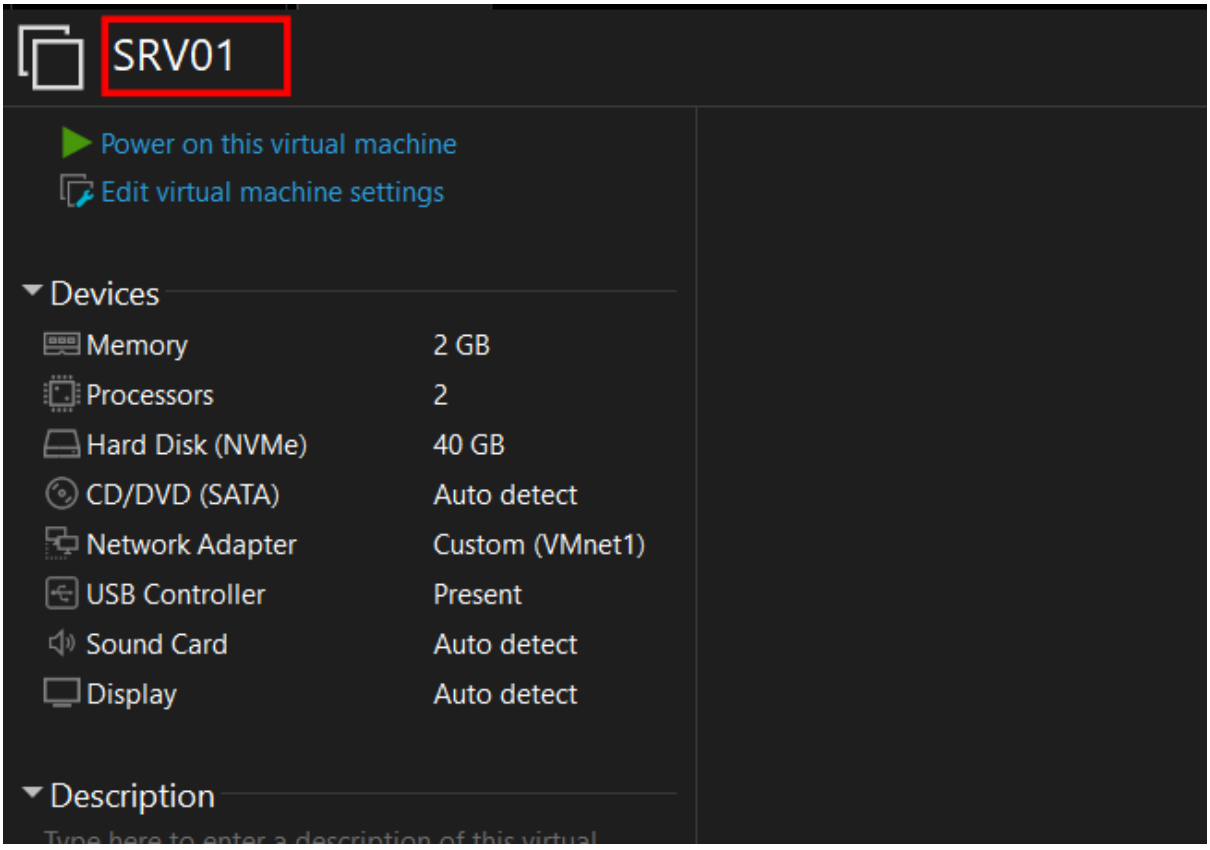
VM	IP	OS	Status
DC01	192.168.10.10	Windows Server 2019	Existing
ADMIN01	192.168.10.20	Windows 10	Existing
CL01	192.168.10.30	Windows 10	Existing
VPN01	192.168.10.50	Windows Server	Existing
IDS01	192.168.10.60	Kali/Ubuntu	Existing — gets upgraded to Wazuh
ATTACKER	192.168.10.40	Kali Linux	Existing — gets upgraded
SRV01	**192.168.10.25**	**Windows Server 2019**	**Use VPN Server Machine**
CL02	**192.168.10.102**	**Windows 10**	**NEW — create this**

PHASE 1 — CREATE NEW VIRTUAL MACHINES

1. Creating and Configuring SRV01 (Windows Server 2019)

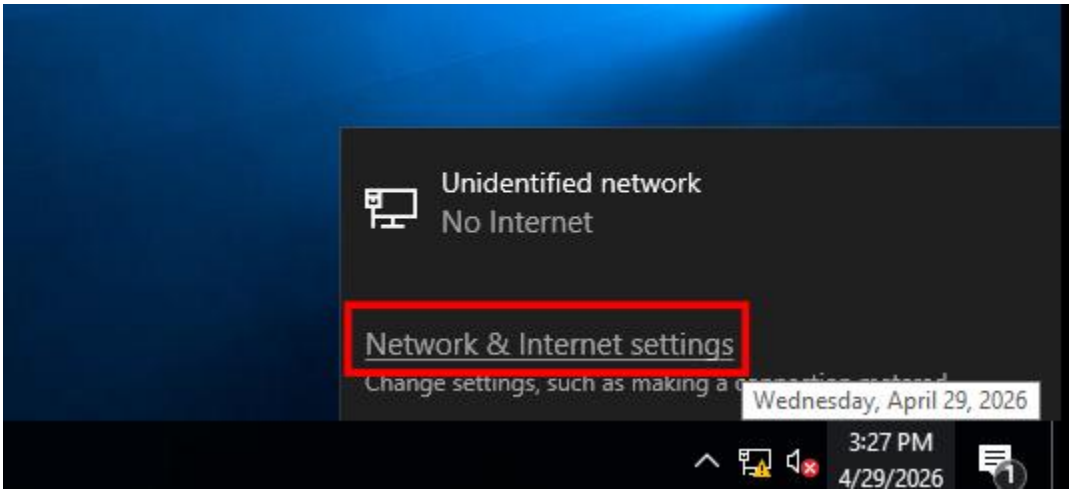
SRV01 is your Patch Management Server and Secure File Server. This machine runs Batch Patch and hosts the Finance Data RBAC share.

- Use Windows Server 2019 VPN
- Rename it to SRV01

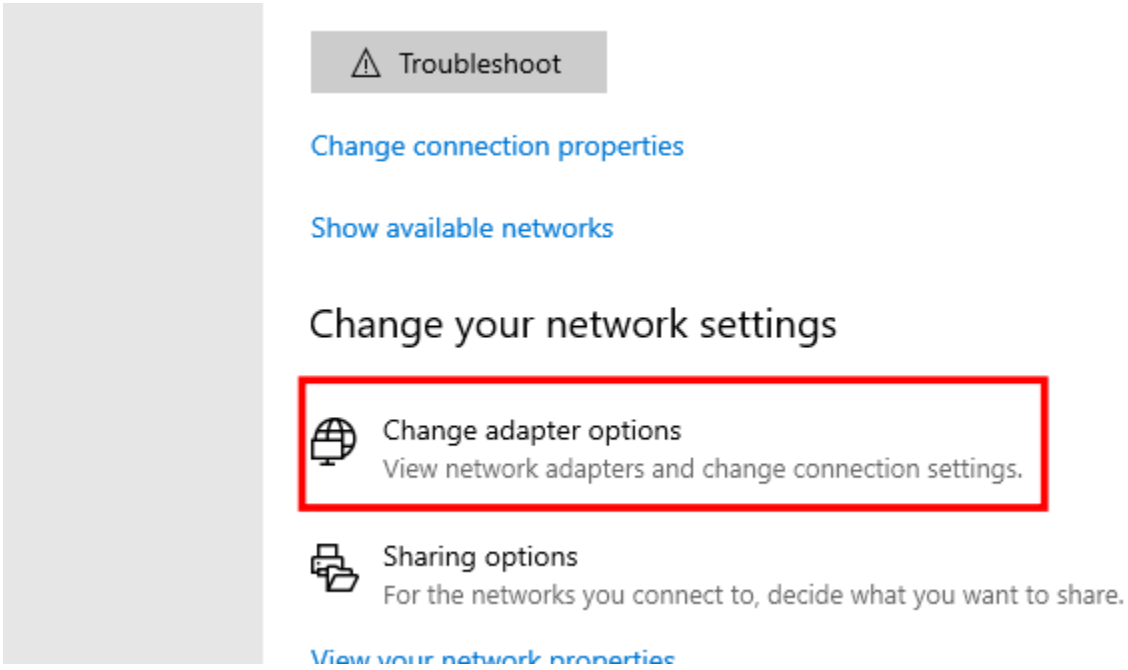


1.1 Configure Static IP on SRV01:

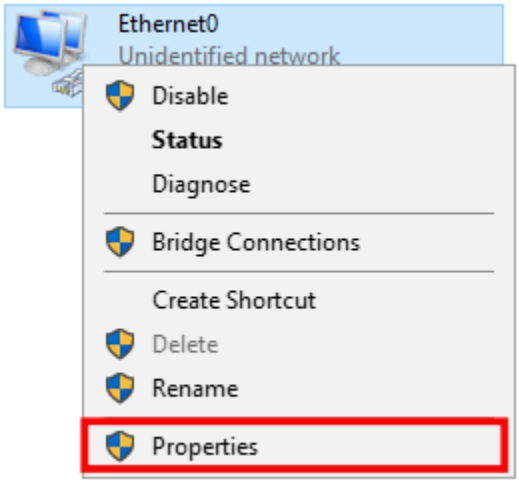
1. Right-click the network icon in taskbar → **Open Network & Internet Settings**



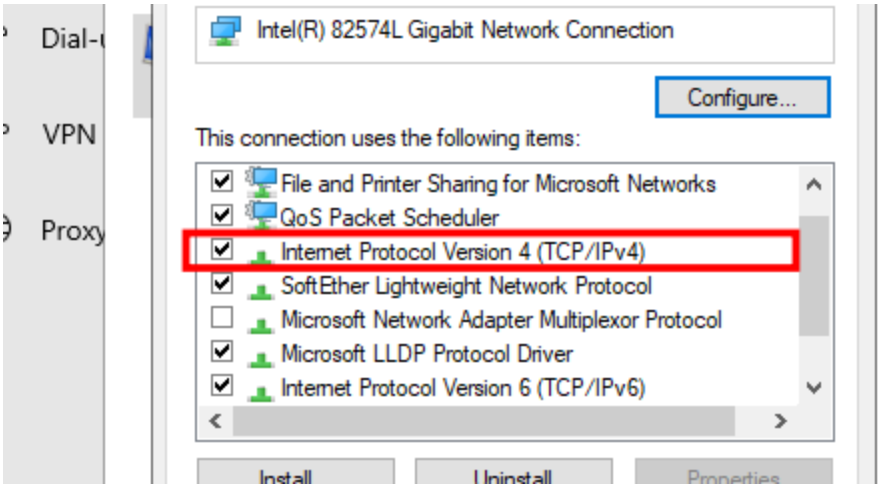
2. Click **Change Adapter Options**



3. Right-click your Ethernet adapter → **Properties**

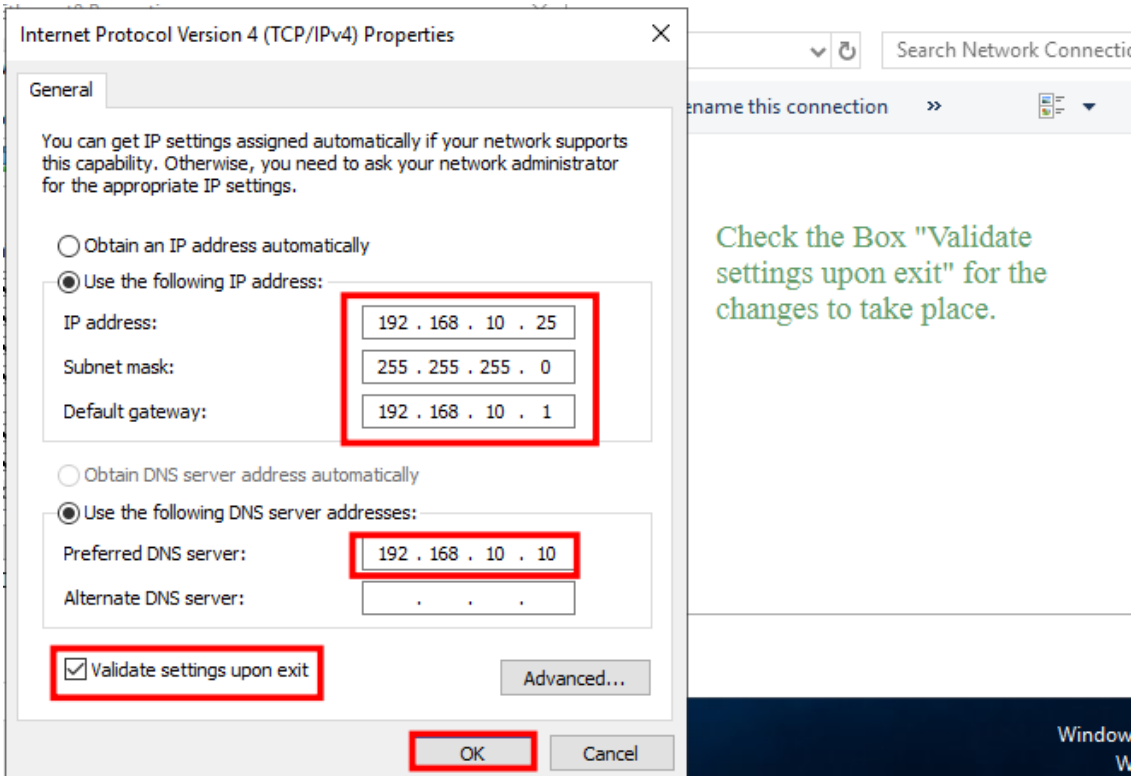


4. Double-click **Internet Protocol Version 4 (TCP/IPv4)**



5. Select **Use the following IP address** and enter:

- IP address: 192.168.10.25
- Subnet mask: 255.255.255.0
- Default gateway: 192.168.10.1
- Preferred DNS server: 192.168.10.10 (DC01)



6. Open CMD → type ipconfig /all → confirm IP shows 192.168.10.25

```
C:\Users\Administrator>ipconfig

Windows IP Configuration


Ethernet adapter Ethernet0:

   Connection-specific DNS Suffix  . :
   Link-local IPv6 Address . . . . . : fe80::5d8c:ea3:a062:c46f%7
   IPv4 Address. . . . . . . . . . . : 192.168.10.25
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 192.168.10.1

C:\Users\Administrator>ipconfig /all
```

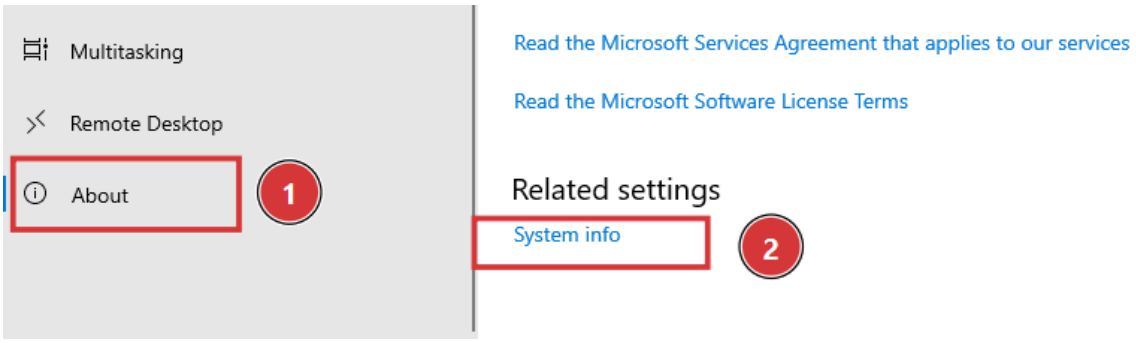
7. Type ping 192.168.10.10 → should get replies from DC01

```
C:\Users\Administrator>ping 192.168.10.10

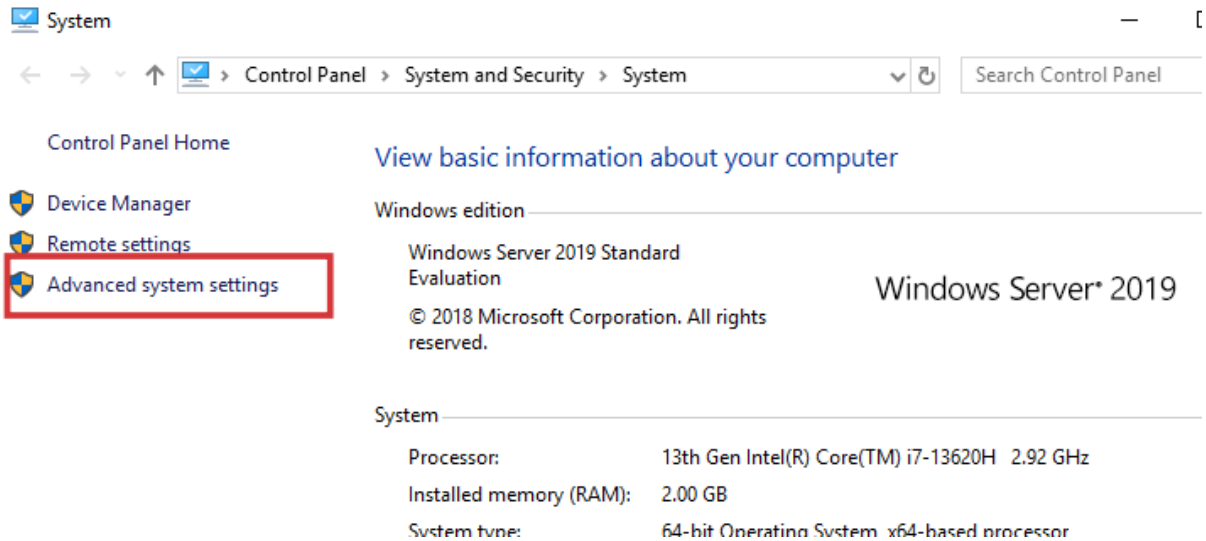
Pinging 192.168.10.10 with 32 bytes of data:
Reply from 192.168.10.10: bytes=32 time<1ms TTL=128
Reply from 192.168.10.10: bytes=32 time<1ms TTL=128
Reply from 192.168.10.10: bytes=32 time=1ms TTL=128
```

1.2 Rename SRV01 and Join Domain:

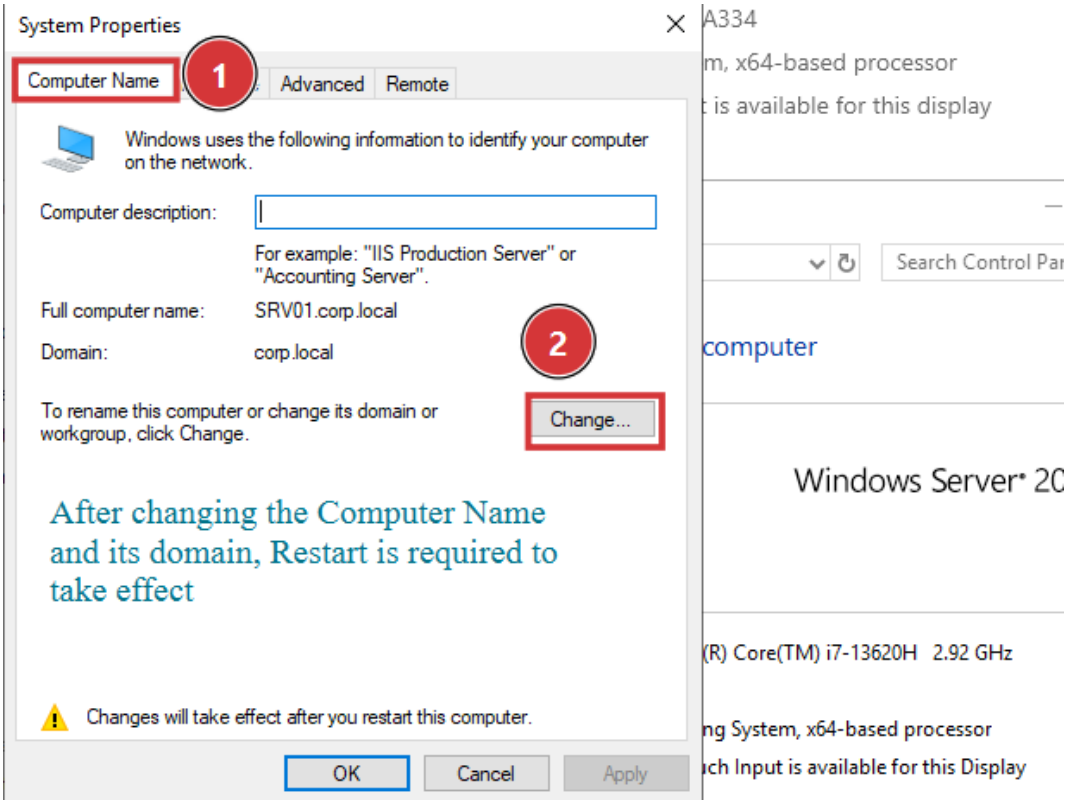
1. Change your hostname by going to settings → About → System info



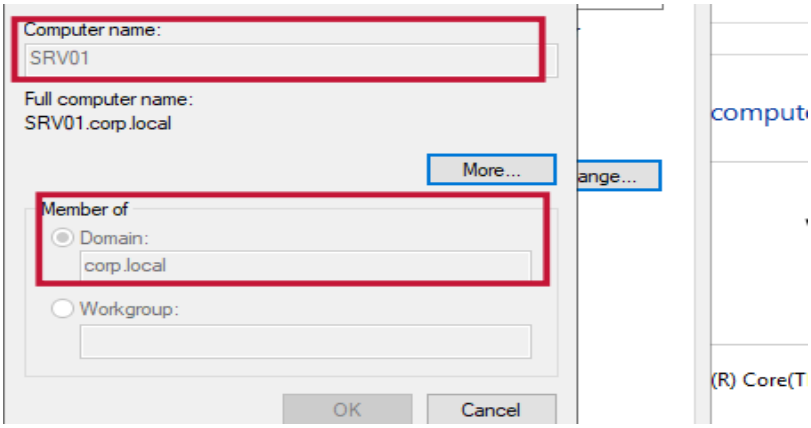
2. Click on Advanced system Settings



3. Go to Computer Name Tab and then click on "Change"



4. Under Computer name: type SRV01 and under Member of: select **Domain** → type corp.local



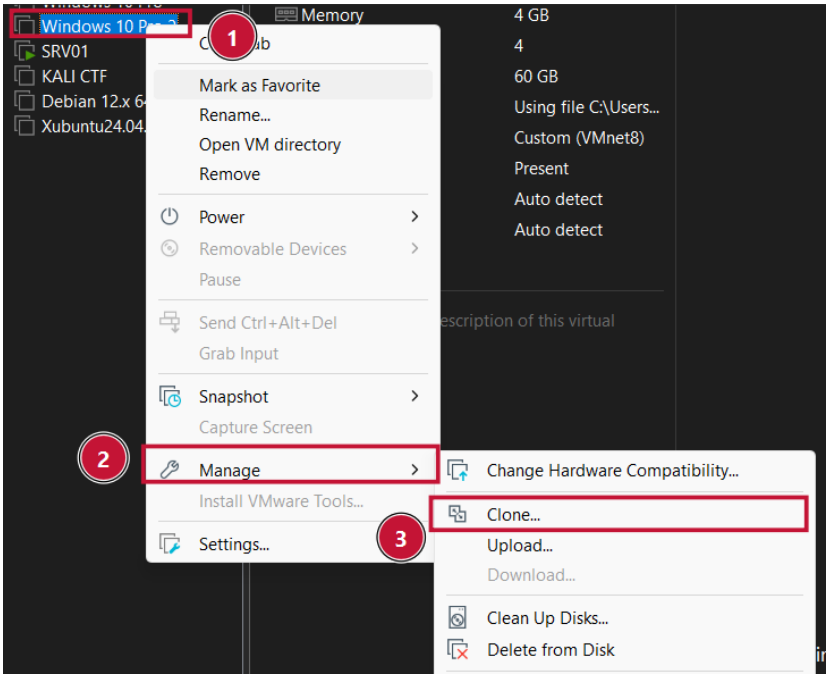
Note: After all these changes restart your Virtual Machine, if you have used Windows Server VPN then just set the Ip Address and Default Gateway

2. Creating and Configuring CL02 (Windows 10 — Unauthorized User Machine)

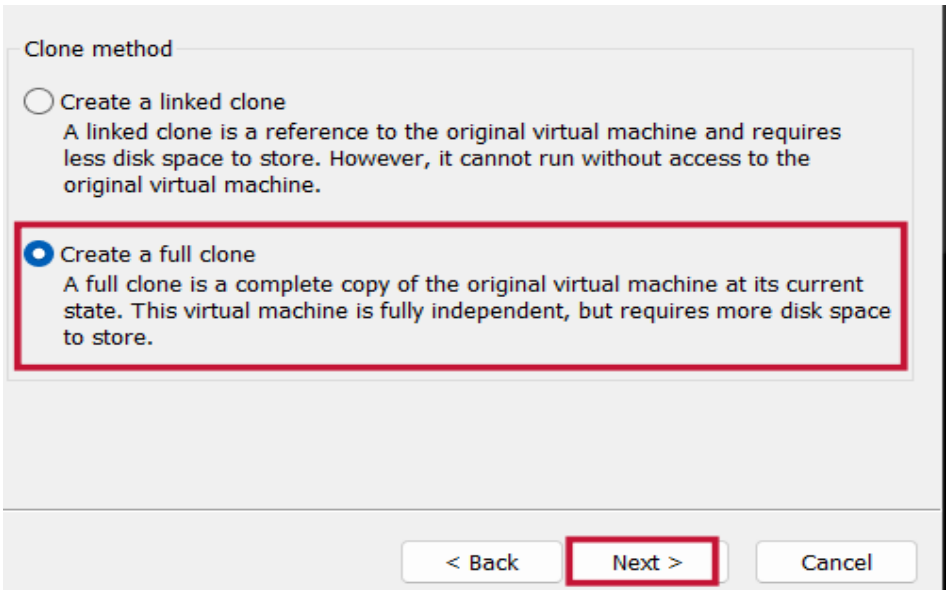
CL02 is the machine that represents an unauthorized user (martin) who should be DENIED access to Finance Data.

Go to VMware Workstation:

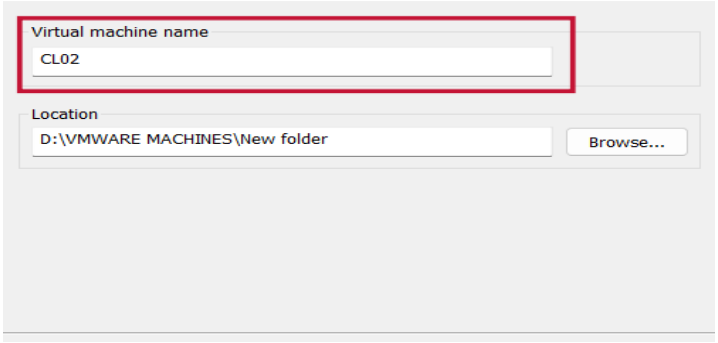
1. Clone your CL01 Virtual Machines (Windows 10 Pro 2)



2. Create a Full Clone

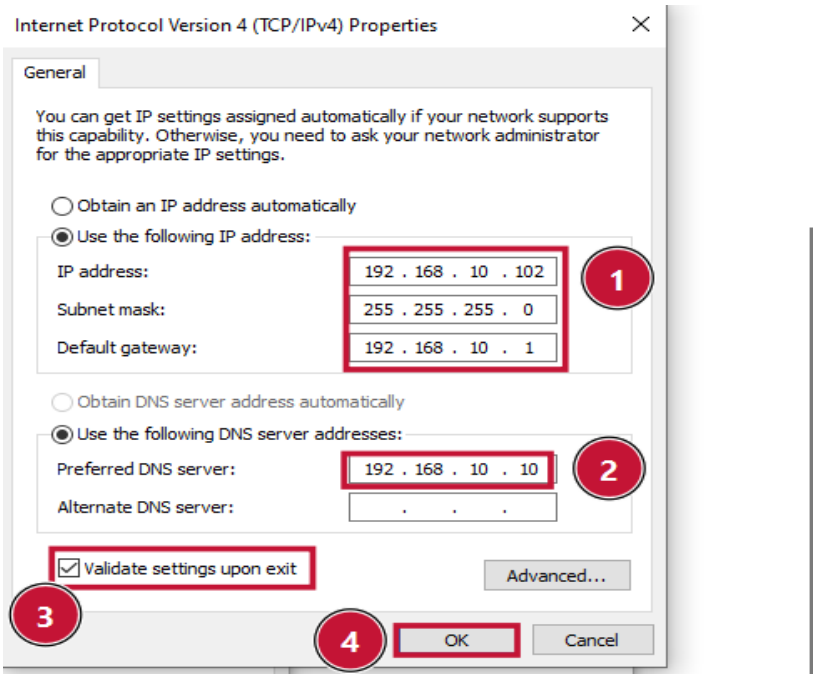


3. Name your Virtual Machine to CL02



2.1 Configure Static IP on CL02:

1. Network icon → Open Network & Internet Settings → Change Adapter Options
2. Right-click Ethernet → Properties → IPv4 → Properties
3. Enter:
    - IP: 192.168.10.102
    - Subnet: 255.255.255.0
    - Gateway: 192.168.10.1
    - DNS: 192.168.10.10



4. Click OK → Open CMD → ping 192.168.10.10 → should reply

```
Microsoft Windows [Version 10.0.19045.6456]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Administrator>ping 192.168.10.10

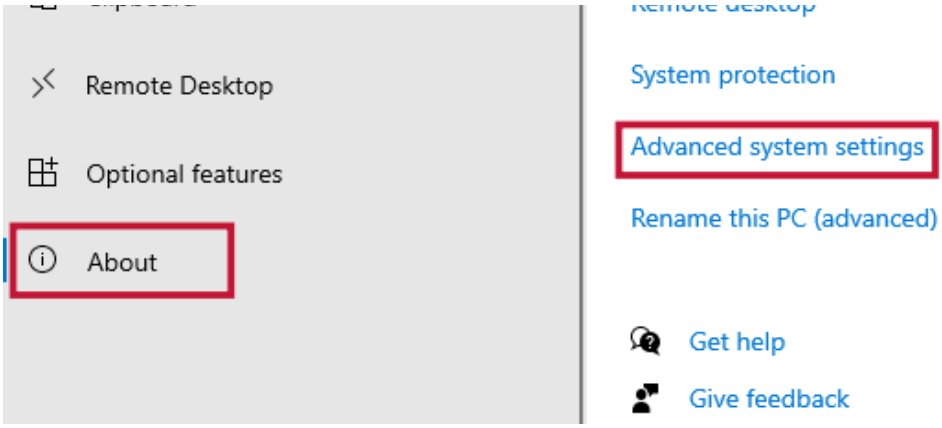
Pinging 192.168.10.10 with 32 bytes of data:
Reply from 192.168.10.10: bytes=32 time<1ms TTL=128
Reply from 192.168.10.10: bytes=32 time<1ms TTL=128
Reply from 192.168.10.10: bytes=32 time=1ms TTL=128
Reply from 192.168.10.10: bytes=32 time=1ms TTL=128

Ping statistics for 192.168.10.10:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 1ms, Average = 0ms

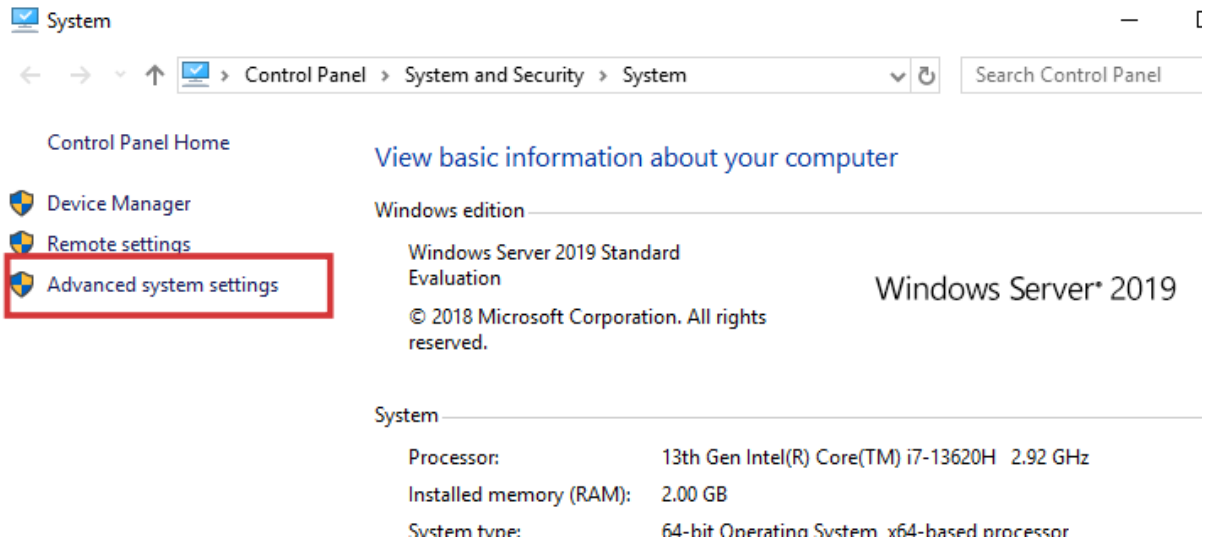
C:\Users\Administrator>
```

2.2 Join CL02 to Domain:

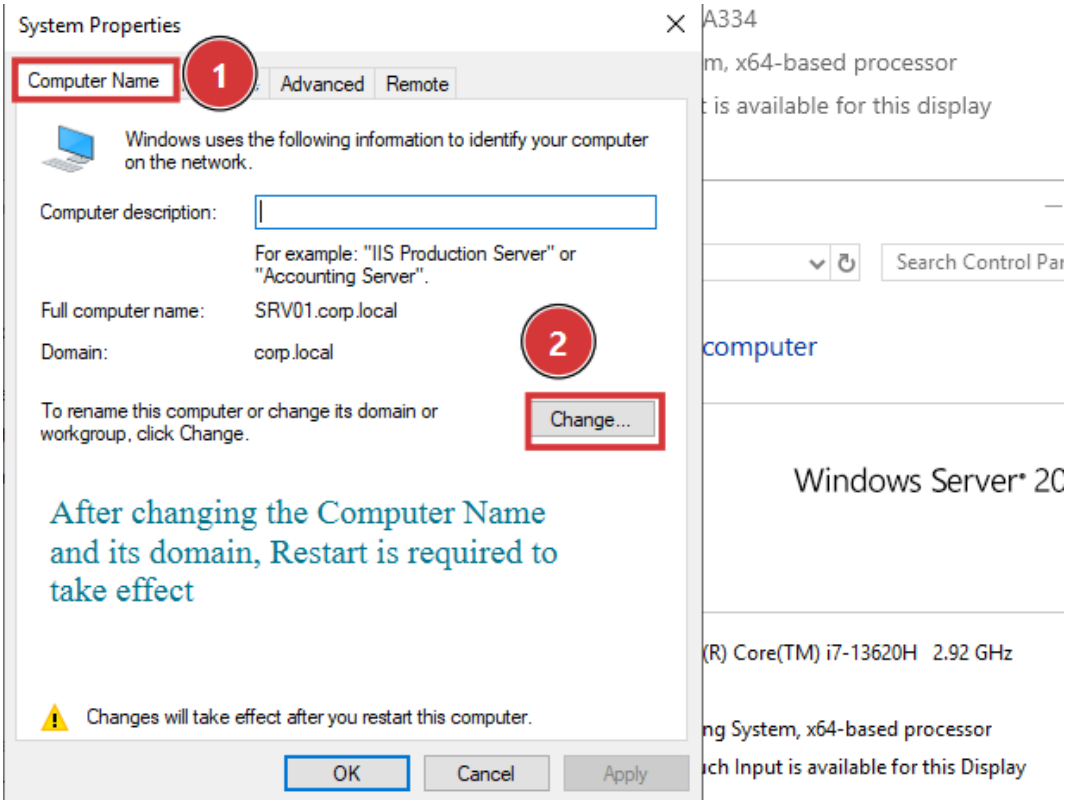
1. Change your hostname by going to settings → About → Advanced system settings



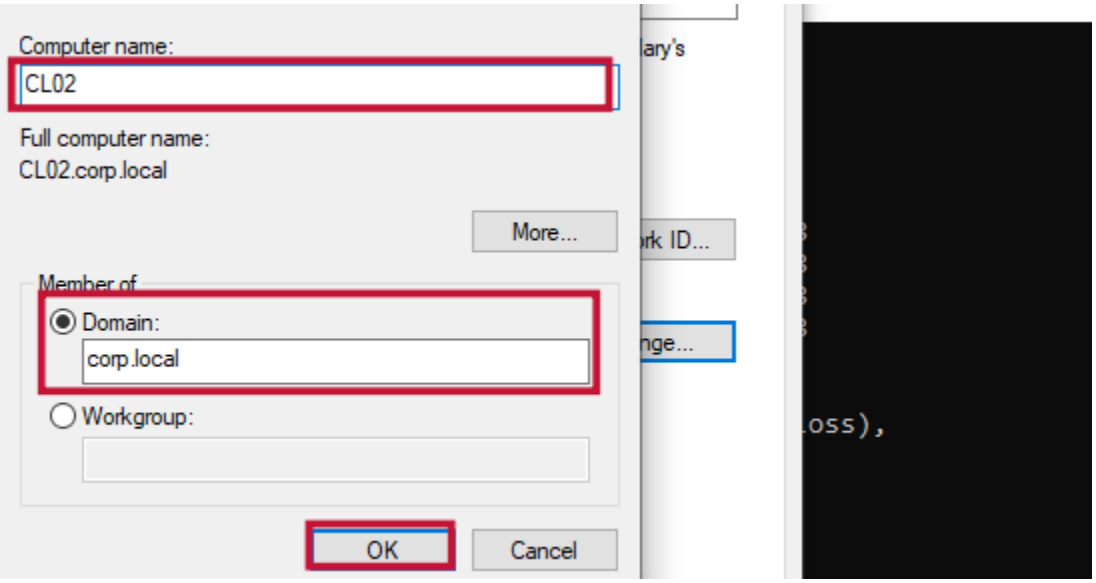
2. Click on Advanced system Settings



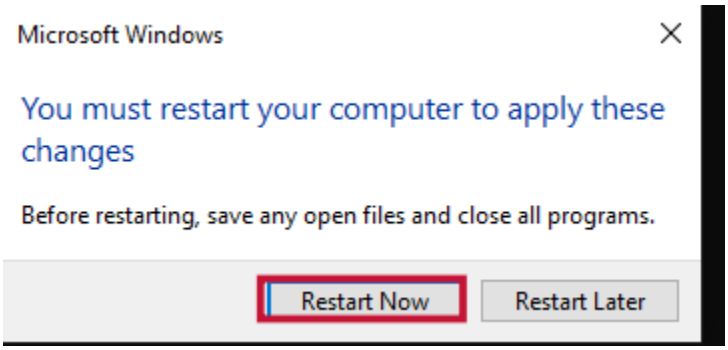
3. Go to Computer Name Tab and then click on "Change"



4. Under Computer name: type SRV01 and under Member of: select **Domain** → type corp.local



5. Restart → login as CORP\Administrator

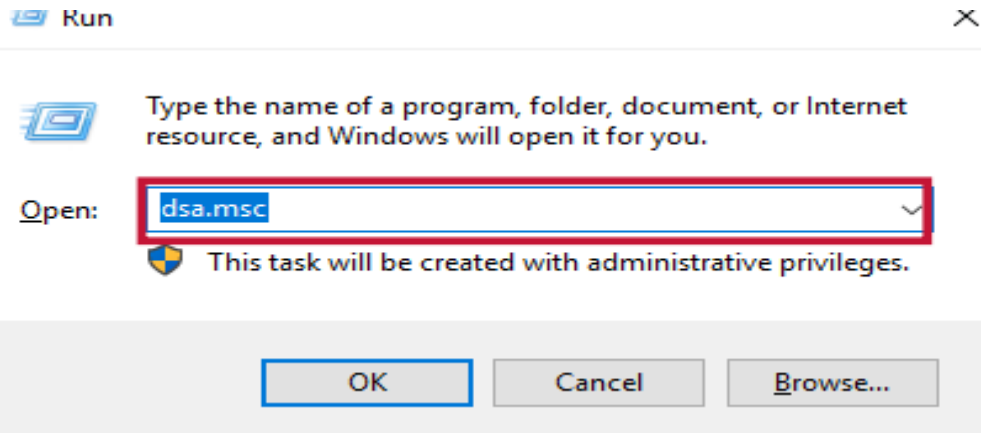


PHASE 2 — ACTIVE DIRECTORY — RBAC USERS & GROUPS

Do all of this on **DC01**.

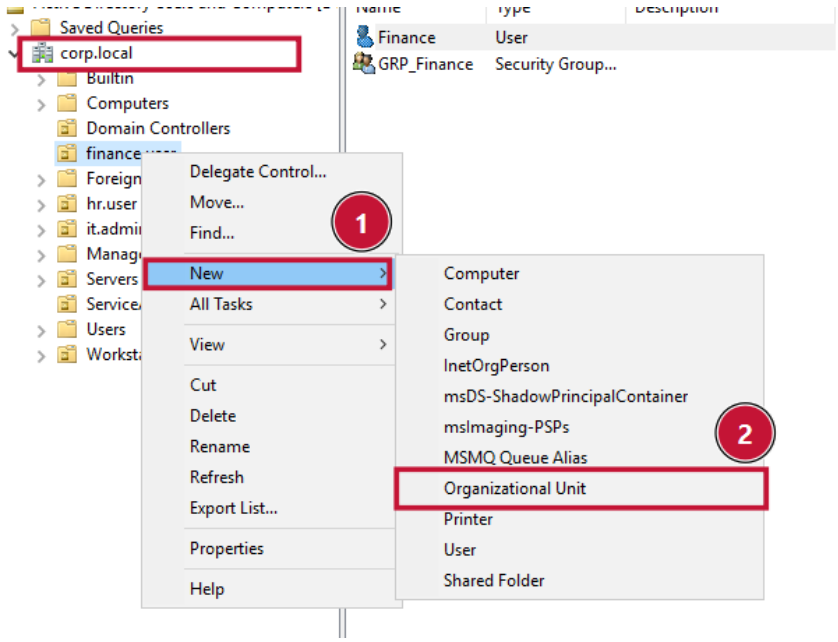
1. CREATE MODULE 5 USERS IN ACTIVE DIRECTORY

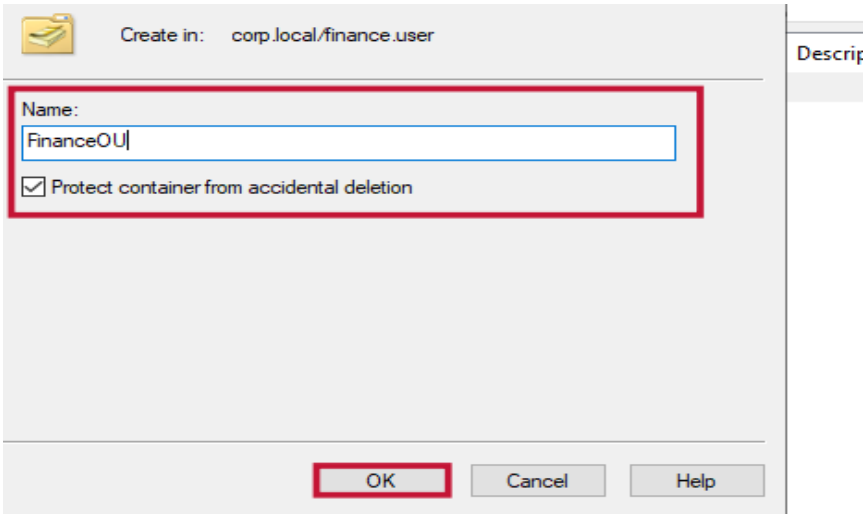
Go to **DC01** → Open **Active Directory Users and Computers** (Win+R → dsa.msc).



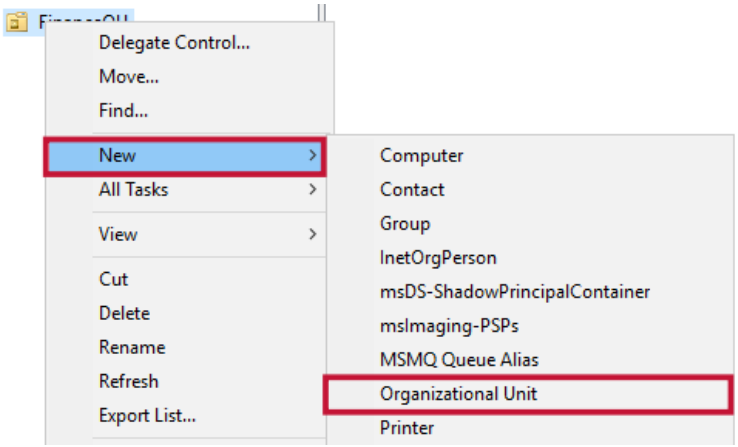
1.1 Create Finance OU structure (if not already existing from Module 2):

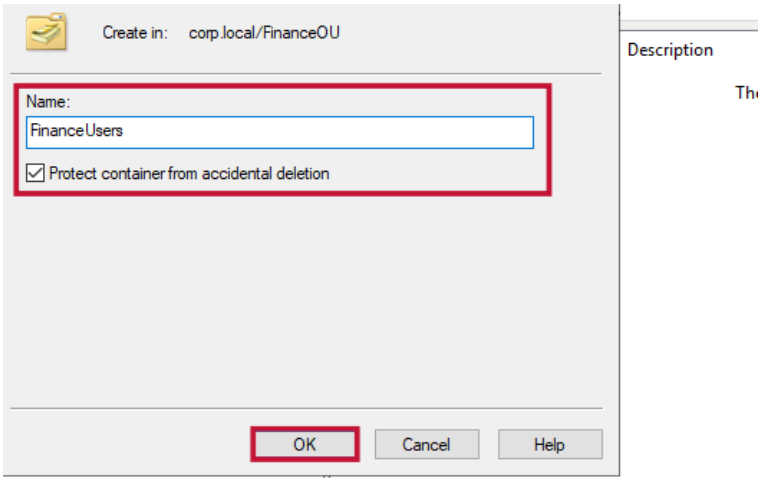
1. Right-click corp. local → New → Organizational Unit → Name: Finance → OK





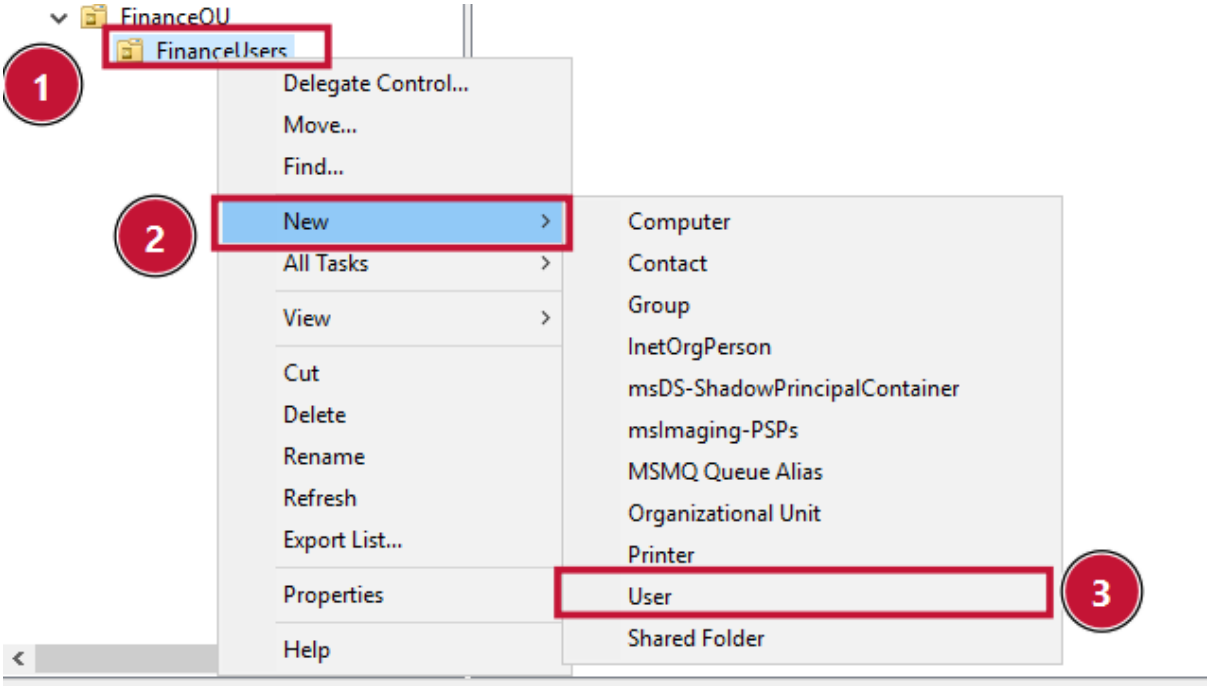
2. Right-click FinanceOU → New → Organizational Unit → Name: FinanceUsers → OK



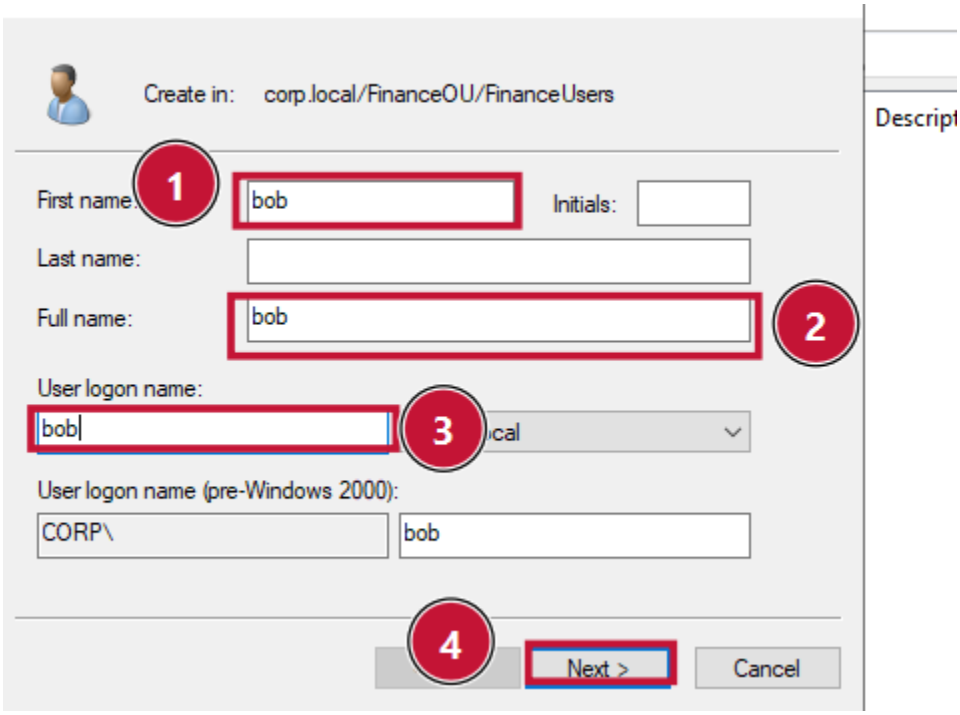


1.2 Create user bob (authorized finance user):

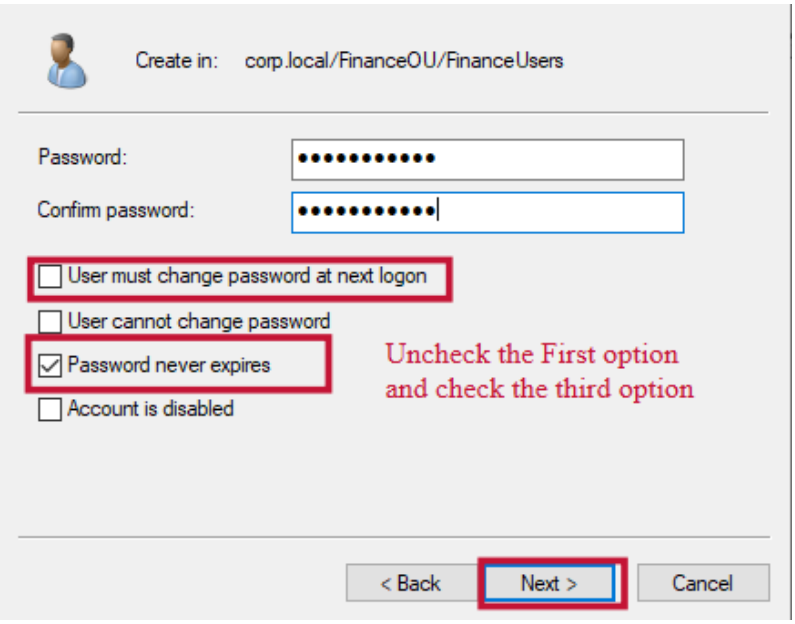
1. Right-click Finance Users OU → New → User



2. First name: bob | User logon name: bob → Next

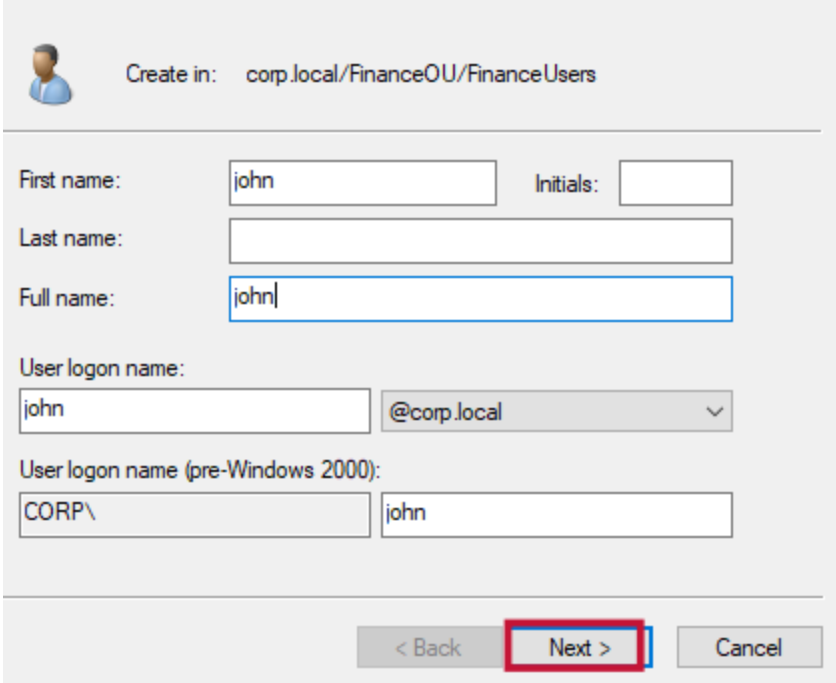


3. Password: Finance@123 → Uncheck "User must change password at next logon" → Check "Password never expires" → Next → Finish

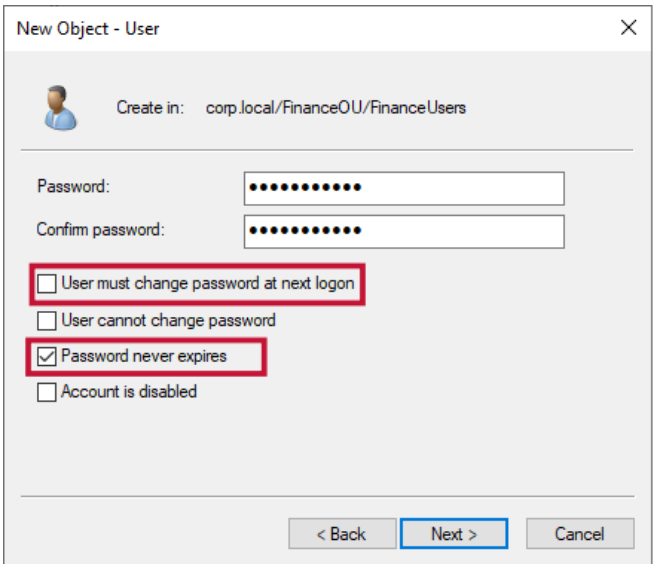


1.3 Create user john (authorized finance user):

1. Right-click Finance Users OU → New → User
2. First name: john | User logon name: john → Next



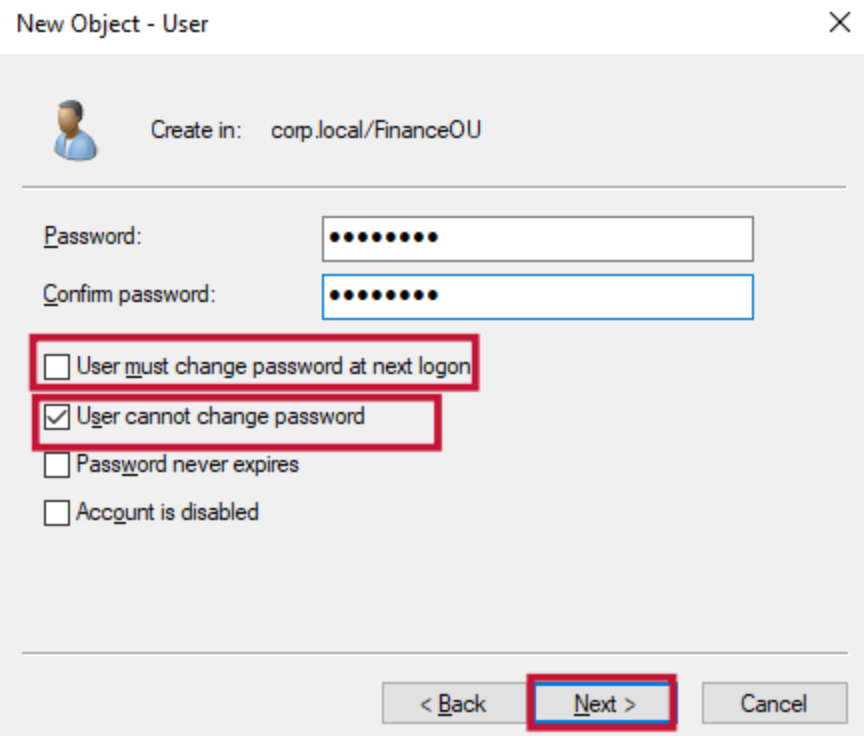
3. Password: Finance@123 → Uncheck must change → Check never expires → Finish



Uncheck "User must change password at next logon" and check "Password never expires".

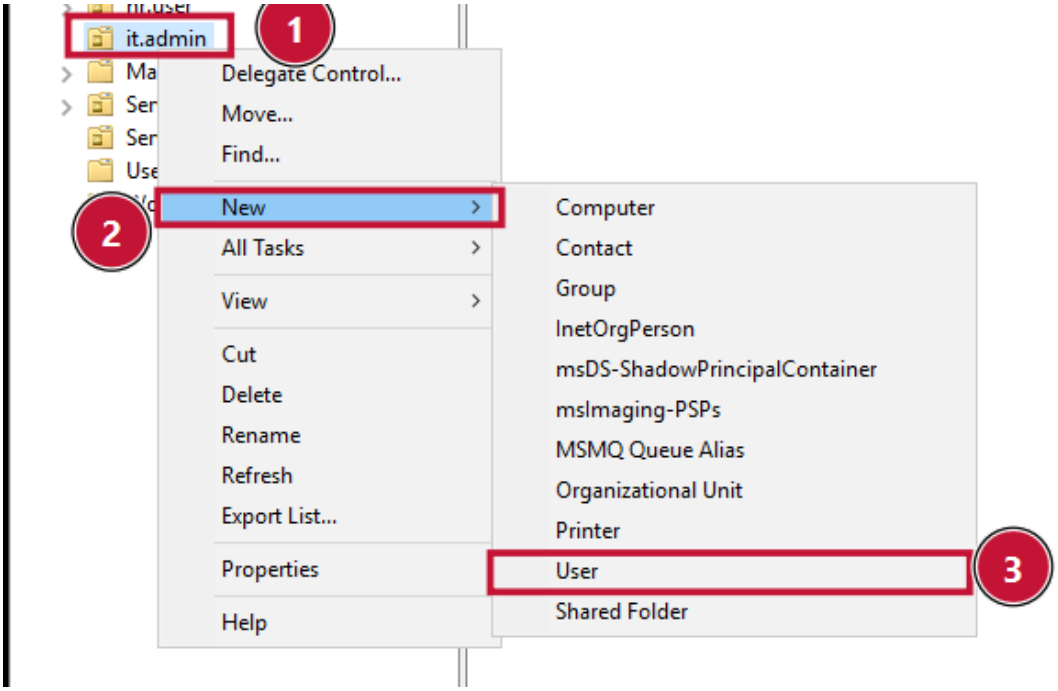
1.4 Create user martin (UNAUTHORIZED user — no finance access):

1. Right-click Finance Users OU → New → User
2. First name: martin | User logon name: martin → Next
3. Password: User@123 → Uncheck must change → Check never expires → Finish

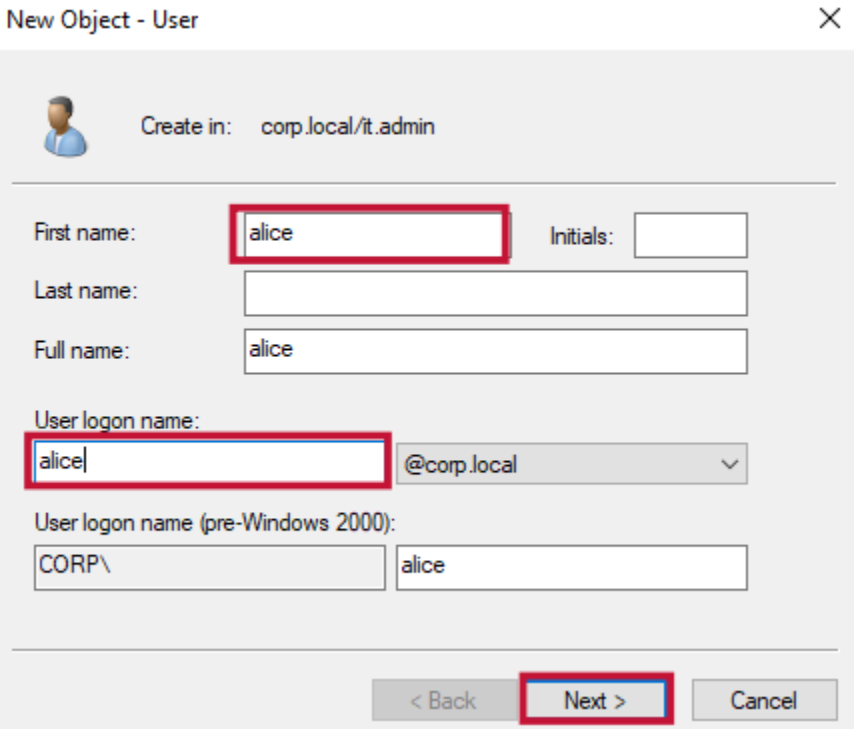


1.5 Create user alice (general client user):

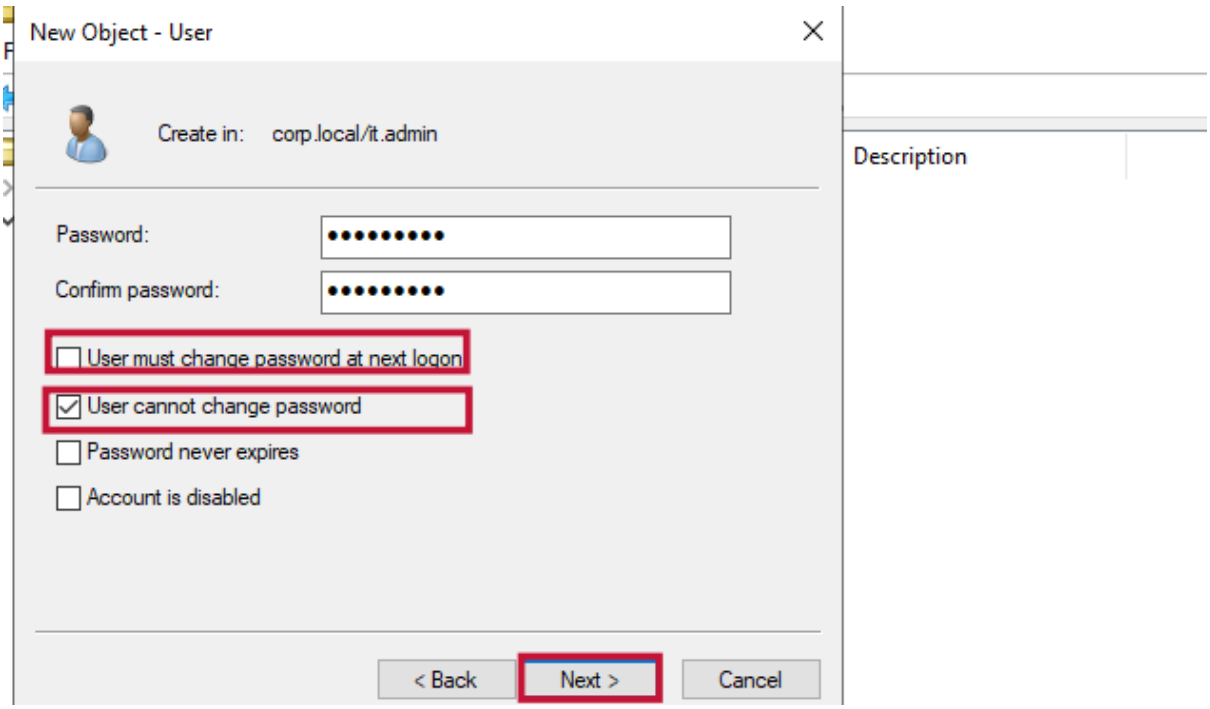
1. Right-click your existing **IT OU** (or create a GeneralOU) → New → User



2. First name: alice | User logon name: alice → Next

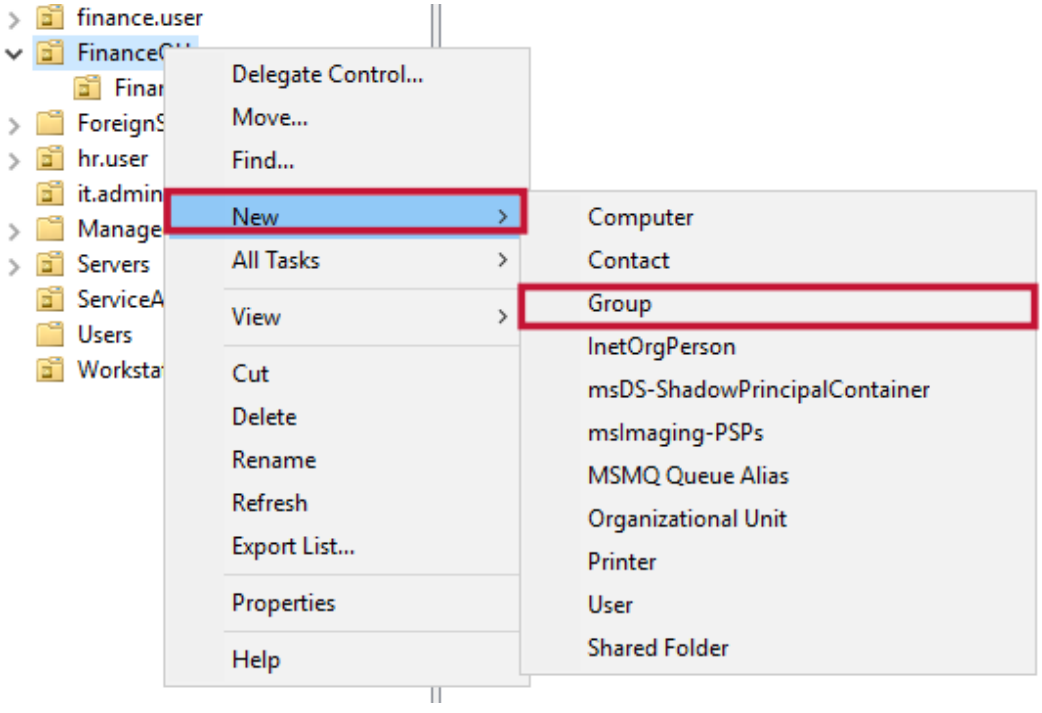


3. Password: AirUniversity@#$1122 → same settings → Finish

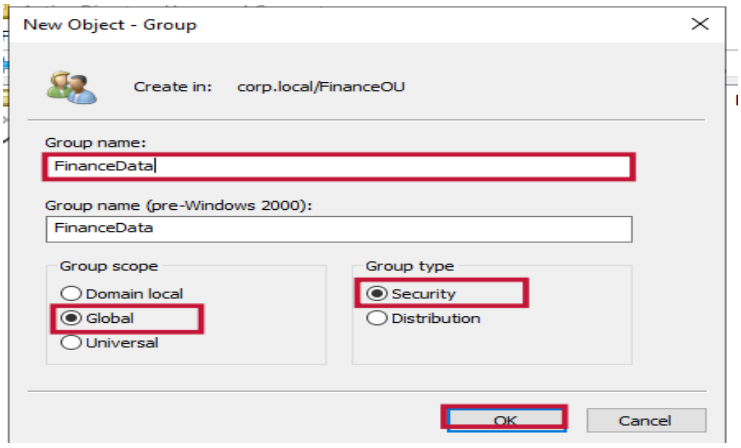


1.6 Create the FinanceData Security Group:

1. Right-click FinanceOU → New → Group

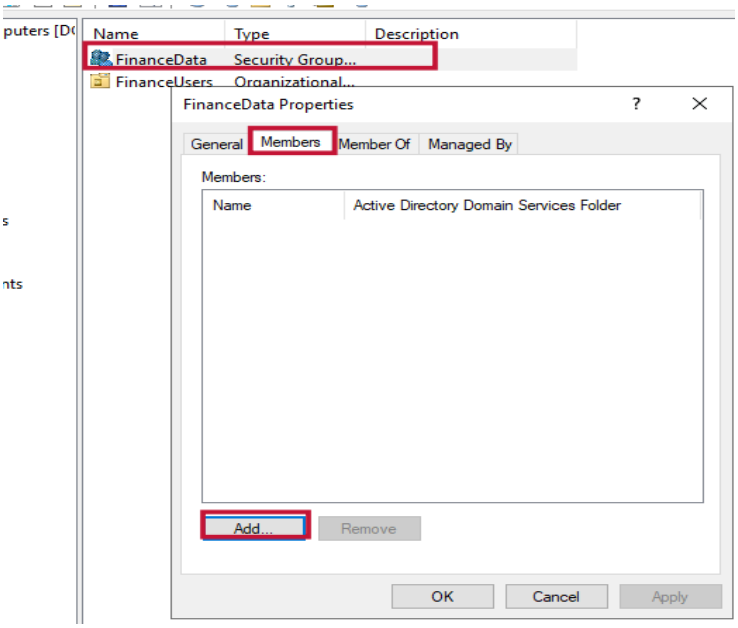


2. Group name: FinanceData
3. Group scope: **Global**
4. Group type: **Security**
5. Click OK

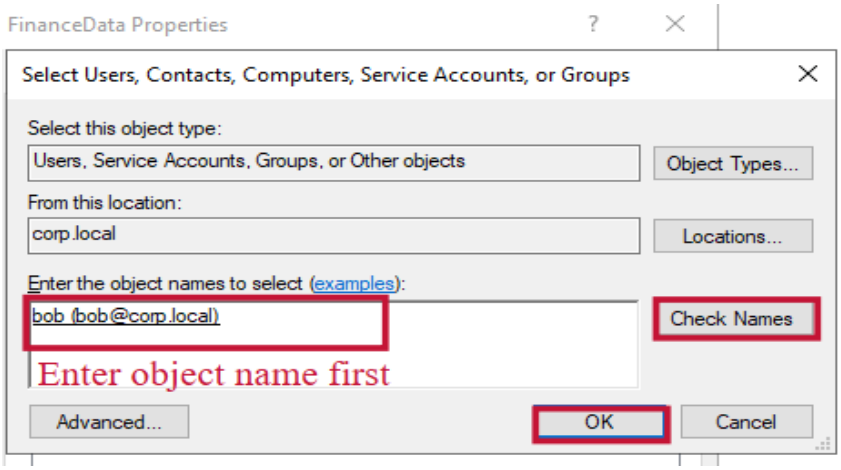


1.7 Add bob and john to Finance Data group:

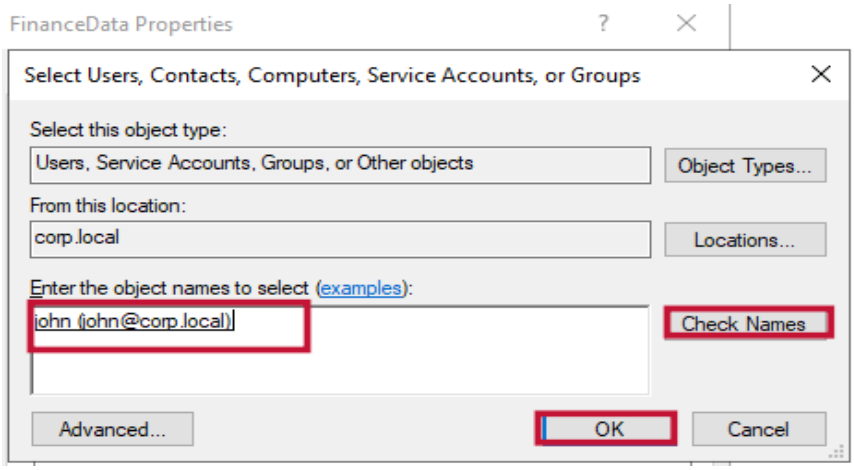
1. Double-click the Finance Data group → Members tab → Add



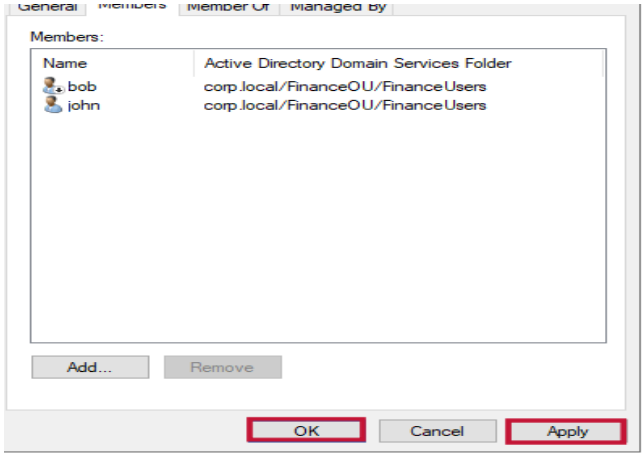
2. Type bob → Check Names → OK



3. Click Add again → type john → Check Names → OK

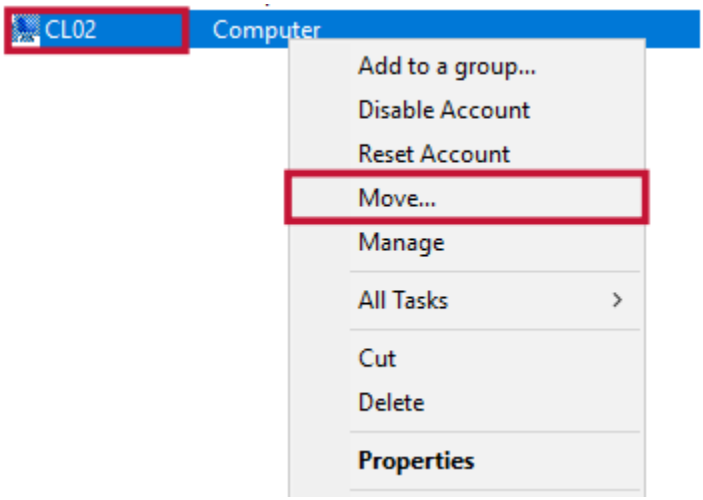


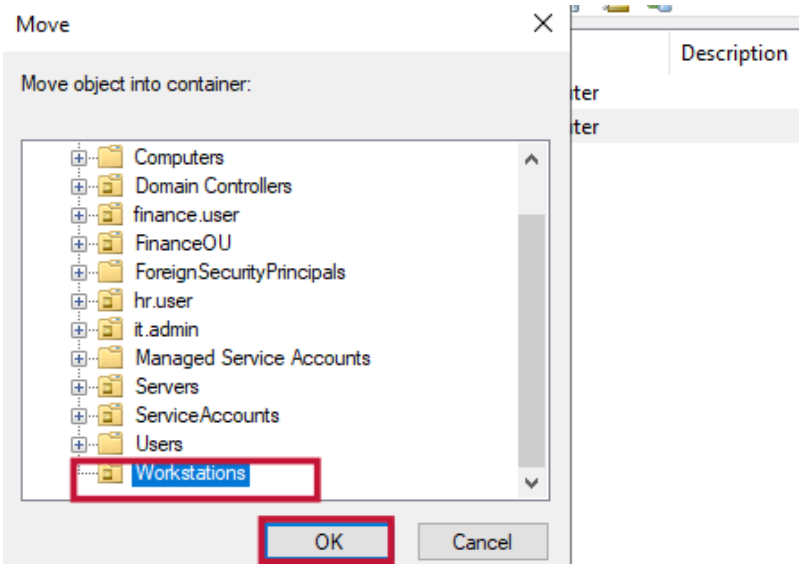
4. Click OK → Apply



1.8 Move CL02 to appropriate OU:

1. In Active Directory Users and Computers, find CL02 under Computers
2. Right-click CL02 → Move → select Workstations OU → OK





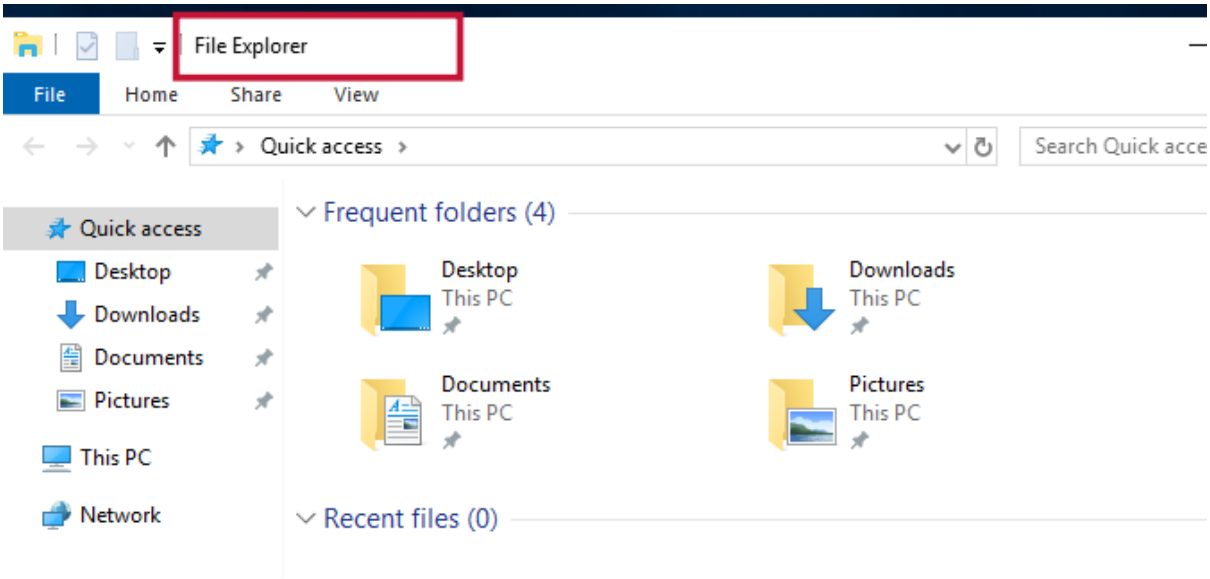
PHASE 3 — SECURE FILE SHARING WITH RBAC ON SRV01

Go to **SRV01** for everything in this phase.

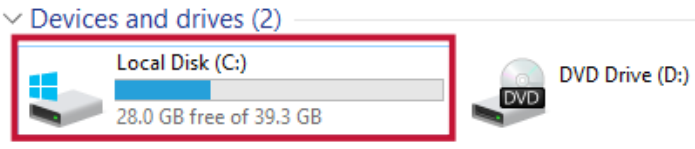
STEP 4 — CREATE AND CONFIGURE THE FINANCEDATA SHARE

Create the folder:

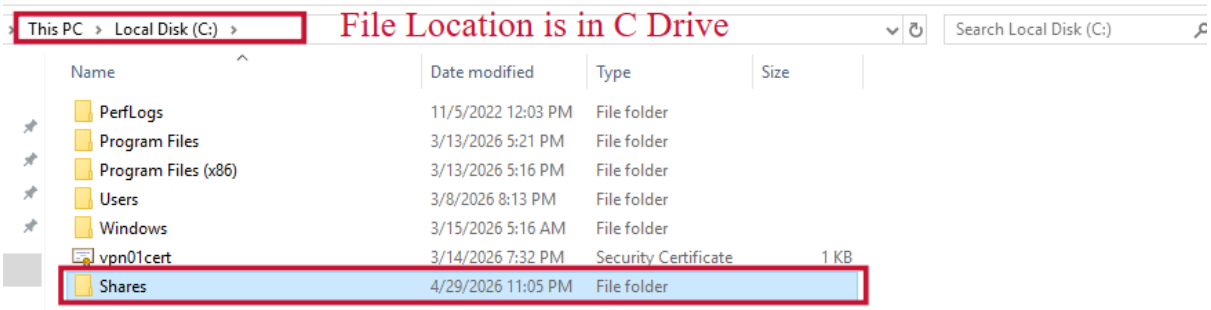
1. Open **File Explorer** on SRV01



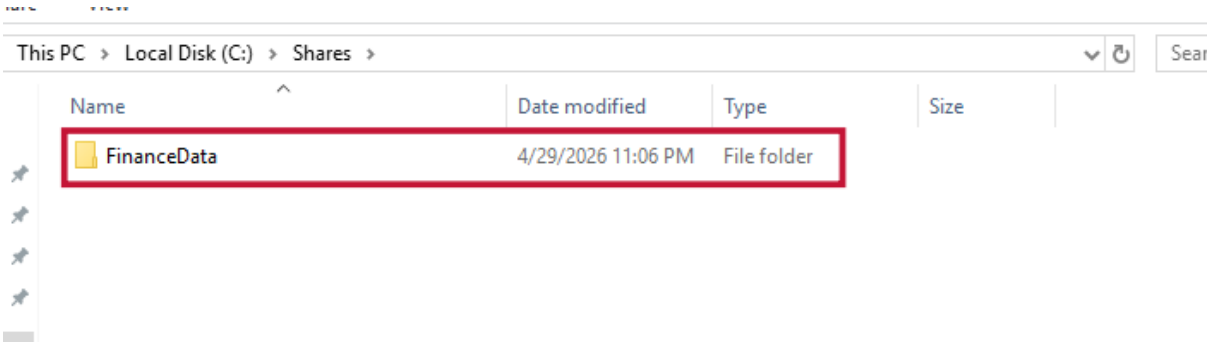
2. Go to your D: drive (if it exists) or C: drive



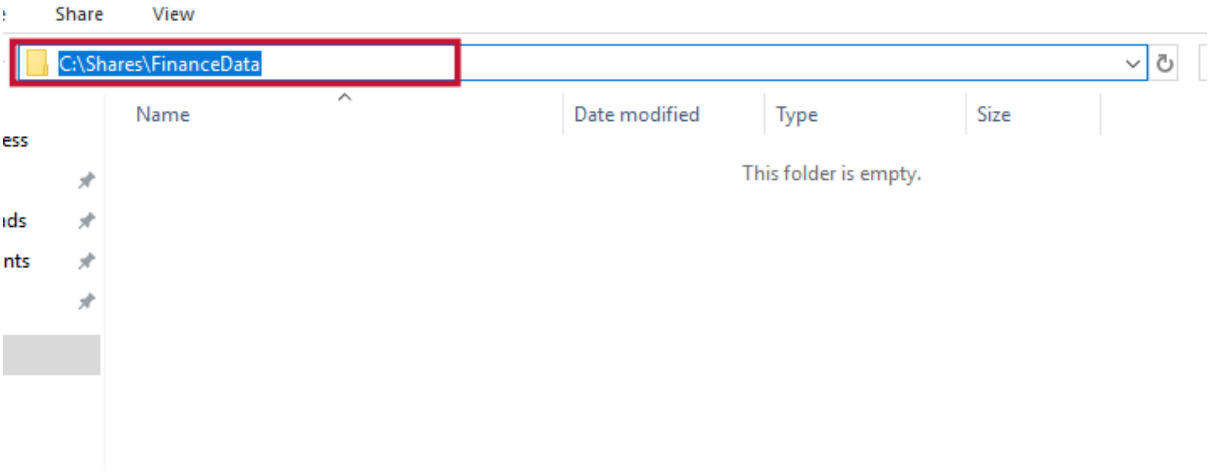
3. Create the path: right-click in File Explorer → New → Folder → name it Shares



4. Open Shares → right-click → New → Folder → name it FinanceData

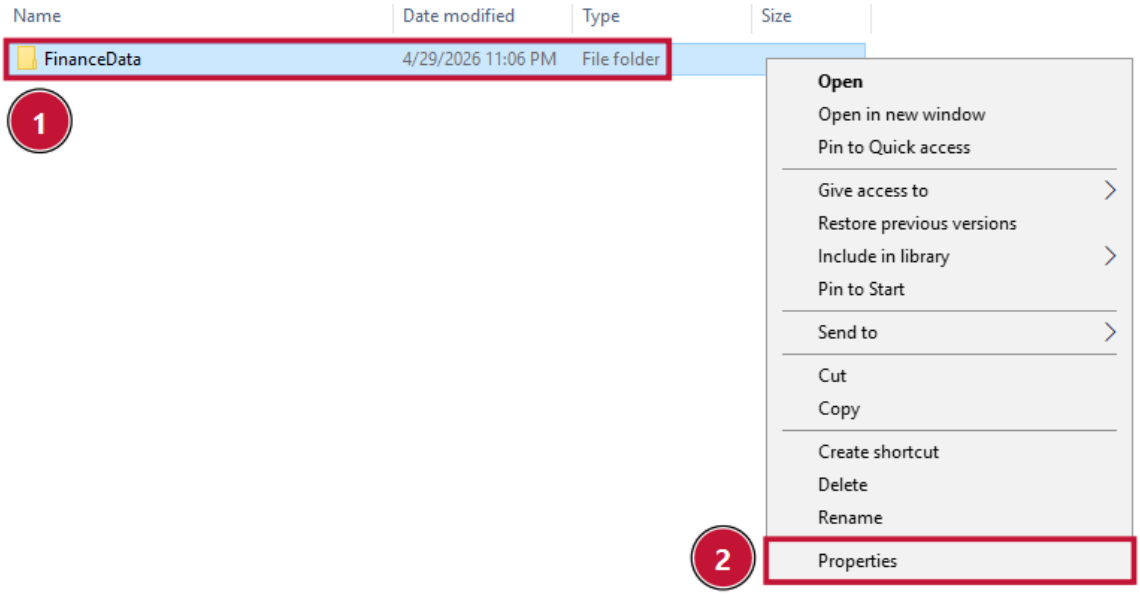


5. So, your full path is: C:\Shares\FinanceData (or D:\Shares\FinanceData)

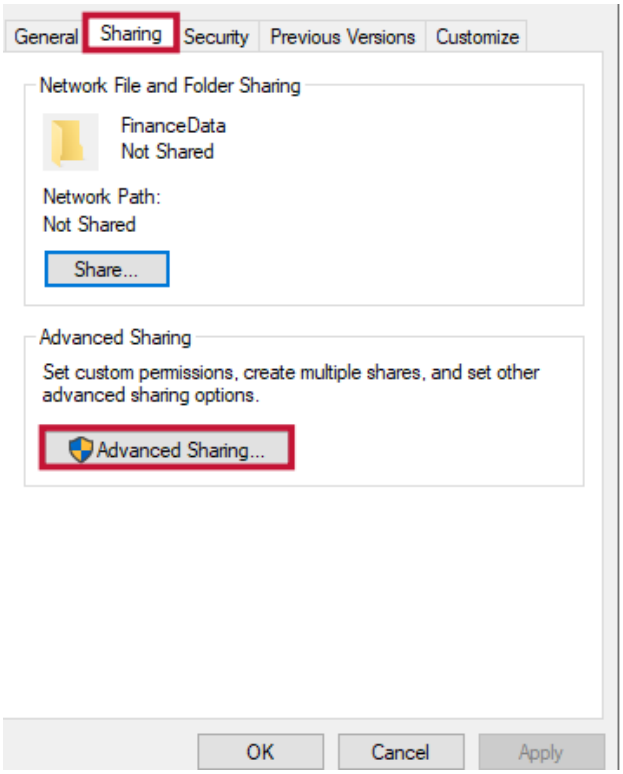


Configure Share Permissions:

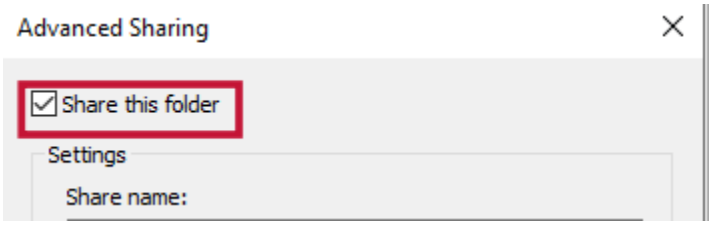
1. Right-click the FinanceData folder → **Properties**



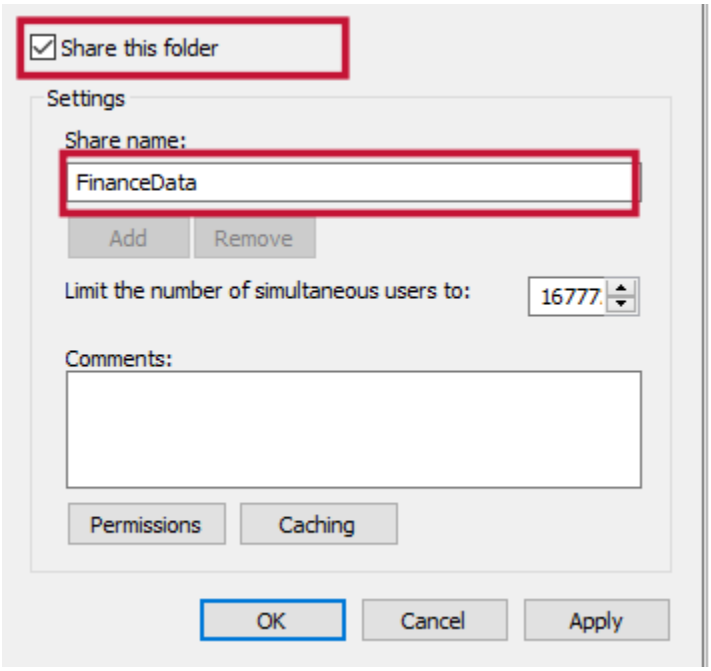
2. Go to the **Sharing** tab → Click **Advanced Sharing**



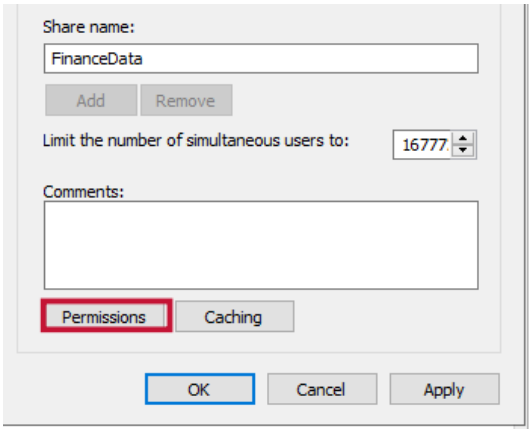
3. Check **Share this folder**



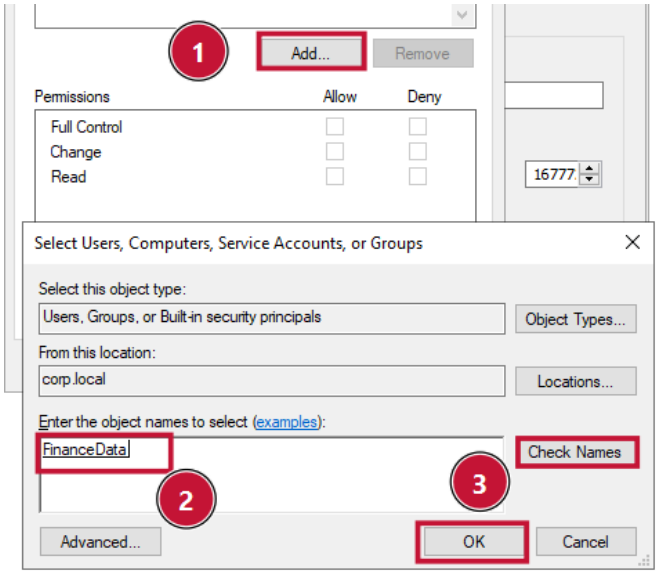
4. Share name: FinanceData



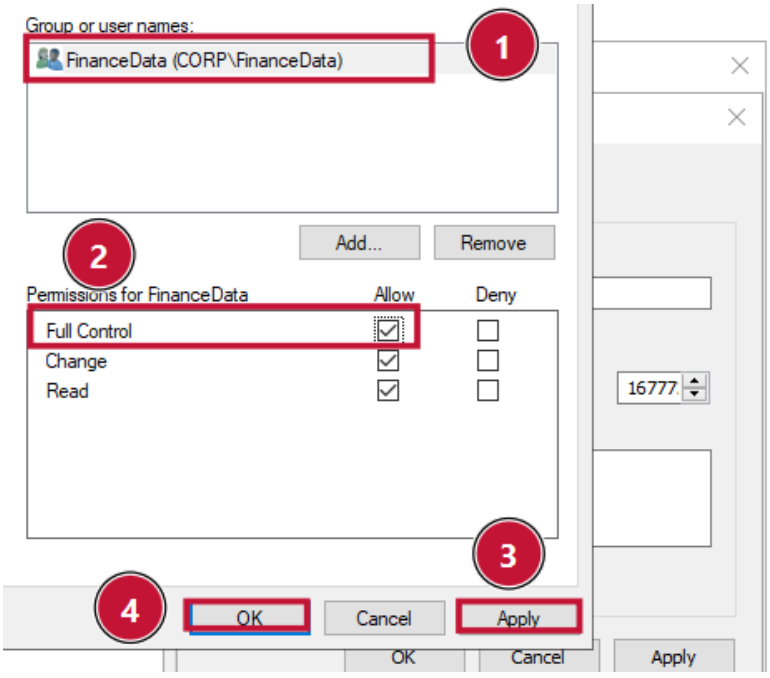
5. Click **Permissions**



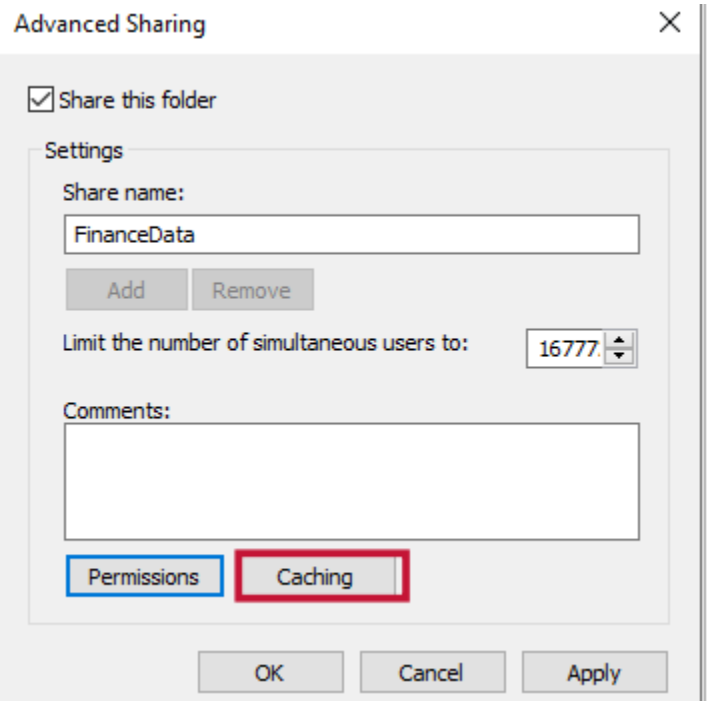
6. Select Everyone → click **Remove** (remove Everyone completely)
7. Click **Add** → type FinanceData → Check Names → OK

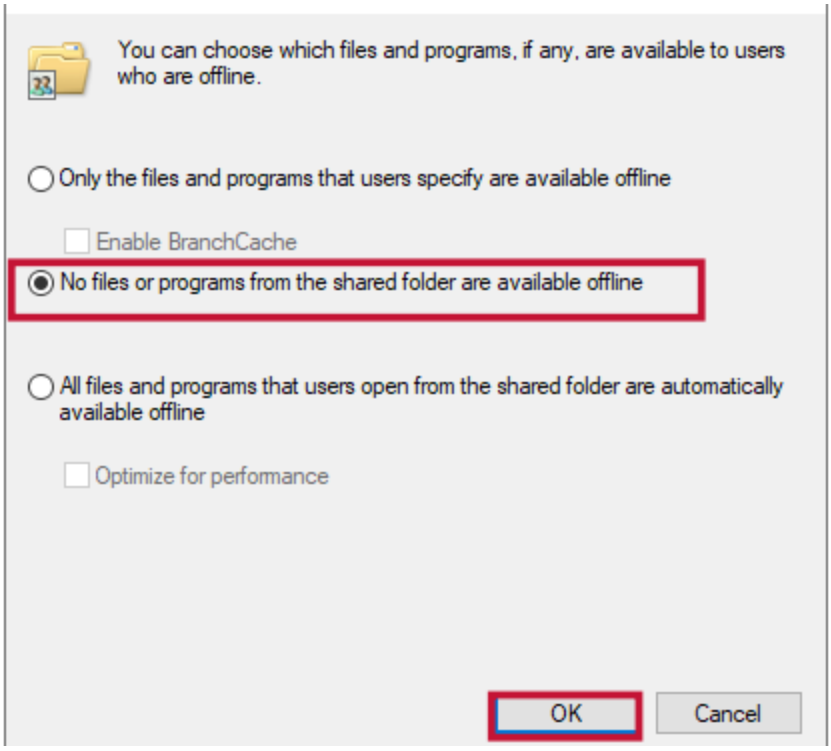


8. Select FinanceData group → check **Full Control** → Apply → OK



9. Back in Advanced Sharing → click **Caching** → Select **No files or programs from the shared folder are available offline** → OK

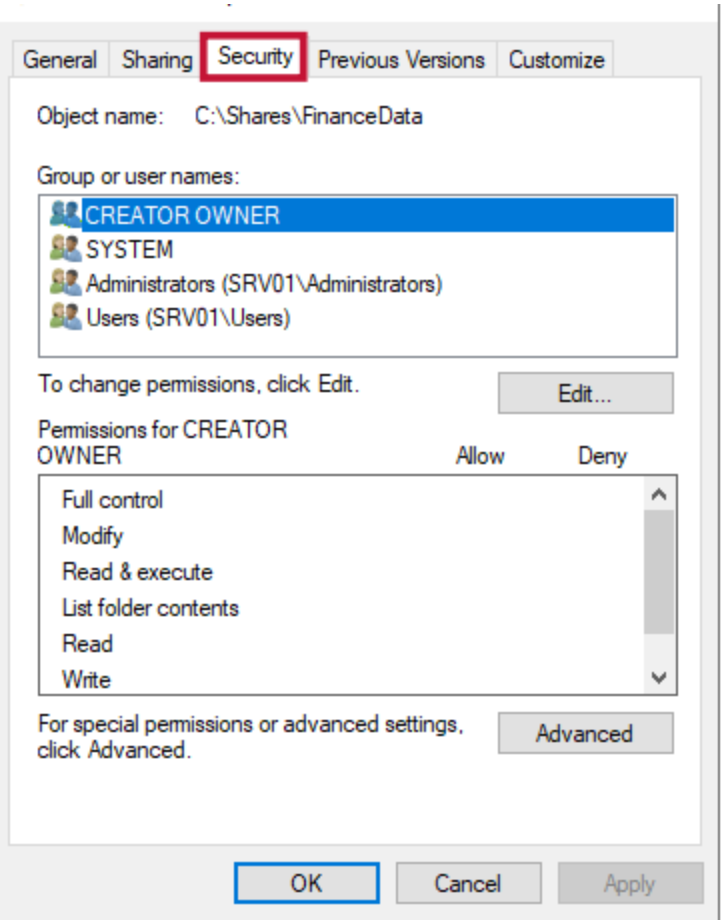




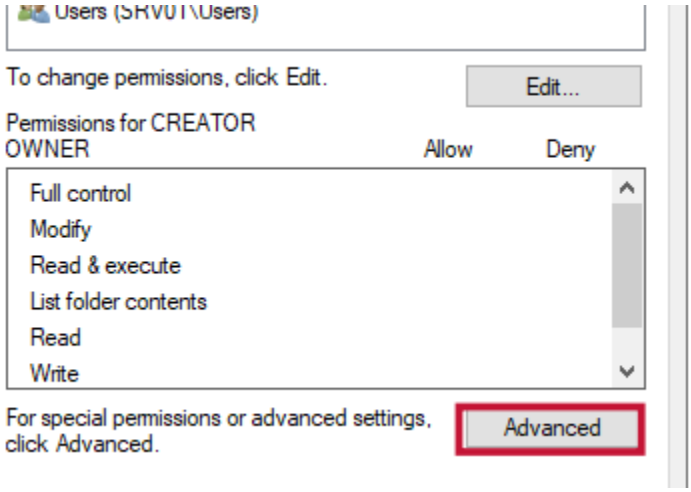
10. Click **Apply** → Ok

Configure NTFS Permissions:

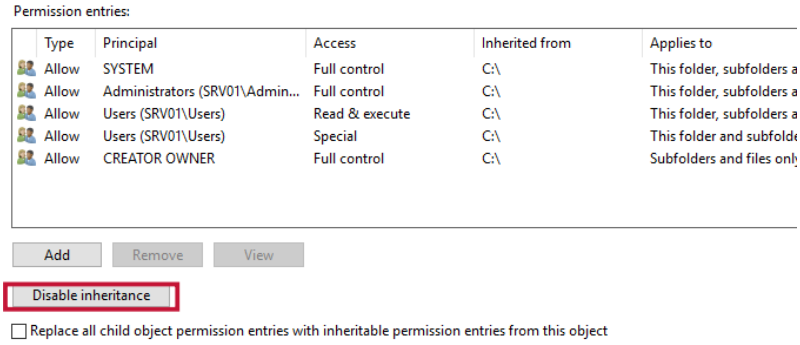
1. Still in FinanceData Properties → go to **Security** tab

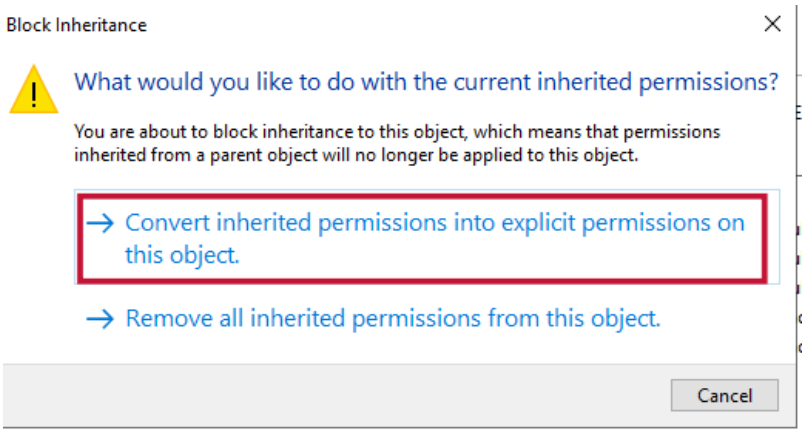


2. Click **Advanced**

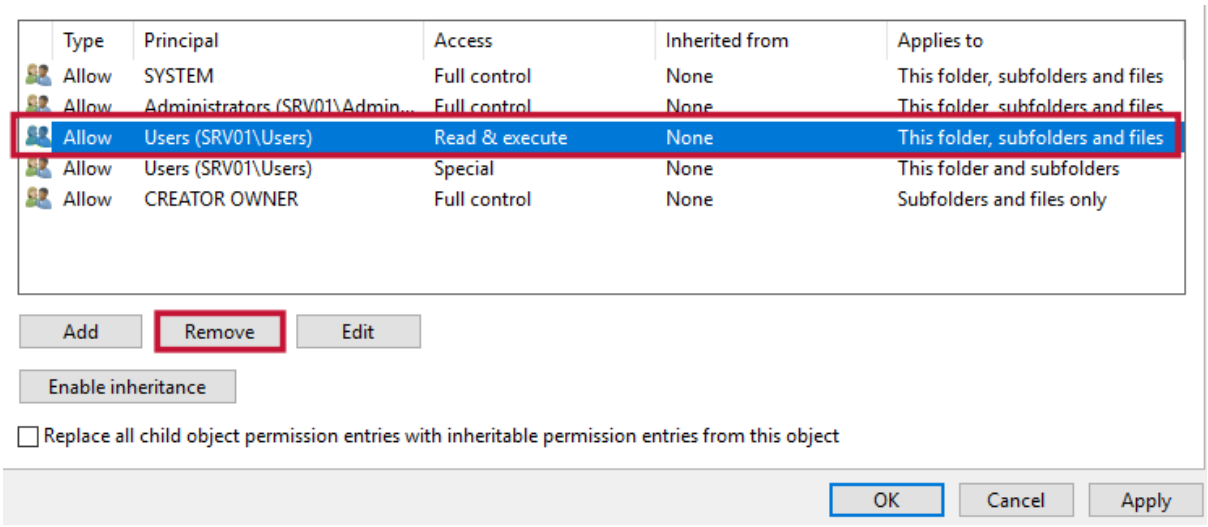


3. Click **Disable inheritance → Convert inherited permissions into explicit permissions on this object**

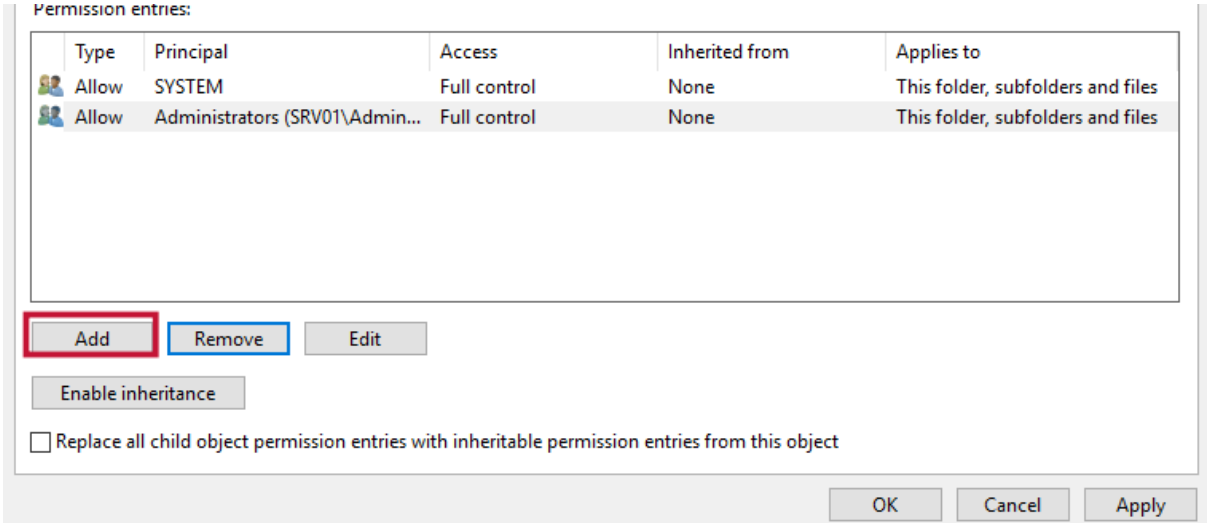


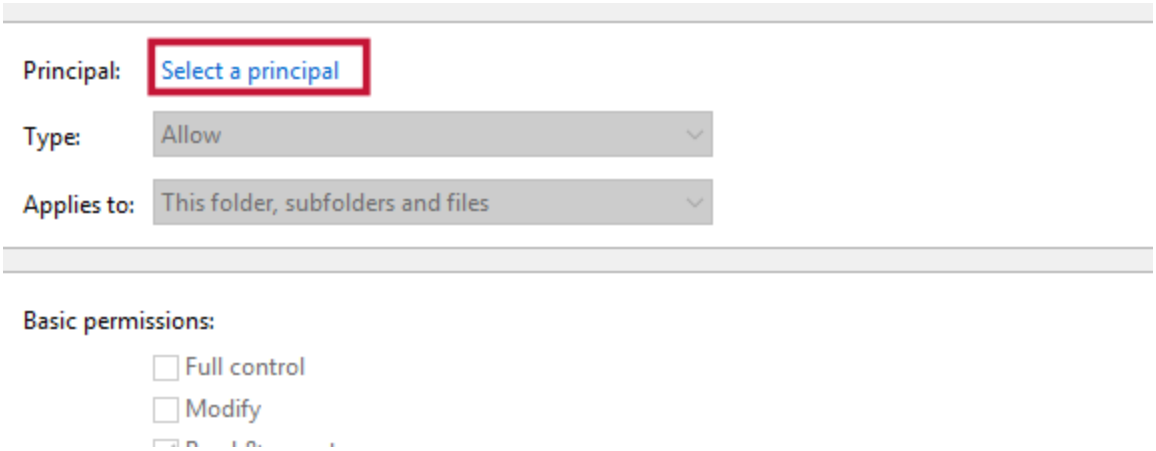


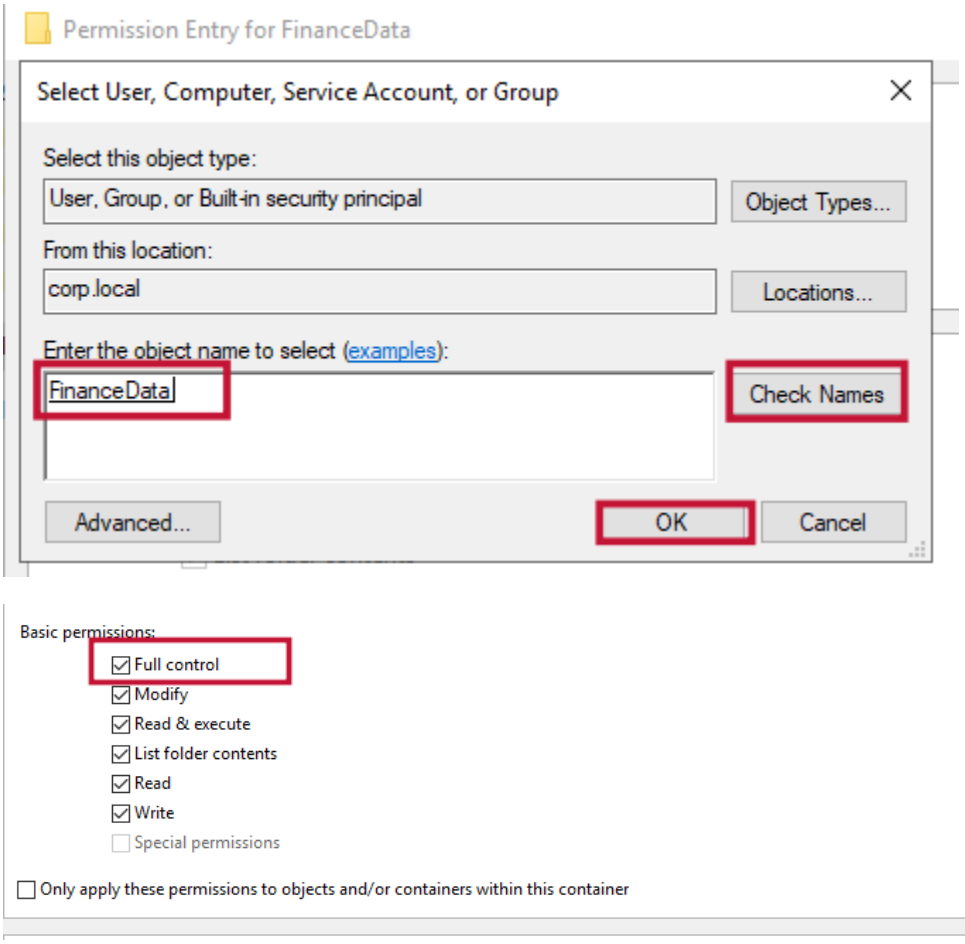
4. Now remove all entries EXCEPT:
    - SYSTEM — keep Full Control
    - Administrators — keep Full Control



5. To add FinanceData group: Click Add → Select a principal → type FinanceData → Check Names → OK → check Full Control → OK



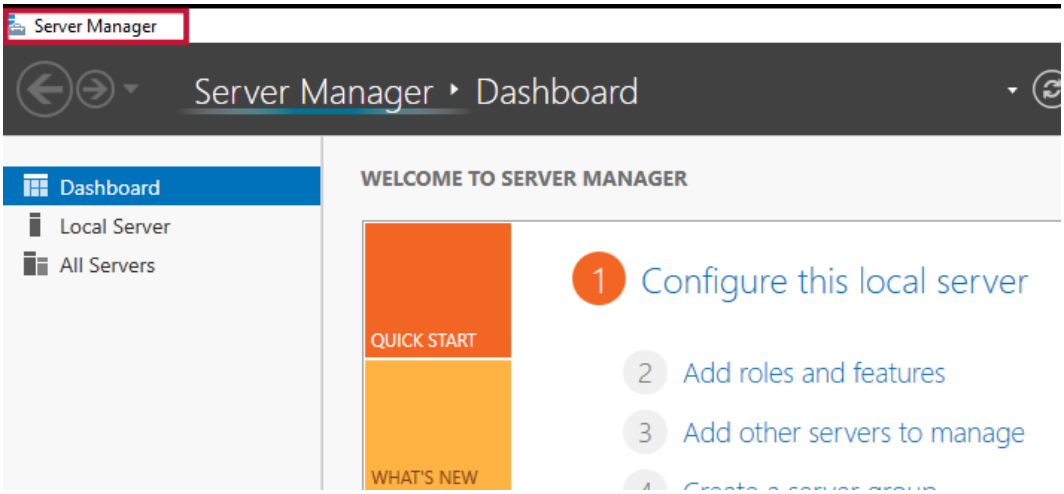




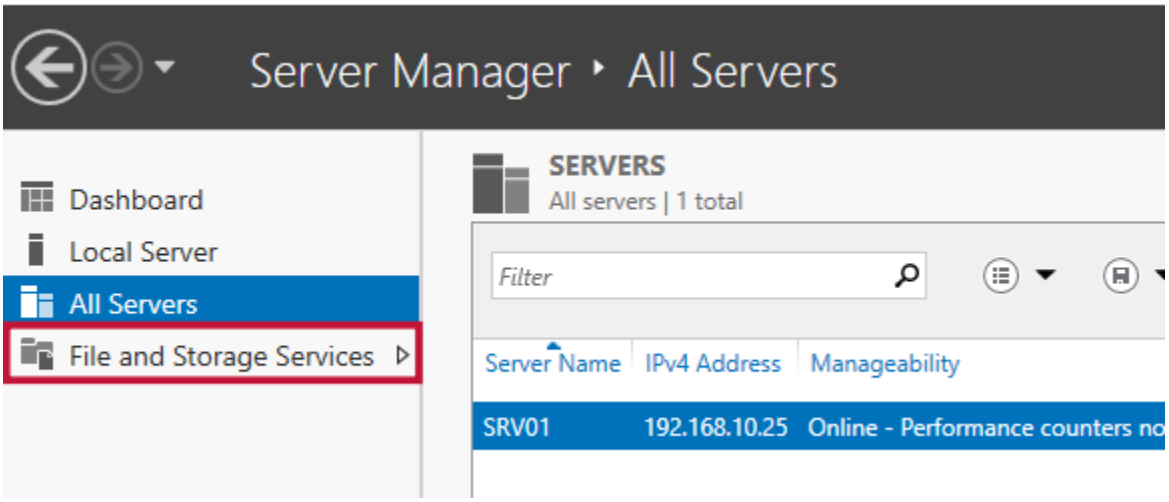
6. Click Apply → OK → OK

Enable Access-Based Enumeration:

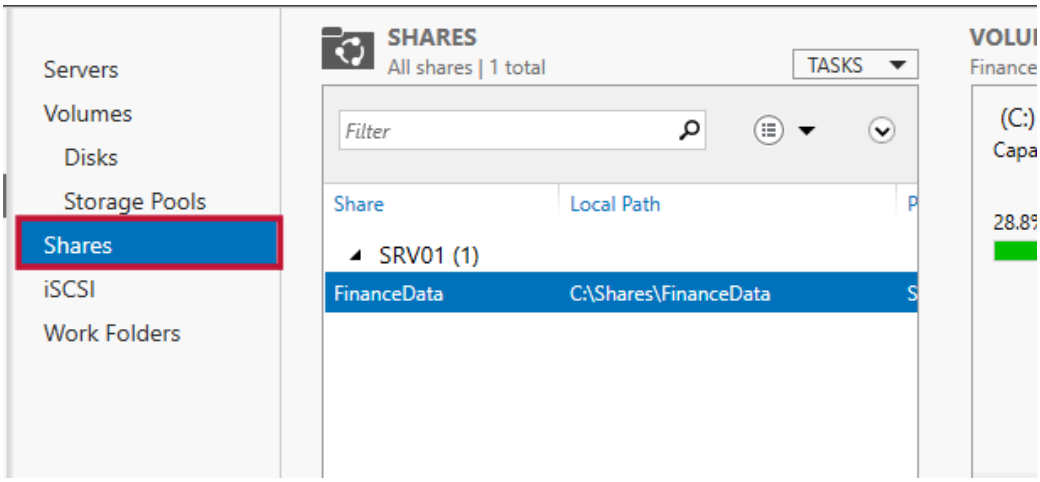
1. Open **Server Manager** on SRV01



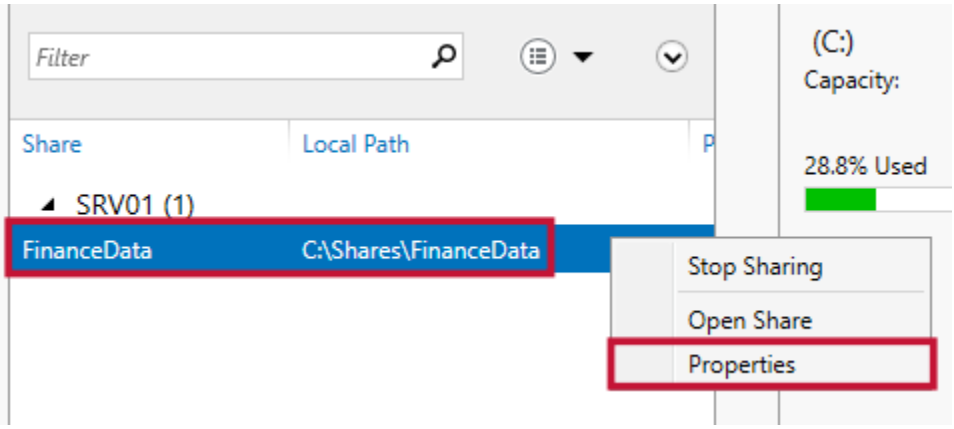
2. Click **File and Storage Services** (left panel)



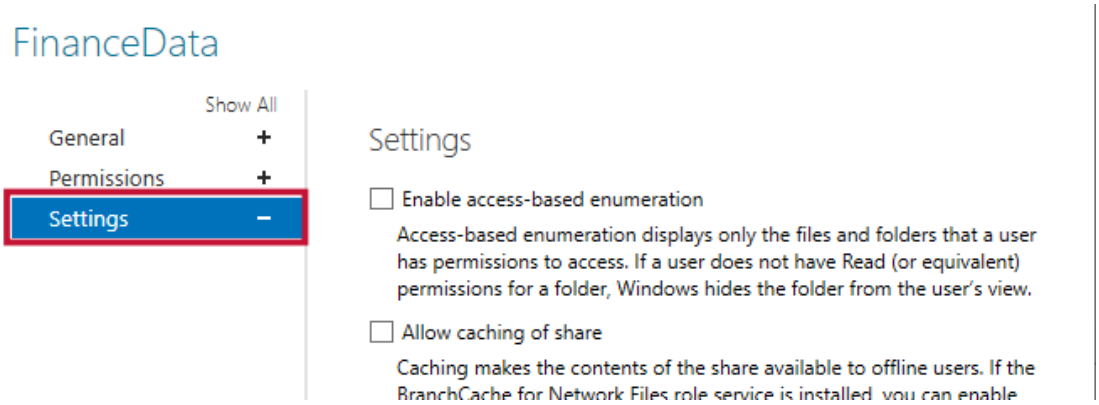
3. Click **Shares**



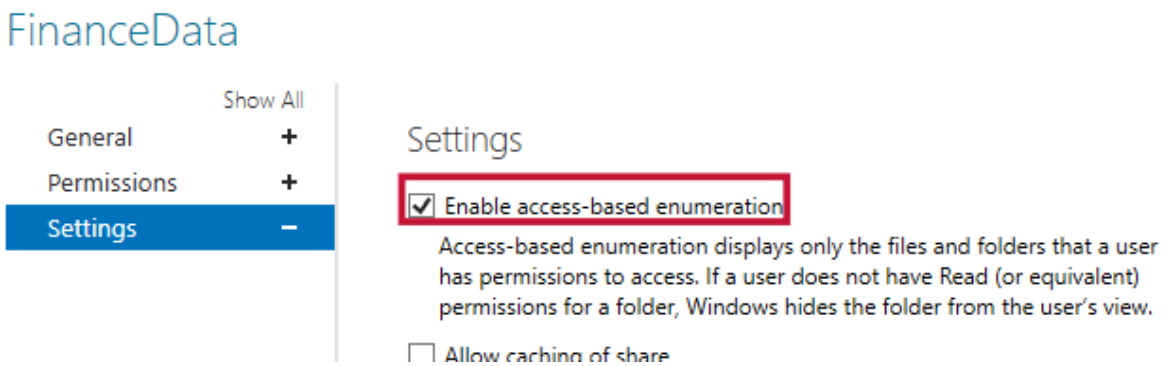
4. Right-click FinanceData share → **Properties**



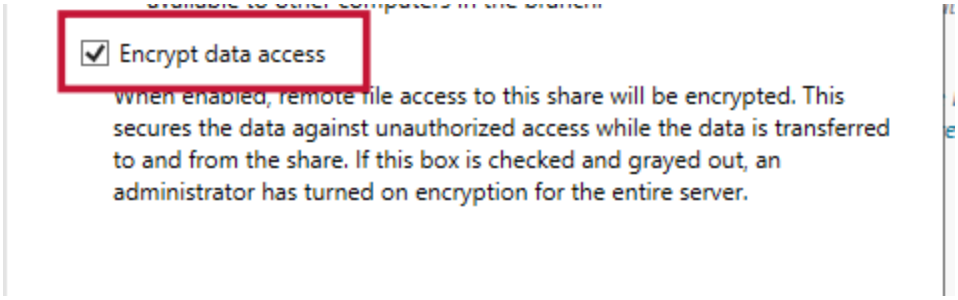
5. Go to **Settings** tab



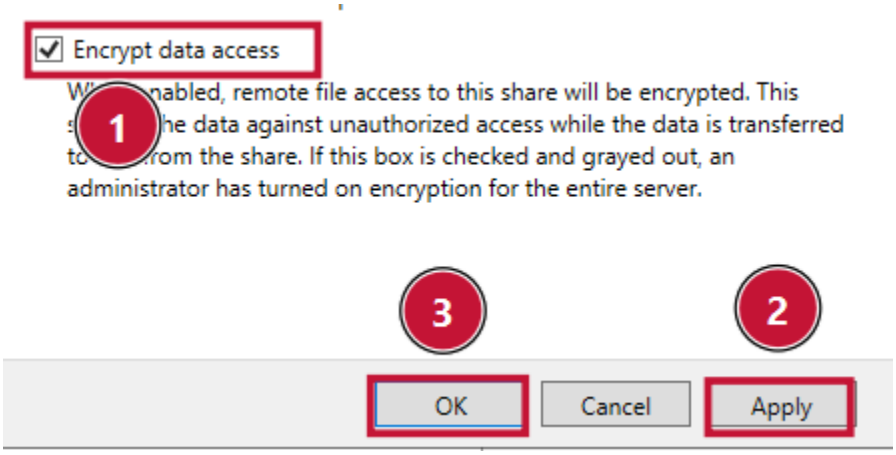
6. Check **Enable access-based enumeration** ← This hides the folder from users who have no access



7. Check **Encrypt data access** ← This enables SMB Encryption for this share

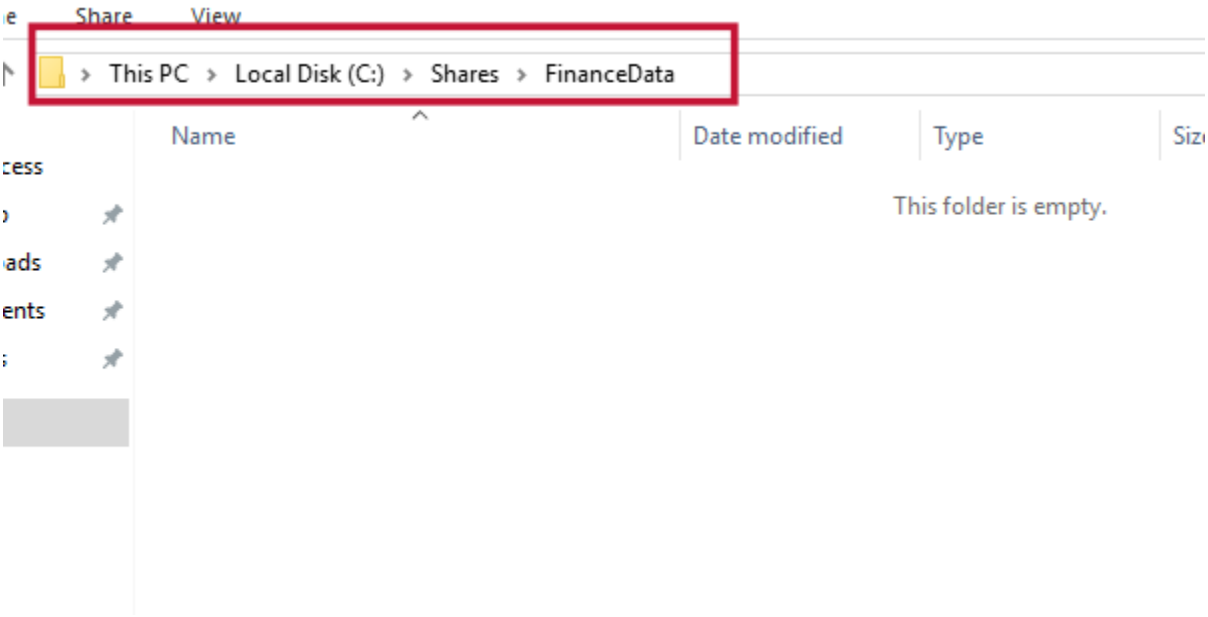


8. Click Apply → OK

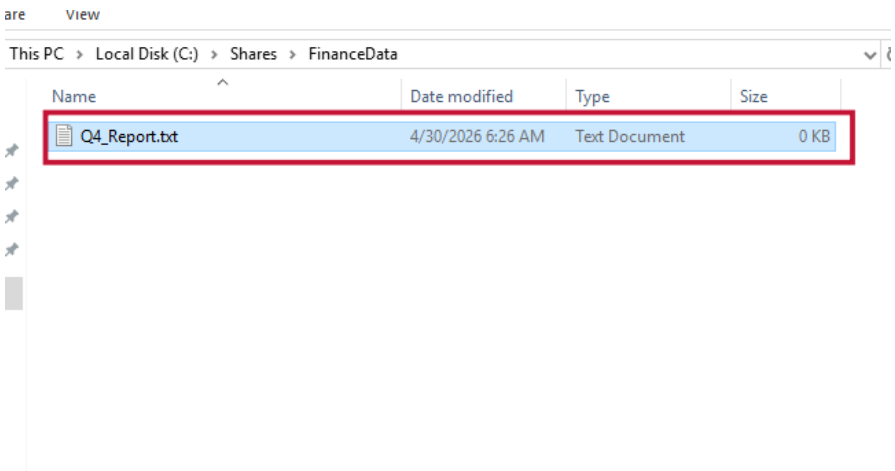


Add some test files:

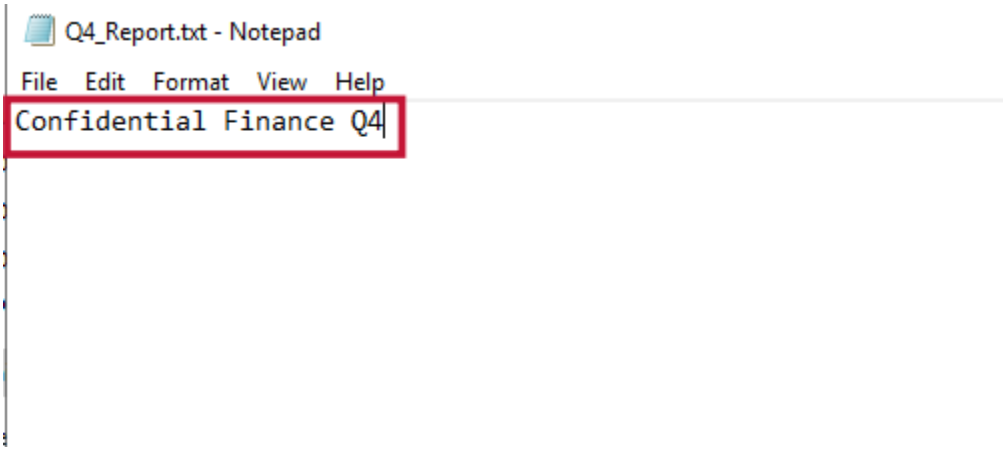
1. Go to C:\Shares\FinanceData on SRV01



2. Right-click → New → Text Document → name it Q4_Report.txt



3. Open it → type "Confidential Finance Data Q4" → Save

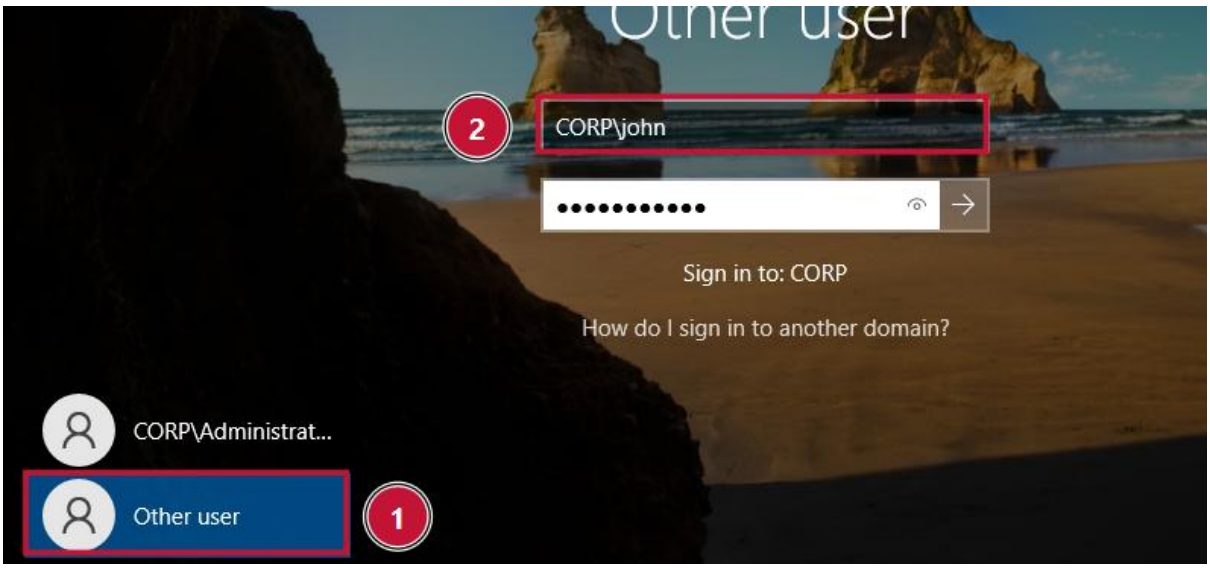


TEST RBAC ACCESS (Access Testing)

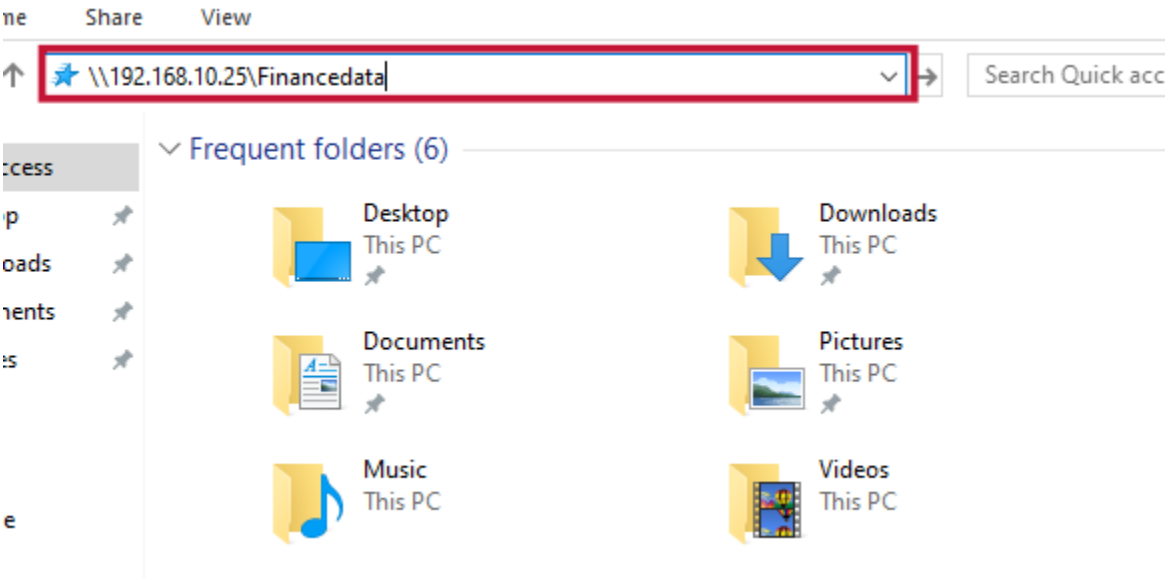
This is the verification step — you test who can and cannot access the share.

Test from CL01 as john (SHOULD succeed):

1. Go to **CL01** → Login as CORP\john (password: Finance@123)

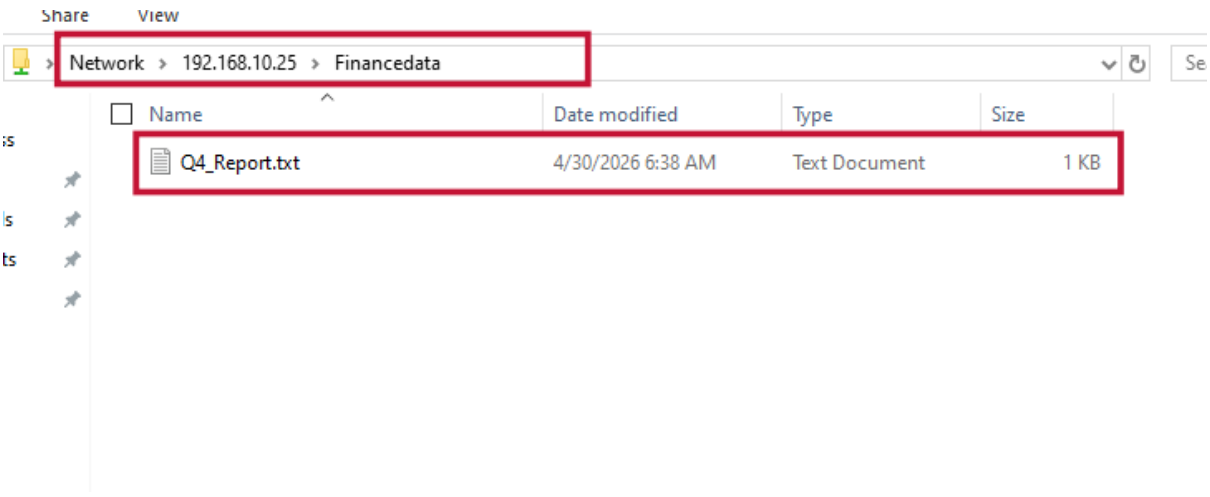


2. Open File Explorer → in address bar type: \\192.168.10.25\FinanceData



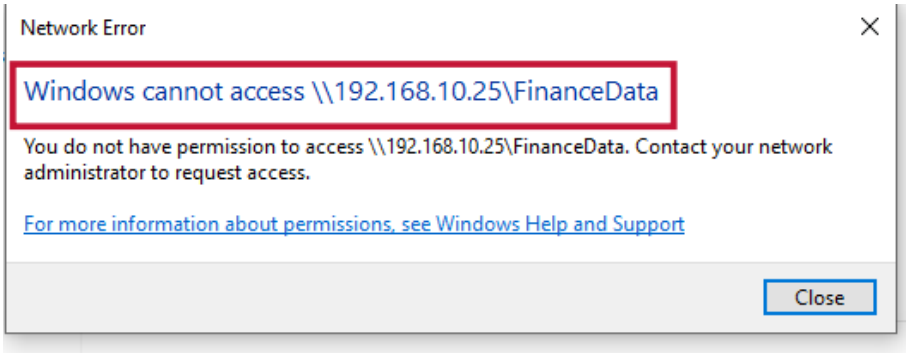
3. Press Enter

4. **Expected result:** Folder opens, you see Q4_Report.txt



Test from CL02 as martin (SHOULD be DENIED):

1. Go to **CL02** → Login as CORP\martin (password: User@123)
2. Open File Explorer → address bar: \\192.168.10.25\FinanceData
3. Press Enter



- **Expected result:** "You do not have permission to access \192.168.10.25\FinanceData. Contact your network administrator to request access."

This demonstrates RBAC (Role-Based Access Control) and Least Privilege in action. martin has a valid domain account but cannot access finance data because he is not in the Finance Data group.

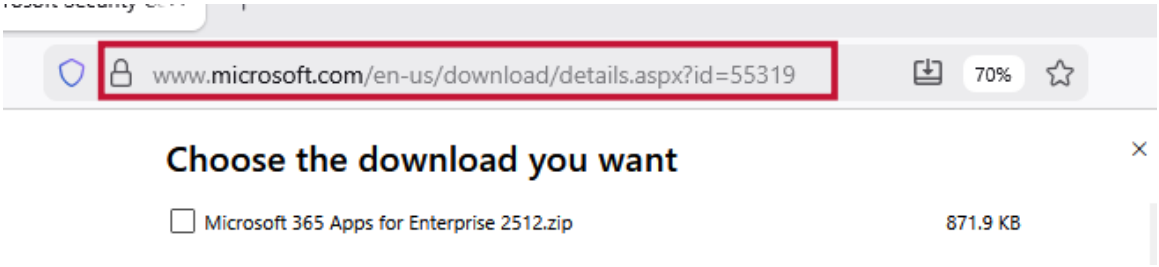
PHASE 4 — MICROSOFT SECURITY COMPLIANCE TOOLKIT (MSCT)

Do this on **DC01** and **SRV01**.

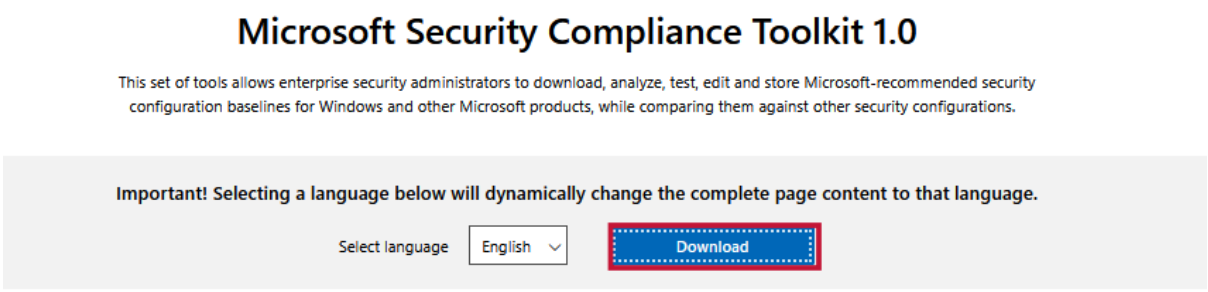
DOWNLOAD AND INSTALL MSCT ON DC01

Download the toolkit:

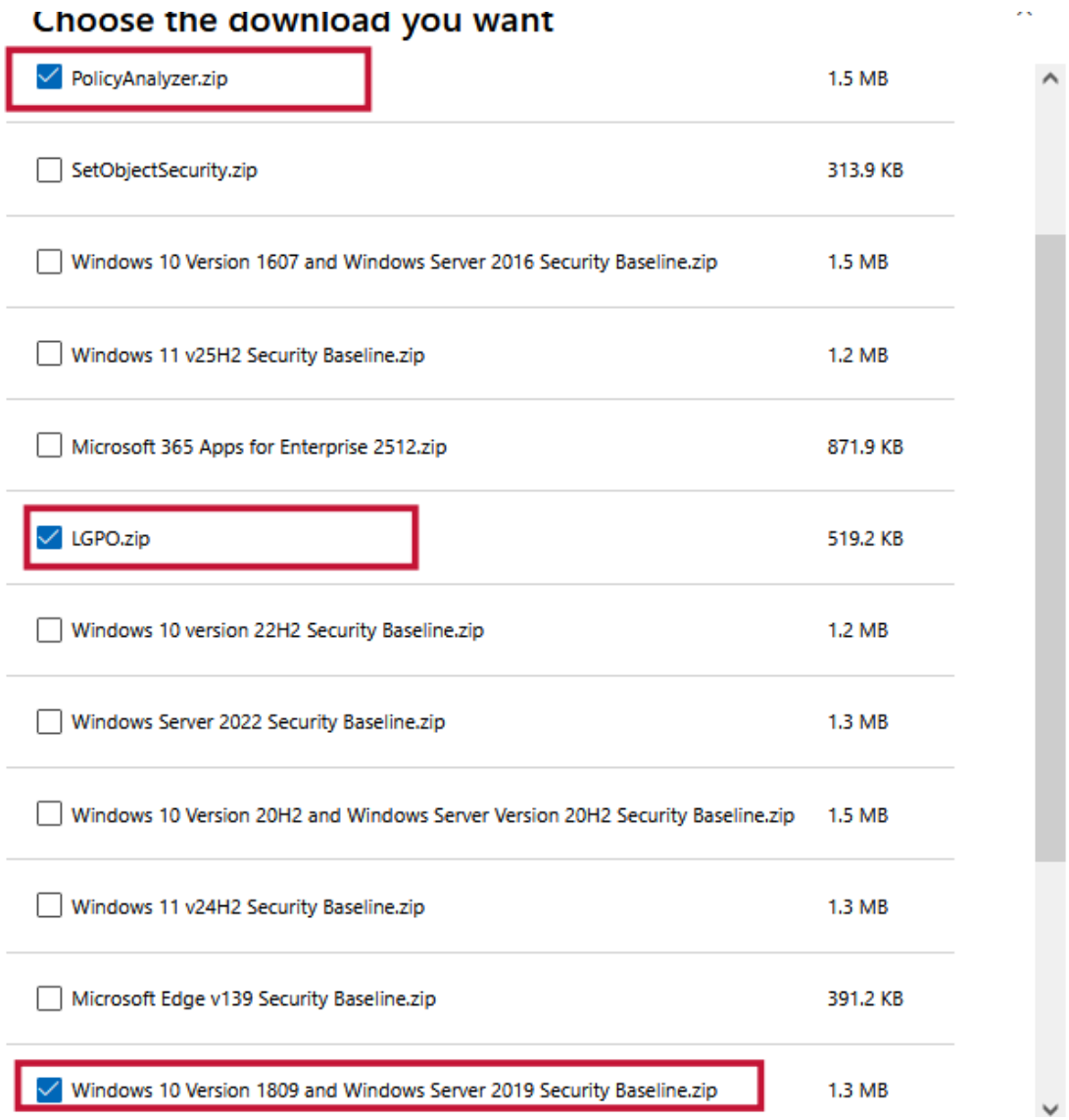
1. On DC01, open Edge/Internet Explorer
2. Go to: https://www.microsoft.com/en-us/download/details.aspx?id=55319



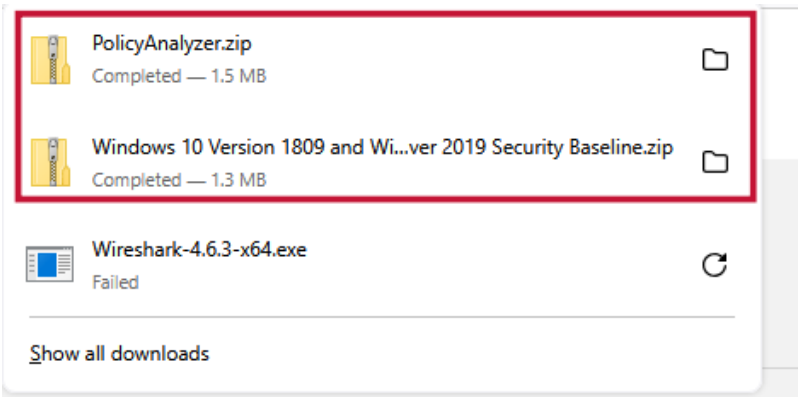
3. Click **Download**



4. Select both files:
    - Windows Server 2019 Security Baseline.zip
    - PolicyAnalyzer.zip
    - LGPO.zip

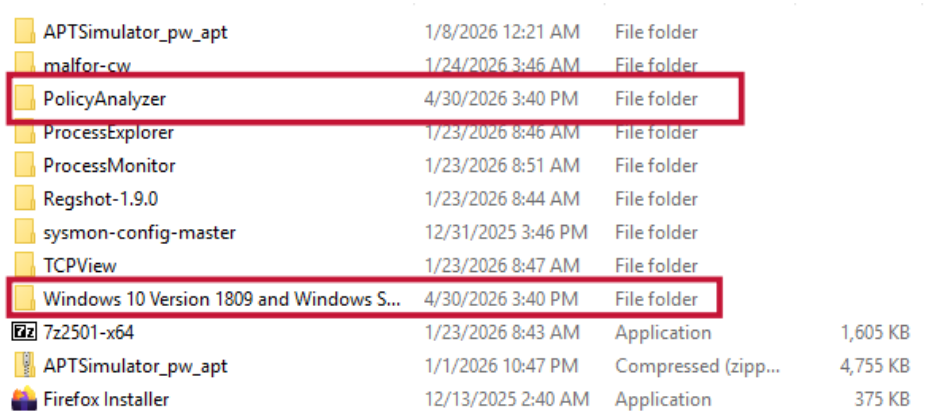


5. Click Next → Download both



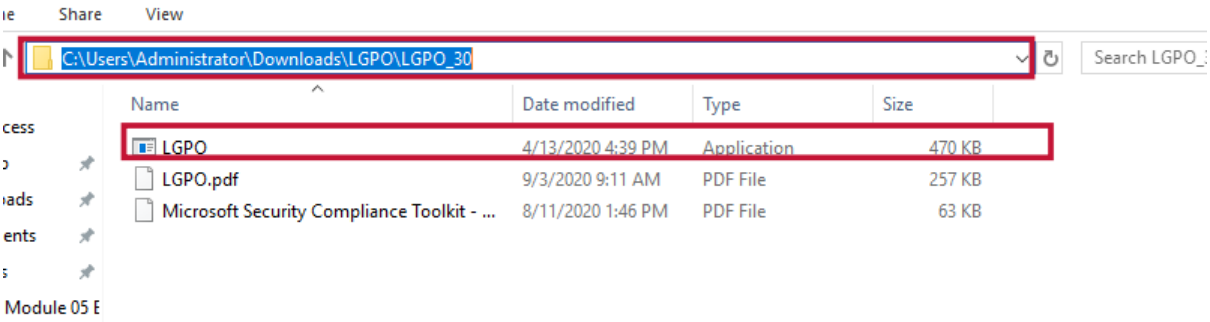
Extract the files:

1. Go to Downloads folder
2. Right-click Windows Server 2019 Security Baseline.zip → Extract All → to C:\MSCT\Baseline
3. Right-click PolicyAnalyzer.zip → Extract All → to C:\MSCT\PolicyAnalyzer

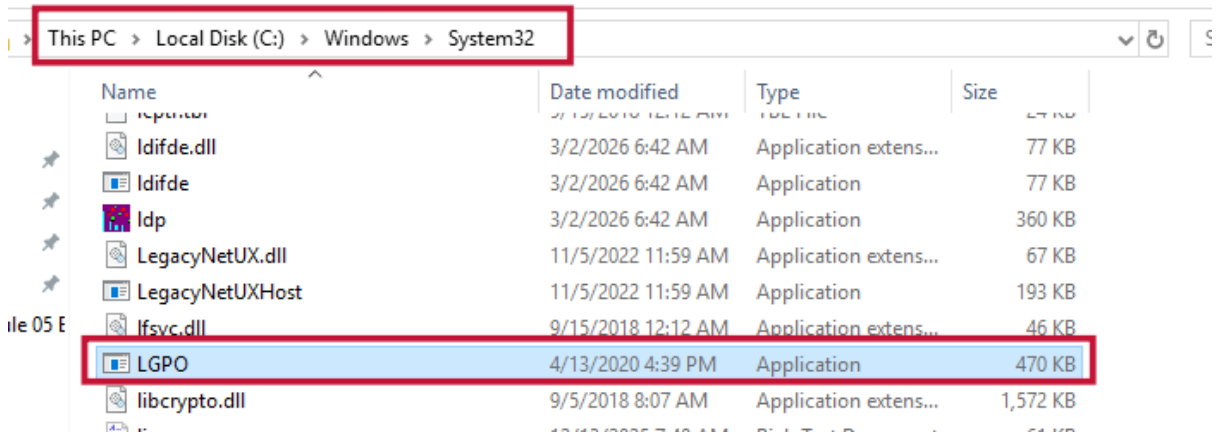


Install LGPO (Local Group Policy Object tool):

1. Inside Downloads\LGPO\LGPO_30\LGPO.exe



2. Copy LGPO.exe to C:\Windows\System32\ so it's accessible from anywhere



RUN POLICY ANALYZER ON DC01

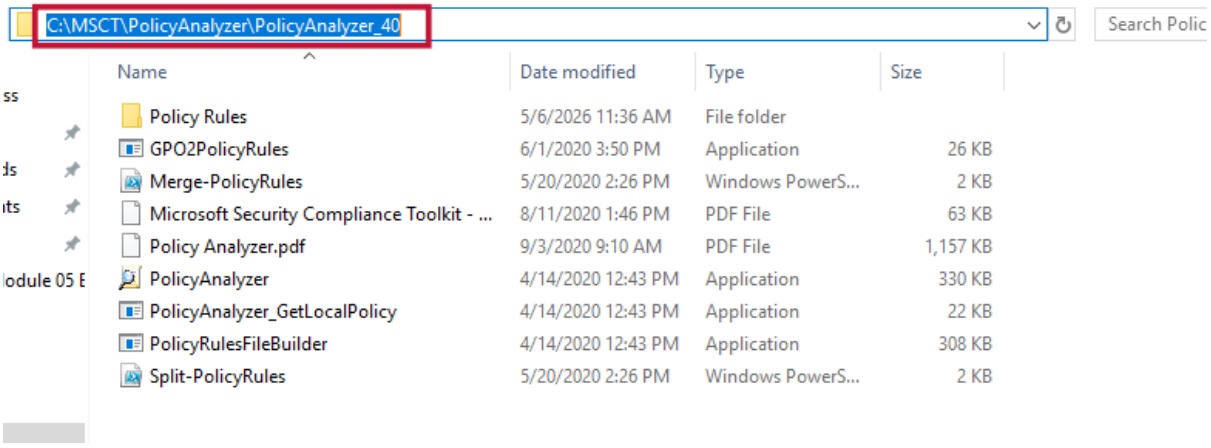
Policy Analyzer compares your current settings against the Microsoft Security Baseline and shows you gaps.

The tools required for this Lab are uploaded on google drive, Download the tools by opening the Link given below

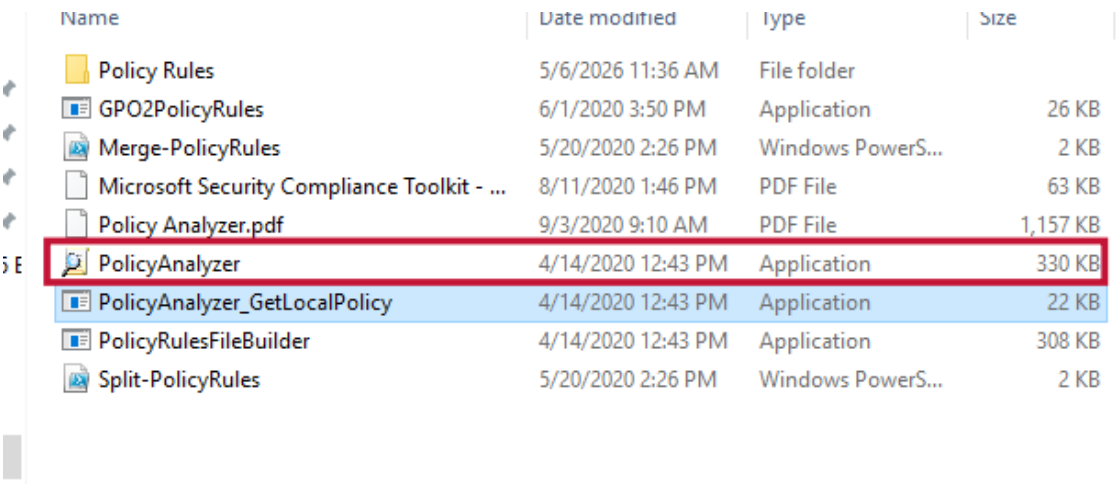
←---Link---->

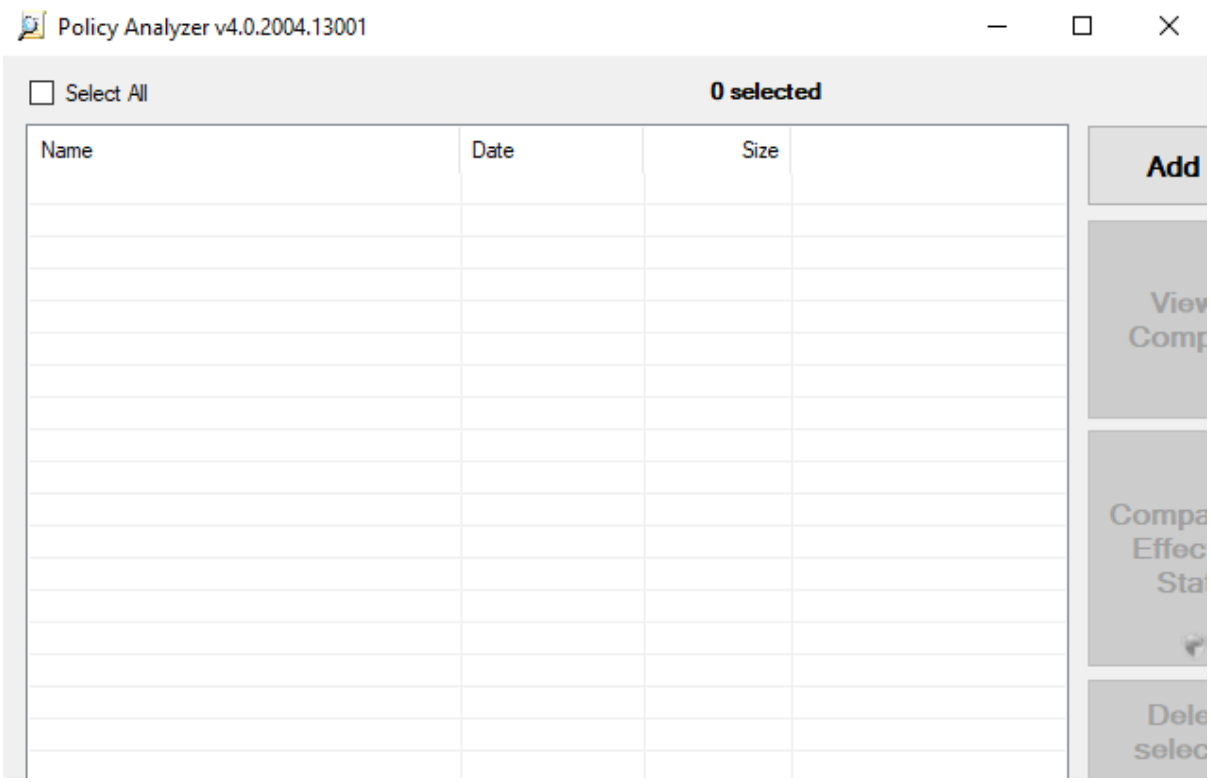
Open Policy Analyzer:

1. Go to C:\MSCT\PolicyAnalyzer\

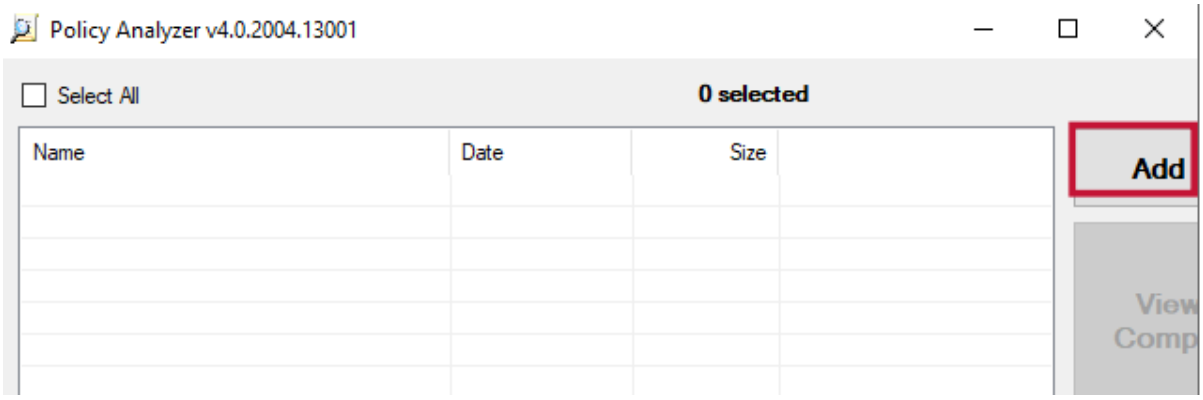


2. Double-click **PolicyAnalyzer.exe**

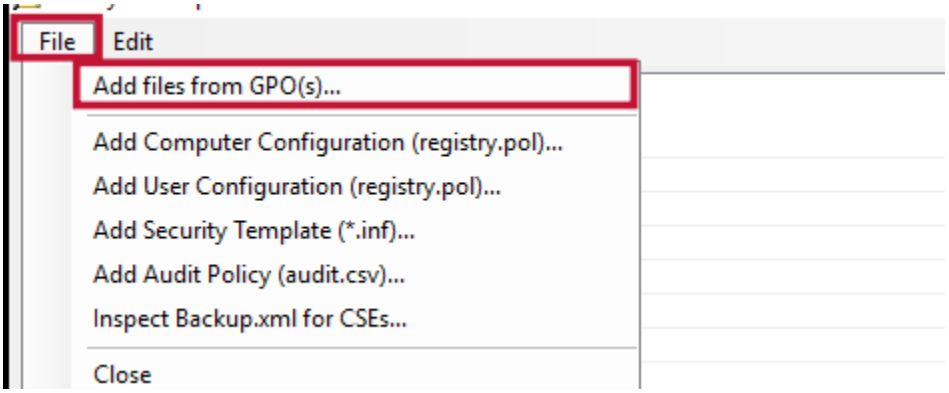




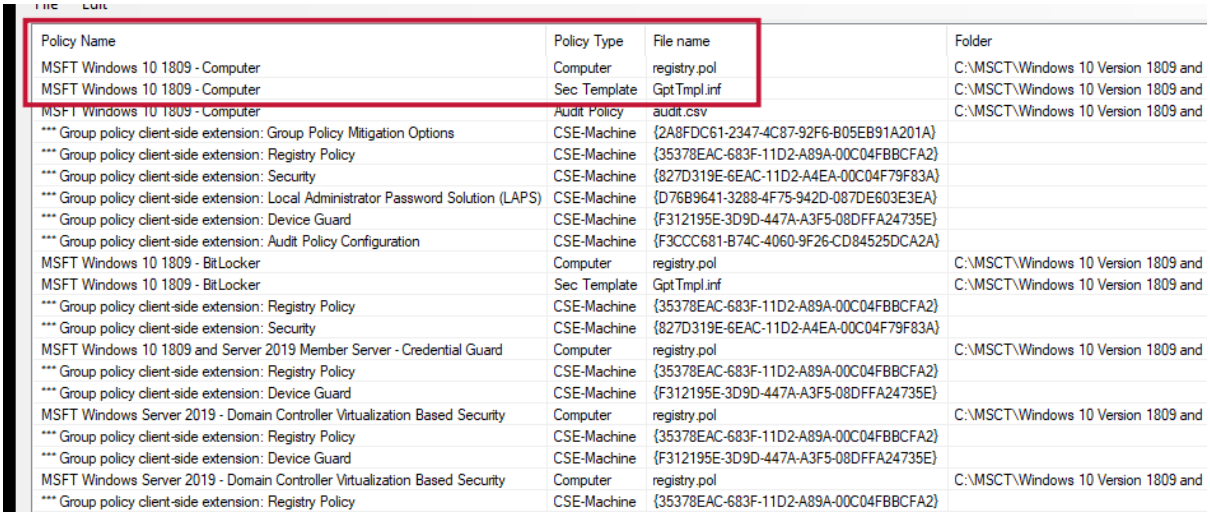
3. Click **Add**



4. Click on File and then on Ass files from GPO(s)

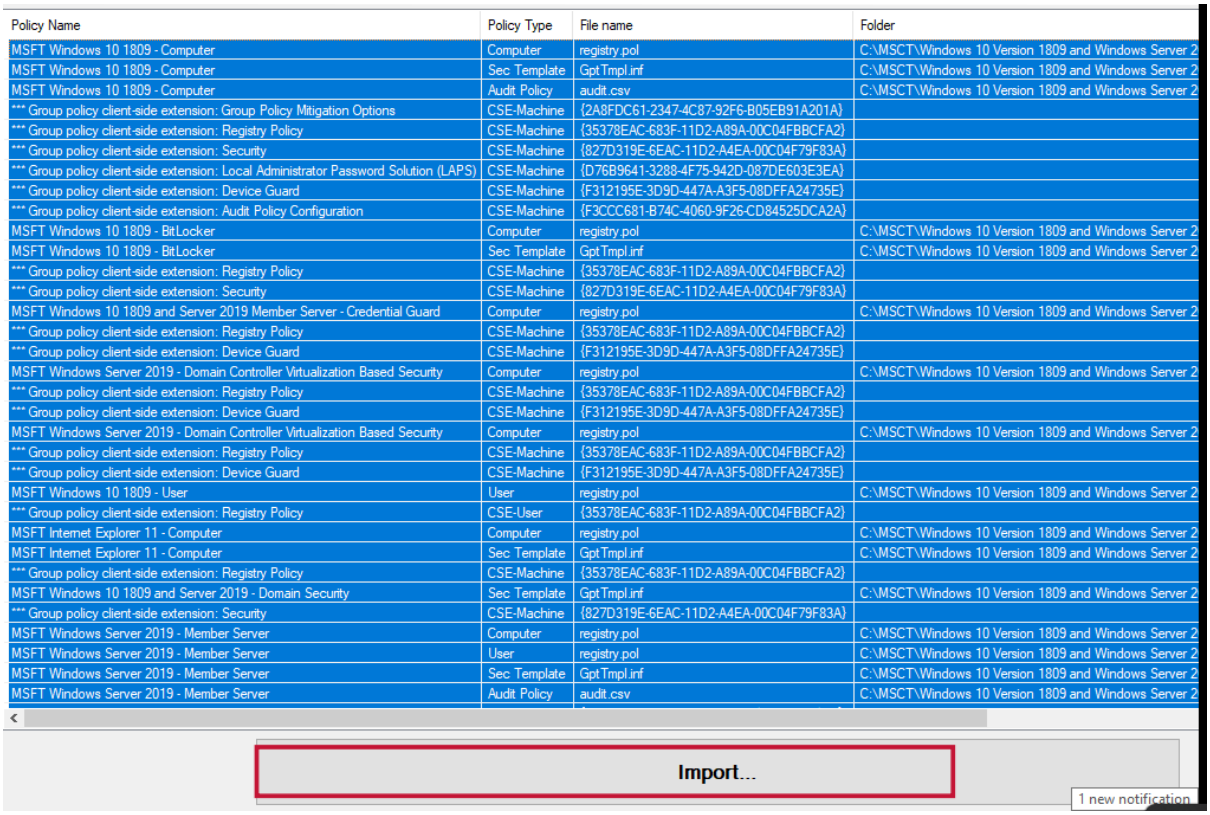


5. Navigate to C:\MSCT\Windows 10 Version*\GPOs\ → Add all GPO folders

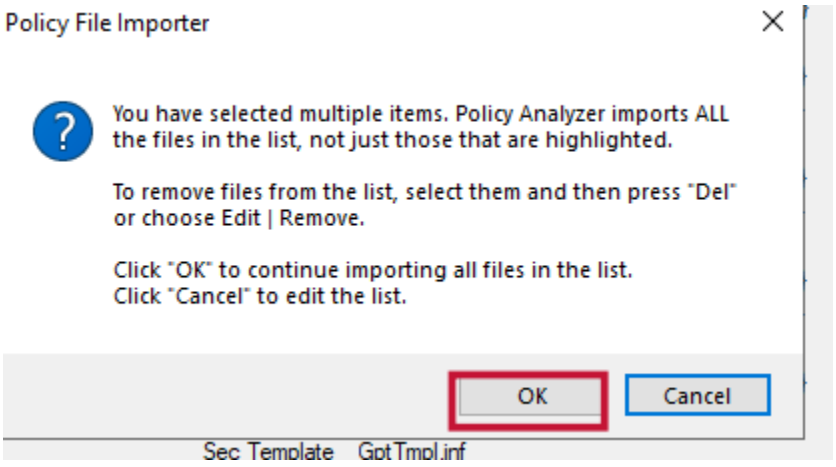


Policy Name	Policy Type	File name	Folder
MSFT Windows 10 1809 - Computer	Computer	registry.pol	C:\MSCT\Windows 10 Version 1809 and
MSFT Windows 10 1809 - Computer	Sec Template	GptTmpl.inf	C:\MSCT\Windows 10 Version 1809 and
MSFT Windows 10 1809 - Computer	Audit Policy	audit.csv	C:\MSCT\Windows 10 Version 1809 and
*** Group policy client-side extension: Group Policy Mitigation Options	CSE-Machine	{2A8FDC61-2347-4C87-92F6-B05EB91A201A}	
*** Group policy client-side extension: Registry Policy	CSE-Machine	{35378EAC-683F-11D2-A89A-00C04FBBCFA2}	
*** Group policy client-side extension: Security	CSE-Machine	{827D319E-6EAC-11D2-A4EA-00C04F79F83A}	
*** Group policy client-side extension: Local Administrator Password Solution (LAPS)	CSE-Machine	{D76B9641-3288-4F75-942D-087DE603E3EA}	
*** Group policy client-side extension: Device Guard	CSE-Machine	{F312195E-3D9D-447A-A3F5-08DFFA24735E}	
*** Group policy client-side extension: Audit Policy Configuration	CSE-Machine	{F3CCC681-B74C-4060-9F26-CD84525DCA2A}	
MSFT Windows 10 1809 - BitLocker	Computer	registry.pol	C:\MSCT\Windows 10 Version 1809 and
MSFT Windows 10 1809 - BitLocker	Sec Template	GptTmpl.inf	C:\MSCT\Windows 10 Version 1809 and
*** Group policy client-side extension: Registry Policy	CSE-Machine	{35378EAC-683F-11D2-A89A-00C04FBBCFA2}	
*** Group policy client-side extension: Security	CSE-Machine	{827D319E-6EAC-11D2-A4EA-00C04F79F83A}	
MSFT Windows 10 1809 and Server 2019 Member Server - Credential Guard	Computer	registry.pol	C:\MSCT\Windows 10 Version 1809 and
*** Group policy client-side extension: Registry Policy	CSE-Machine	{35378EAC-683F-11D2-A89A-00C04FBBCFA2}	
*** Group policy client-side extension: Device Guard	CSE-Machine	{F312195E-3D9D-447A-A3F5-08DFFA24735E}	
MSFT Windows Server 2019 - Domain Controller Virtualization Based Security	Computer	registry.pol	C:\MSCT\Windows 10 Version 1809 and
*** Group policy client-side extension: Registry Policy	CSE-Machine	{35378EAC-683F-11D2-A89A-00C04FBBCFA2}	
*** Group policy client-side extension: Device Guard	CSE-Machine	{F312195E-3D9D-447A-A3F5-08DFFA24735E}	
MSFT Windows Server 2019 - Domain Controller Virtualization Based Security	Computer	registry.pol	C:\MSCT\Windows 10 Version 1809 and
*** Group policy client-side extension: Registry Policy	CSE-Machine	{35378EAC-683F-11D2-A89A-00C04FBBCFA2}	

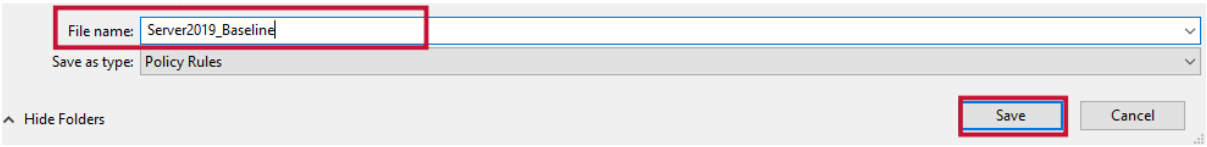
6. Select all the Policies and then click on Import



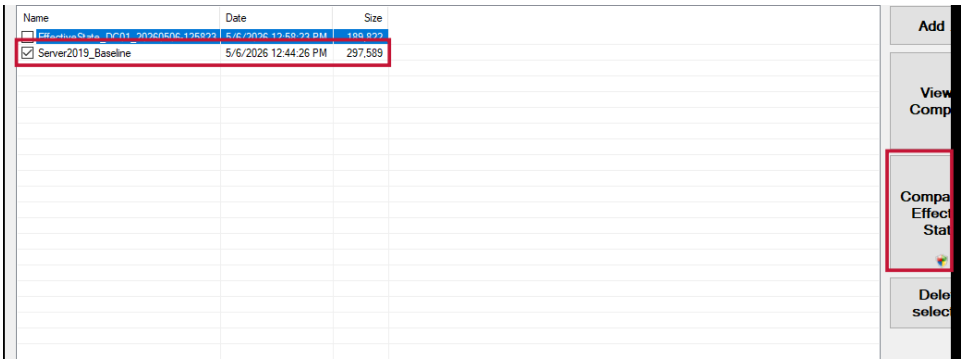
7. Click on Ok



8. **Type a name** in the "File name:" box at the bottom: Server2019_Baseline

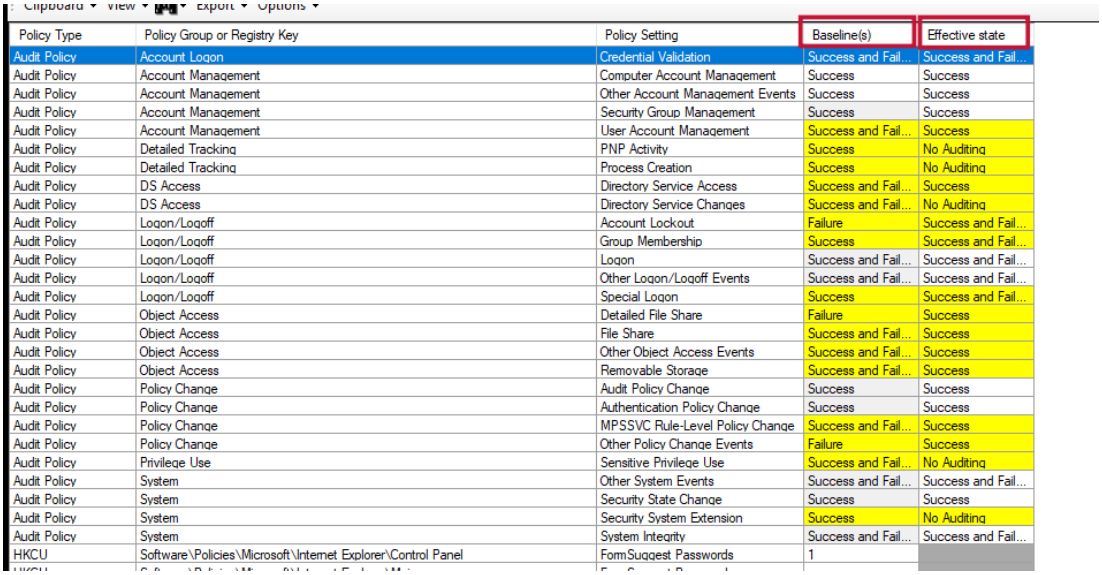


9. Click on Compare Effective State



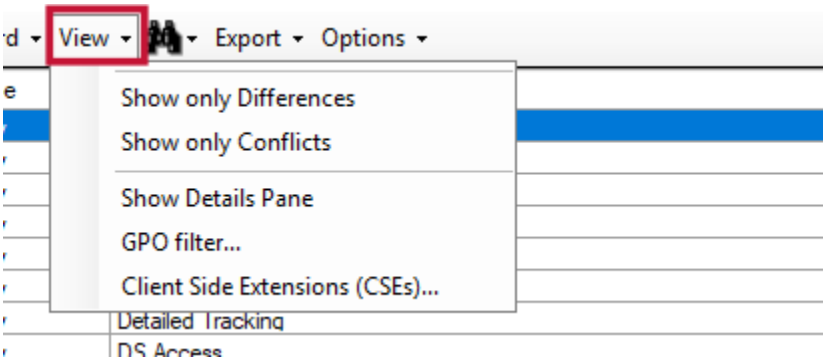
10. A results window will open with columns:

- **Baseline(s)** = Microsoft recommended settings
- **Effective State** = Your current system settings

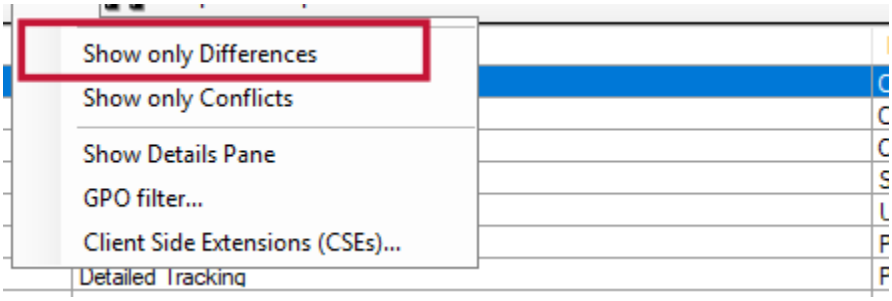


Policy Type	Policy Group or Registry Key	Policy Setting	Baseline(s)	Effective state
Audit Policy	Account Logon	Credential Validation	Success and Fail...	Success and Fail...
Audit Policy	Account Management	Computer Account Management	Success	Success
Audit Policy	Account Management	Other Account Management Events	Success	Success
Audit Policy	Account Management	Security Group Management	Success	Success
Audit Policy	Account Management	User Account Management	Success and Fail...	Success
Audit Policy	Detailed Tracking	PNP Activity	Success	No Auditing
Audit Policy	Detailed Tracking	Process Creation	Success	No Auditing
Audit Policy	DS Access	Directory Service Access	Success and Fail...	Success
Audit Policy	DS Access	Directory Service Changes	Success and Fail...	No Auditing
Audit Policy	Logon/Logoff	Account Lockout	Failure	Success and Fail...
Audit Policy	Logon/Logoff	Group Membership	Success	Success and Fail...
Audit Policy	Logon/Logoff	Logon	Success and Fail...	Success and Fail...
Audit Policy	Logon/Logoff	Other Logon/Logoff Events	Success and Fail...	Success and Fail...
Audit Policy	Logon/Logoff	Special Logon	Success	Success and Fail...
Audit Policy	Object Access	Detailed File Share	Failure	Success
Audit Policy	Object Access	File Share	Success and Fail...	Success
Audit Policy	Object Access	Other Object Access Events	Success and Fail...	Success
Audit Policy	Object Access	Removable Storage	Success and Fail...	Success
Audit Policy	Policy Change	Audit Policy Change	Success	Success
Audit Policy	Policy Change	Authentication Policy Change	Success	Success
Audit Policy	Policy Change	MPSSVC Rule-Level Policy Change	Success and Fail...	Success
Audit Policy	Policy Change	Other Policy Change Events	Failure	Success
Audit Policy	Privilege Use	Sensitive Privilege Use	Success and Fail...	No Auditing
Audit Policy	System	Other System Events	Success and Fail...	Success and Fail...
Audit Policy	System	Security State Change	Success	Success
Audit Policy	System	Security System Extension	Success	No Auditing
Audit Policy	System	System Integrity	Success and Fail...	Success and Fail...
HKCU	Software\Policies\Microsoft\Internet Explorer\Control Panel	FormSuggest Passwords	1	

11. Click **"View"** in the top menu



12. Select **"Show only differences"** or **"Filter to differences"**



All Yellow Highlighted Misconfigurations Found:

Policy Type	Policy Group or Registry Key	Policy Setting	Baseline(s)	Effective state
Audit Policy	Account Management	User Account Management	Success and Fail...	Success
Audit Policy	Detailed Tracking	PNP Activity	Success	No Auditing
Audit Policy	Detailed Tracking	Process Creation	Success	No Auditing
Audit Policy	DS Access	Directory Service Access	Success and Fail...	Success
Audit Policy	DS Access	Directory Service Changes	Success and Fail...	No Auditing
Audit Policy	Logon/Logoff	Account Lockout	Failure	Success and Fail...
Audit Policy	Logon/Logoff	Group Membership	Success	Success and Fail...
Audit Policy	Logon/Logoff	Special Logon	Success	Success and Fail...
Audit Policy	Object Access	Detailed File Share	Failure	Success
Audit Policy	Object Access	File Share	Success and Fail...	Success
Audit Policy	Object Access	Other Object Access Events	Success and Fail...	Success
Audit Policy	Object Access	Removable Storage	Success and Fail...	Success
Audit Policy	Policy Change	MPSSVC Rule-Level Policy Change	Success and Fail...	Success
Audit Policy	Policy Change	Other Policy Change Events	Failure	Success
Audit Policy	Privilege Use	Sensitive Privilege Use	Success and Fail...	No Auditing
Audit Policy	System	Security System Extension	Success	No Auditing
HKCU	Software\Policies\Microsoft\Internet Explorer\Control Panel	FormSuggest Passwords	1	
HKCU	Software\Policies\Microsoft\Internet Explorer\Main	FormSuggest Passwords	no	
HKCU	Software\Policies\Microsoft\Internet Explorer\Main	FormSuggest PW Ask	no	
HKCU	Software\Policies\Microsoft\Windows\CloudContent	DisableThirdPartySuggestions	1	
HKCU	Software\Policies\Microsoft\Windows\CurrentVersion\PushNotifications	NoToastApplicationNotificationOn...	1	
HKLM	Software\Microsoft\WcmSvc\wifinetworkmanager\config	AutoConnectAllowedOEM	0	
HKLM	Software\Microsoft\Windows NT\CurrentVersion\Winlogon	ScRemoveOption	1	0
HKLM	Software\Microsoft\Windows\CurrentVersion\Policies\CredUI	EnumerateAdministrators	0	
HKLM	Software\Microsoft\Windows\CurrentVersion\Policies\Explorer	NoAutorun	1	
HKLM	Software\Microsoft\Windows\CurrentVersion\Policies\Explorer	NoDriveTypeAutoRun	255	
HKLM	Software\Microsoft\Windows\CurrentVersion\Policies\Explorer	NoWebServices	1	
HKLM	Software\Microsoft\Windows\CurrentVersion\Policies\Ext	RunThisTimeEnabled	0	
HKLM	Software\Microsoft\Windows\CurrentVersion\Policies\Ext	VersionCheckEnabled	1	
HKLM	Software\Microsoft\Windows\CurrentVersion\Policies\System	ConsentPromptBehaviorAdmin	2	5
HKLM	Software\Microsoft\Windows\CurrentVersion\Policies\System	ConsentPromptBehaviorUser	0	3
HKLM	Software\Microsoft\Windows\CurrentVersion\Policies\System	FilterAdministratorToken	1	

#	Policy Setting	Baseline	Effective State
1	User Account Management	Success and Fail	Success
2	PNP Activity	Success	No Auditing
3	Process Creation	Success	No Auditing
4	Directory Service Changes	Success and Fail	No Auditing
5	Account Lockout	Failure	Success and Fail
6	Group Membership	Success	Success and Fail
7	Special Logon	Success	Success and Fail
8	Detailed File Share	Failure	Success
9	File Share	Success and Fail	Success
10	Other Object Access Events	Success and Fail	Success
11	Removable Storage	Success and Fail	Success
12	MPSSVC Rule-Level Policy Change	Success and Fail	Success
13	Other Policy Change Events	Failure	Success
14	Sensitive Privilege Use	Success and Fail	No Auditing
15	Security System Extension	Success	No Auditing
16	ScRemoveOption	1	0
17	ConsentPromptBehaviorAdmin	2	5
18	ConsentPromptBehaviorUser	0	3

Document Top 5 For Your Lab Report:

Misconfiguration 1:

- Setting: PNP Activity
- Baseline: Success
- Your System: No Auditing
- Risk: PnP device installations are not being audited

Misconfiguration 2:

- Setting: Process Creation
- Baseline: Success
- Your System: No Auditing
- Risk: Malicious process launches won't be logged

Misconfiguration 3:

- Setting: Sensitive Privilege Use
- Baseline: Success and Fail
- Your System: No Auditing
- Risk: Privilege abuse goes undetected

Misconfiguration 4:

- Setting: ConsentPromptBehaviorAdmin
- Baseline: 2
- Your System: 5
- Risk: UAC prompt is weaker than recommended, easier for attackers to bypass

Misconfiguration 5:

- Setting: ScRemoveOption
- Baseline: 1
- Your System: 0
- Risk: Smart card removal does not lock the workstation

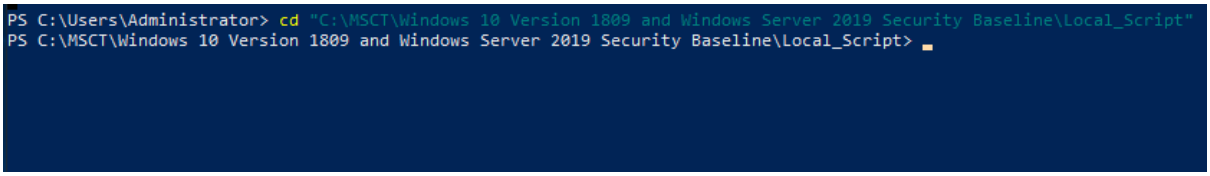
APPLY SECURITY BASELINE USING LGPO

This applies the Microsoft hardening settings automatically.

On DC01 — Open PowerShell as Administrator:

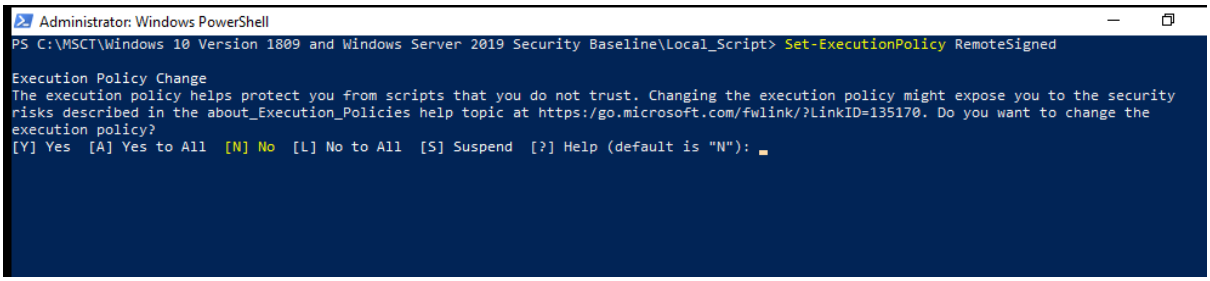
On DC01 — Open PowerShell as Administrator:

```
cd "C:\MSCT\Windows 10 Version 1809 and Windows Server 2019 Security Baseline\Local_Script"
```



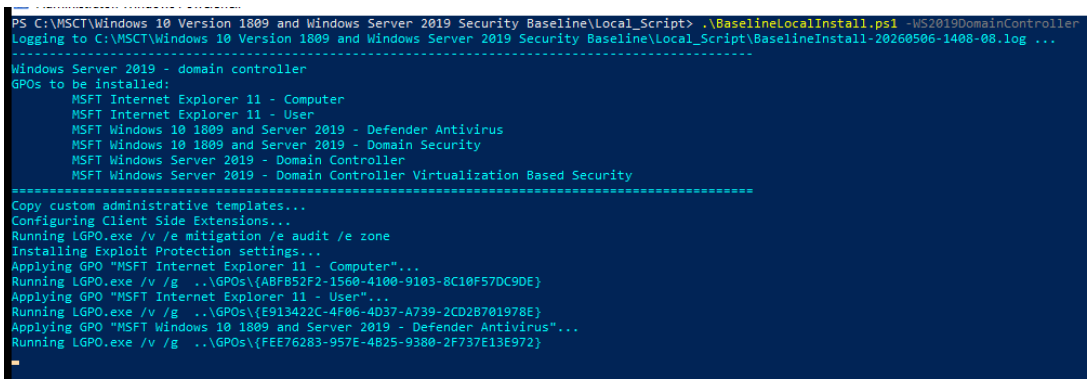
Press **Enter**, then type:

```
Set-ExecutionPolicy RemoteSigned
```



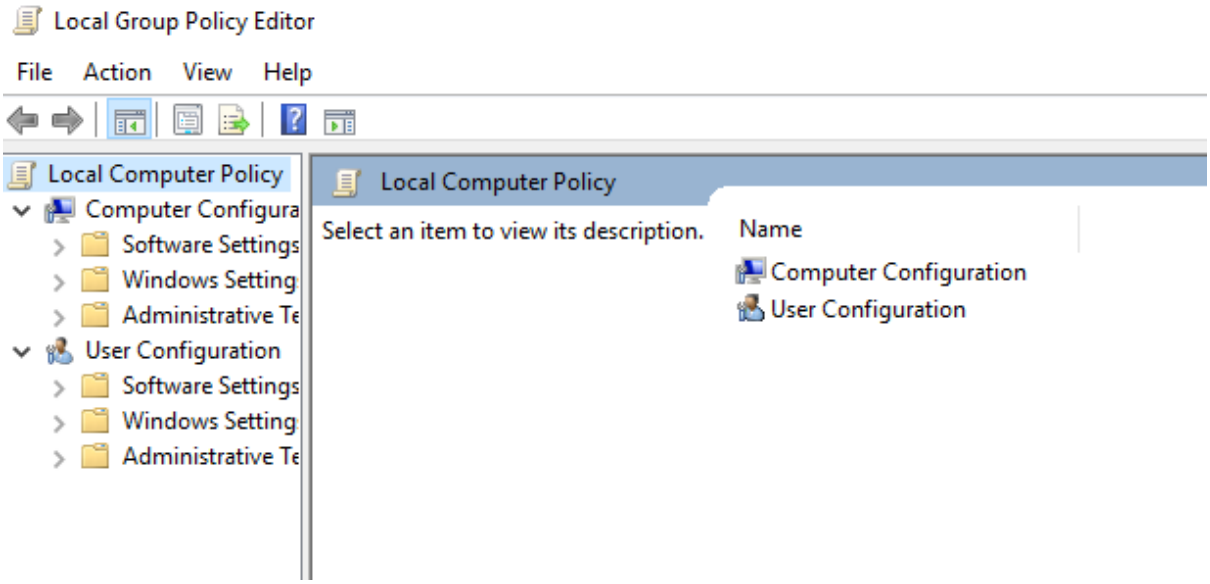
Type **Y** and press Enter when prompted, then run:

```
.\BaselineLocalInstall.ps1 -WS2019DomainController
```

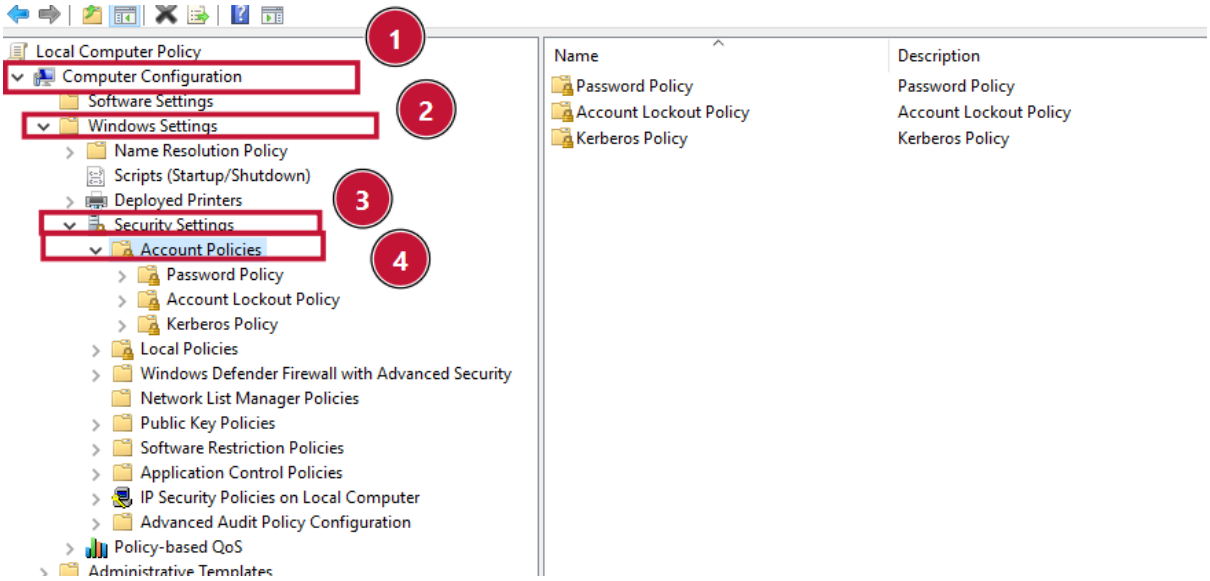


Verify application:

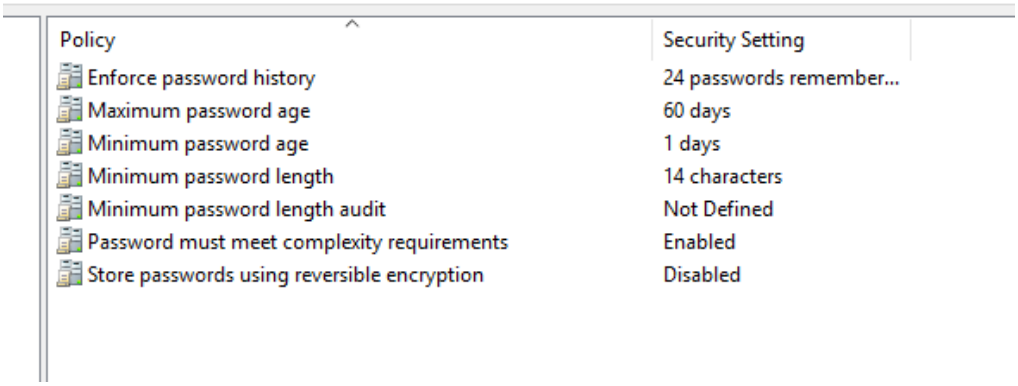
1. Open gpedit.msc (Local Group Policy Editor)



2. Navigate to: Computer Configuration → Windows Settings → Security Settings → Account Policies



3. Confirm Password Policy shows stricter settings than before



Policy	Security Setting
Enforce password history	24 passwords remember...
Maximum password age	60 days
Minimum password age	1 days
Minimum password length	14 characters
Minimum password length audit	Not Defined
Password must meet complexity requirements	Enabled
Store passwords using reversible encryption	Disabled

Repeat the same process on SRV01:

1. Copy the entire C:\MSCT\ folder from DC01 to SRV01 (use a shared folder or USB)
2. Or re-download MSCT on SRV01
3. Run the same Policy Analyzer comparison
4. Apply the baseline with LGPO

```
PS C:\MSCT\MSCT\Windows 10 Version 1809 and Windows Server 2019 Security Baseline\Local_Script> .\Ba
selineLocalInstall.ps1 -WS2019DomainController
Logging to C:\MSCT\MSCT\Windows 10 Version 1809 and Windows Server 2019 Security Baseline\Local_Scri
pt\BaselineInstall-20260506-1435-06.log ...
-------------------------------------------------------------------------------------------------
Windows Server 2019 - domain controller
GPOs to be installed:
        MSFT Internet Explorer 11 - Computer
        MSFT Internet Explorer 11 - User
        MSFT Windows 10 1809 and Server 2019 - Defender Antivirus
        MSFT Windows 10 1809 and Server 2019 - Domain Security
        MSFT Windows Server 2019 - Domain Controller
        MSFT Windows Server 2019 - Domain Controller Virtualization Based Security
=================================================================================================
Copy custom administrative templates...
Configuring Client Side Extensions...
Running LGPO.exe /v /e mitigation /e audit /e zone
Installing Exploit Protection settings...
Applying GPO "MSFT Internet Explorer 11 - Computer"...
Running LGPO.exe /v /g  ..\GPOs\{ABFB52F2-1560-4100-9103-8C10F57DC9DE}
Applying GPO "MSFT Internet Explorer 11 - User"...
Running LGPO.exe /v /g  ..\GPOs\{E913422C-4F06-4D37-A739-2CD2B701978E}
Applying GPO "MSFT Windows 10 1809 and Server 2019 - Defender Antivirus"...
Running LGPO.exe /v /g  ..\GPOs\{FEE76283-957E-4B25-9380-2F737E13E972}
Applying GPO "MSFT Windows 10 1809 and Server 2019 - Domain Security"...
Running LGPO.exe /v /g  ..\GPOs\{B9263530-926F-46F3-8382-832C31EC81B5}
Applying GPO "MSFT Windows Server 2019 - Domain Controller"...
Running LGPO.exe /v /g  ..\GPOs\{FEFBD334-CF33-4078-8829-4B00DC1D164B}
Applying GPO "MSFT Windows Server 2019 - Domain Controller Virtualization Based Security"...
Running LGPO.exe /v /g  ..\GPOs\{7EA149BF-56B3-42CF-AF68-3FC789510ADD}
=================================================================================================
=================================================================================================
To test properly, create a new non-administrative user account and reboot.

Detailed logs are in this file:
C:\MSCT\MSCT\Windows 10 Version 1809 and Windows Server 2019 Security Baseline\Local_Script\Baseline
Install-20260506-1435-06.log

Please post feedback to the Security Guidance blog:
https://blogs.technet.microsoft.com/secguide/
=================================================================================================
=================================================================================================
PS C:\MSCT\MSCT\Windows 10 Version 1809 and Windows Server 2019 Security Baseline\Local_Script>
```

PHASE 5 — PATCH MANAGEMENT WITH BATCHPATCH

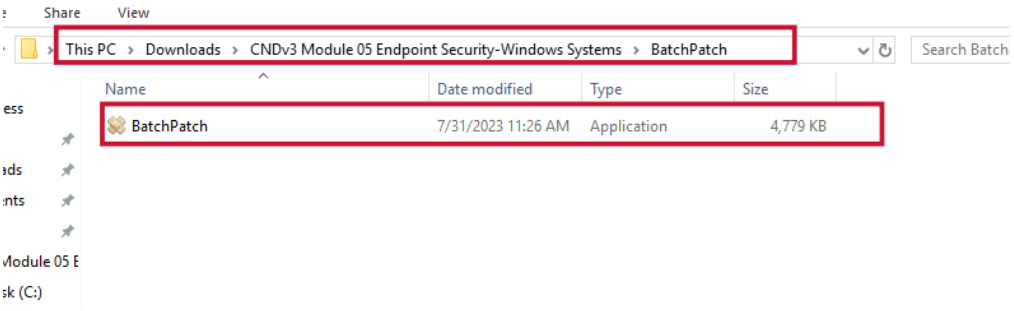
Do all of this on **SRV01**.

INSTALL BATCHPATCH ON SRV01

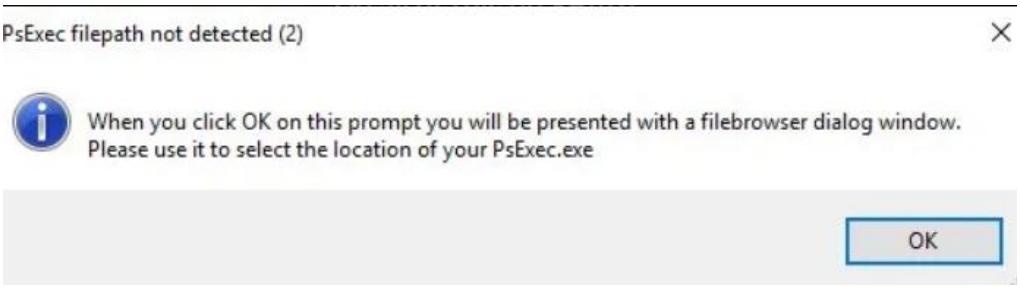
Batch Patch is a remote Windows patch management tool. It lets you scan, deploy patches, and reboot remote machines from one console.

Download BatchPatch:

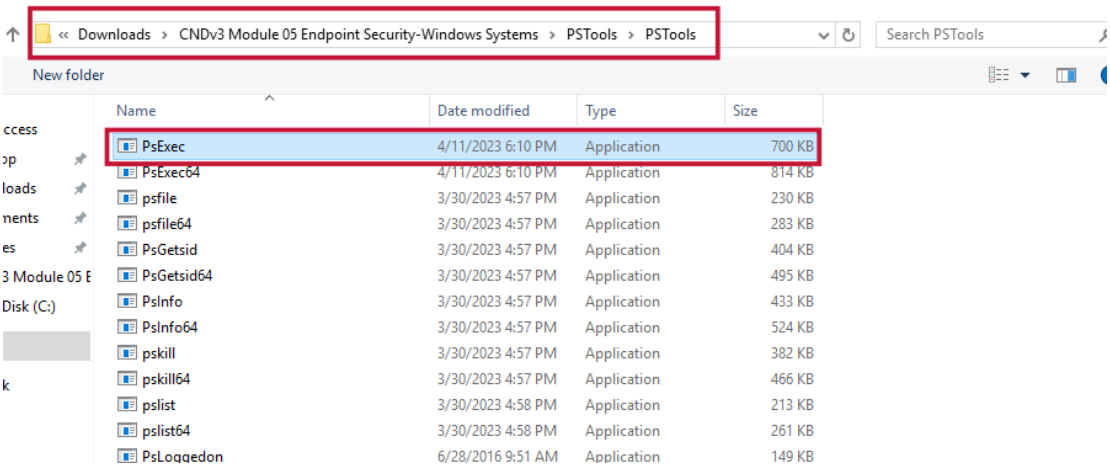
1. Run the installer



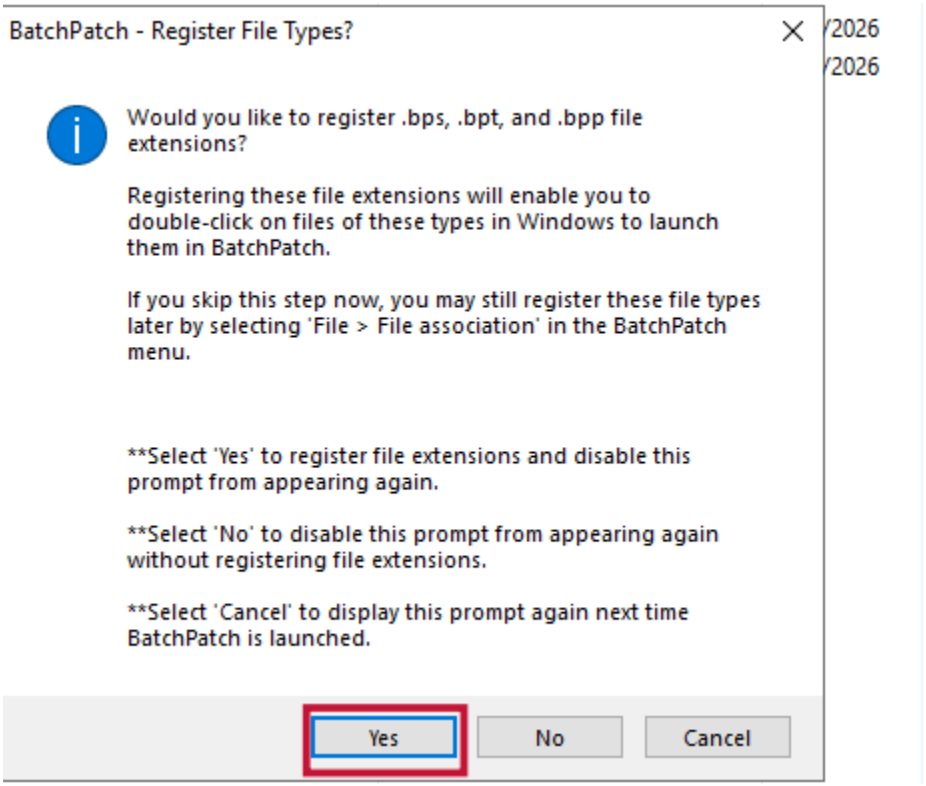
2. Click Ok and it will ask you to select the PsExec.exe



3. Select the PsExec.exe file from PSTools



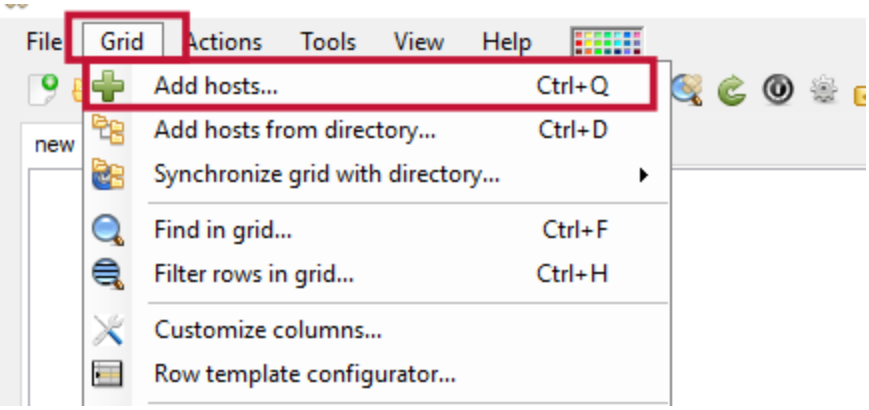
4. Click **"Yes"** to register the file extensions.



STEP 10 — CONFIGURE BATCHPATCH FOR REMOTE PATCHING

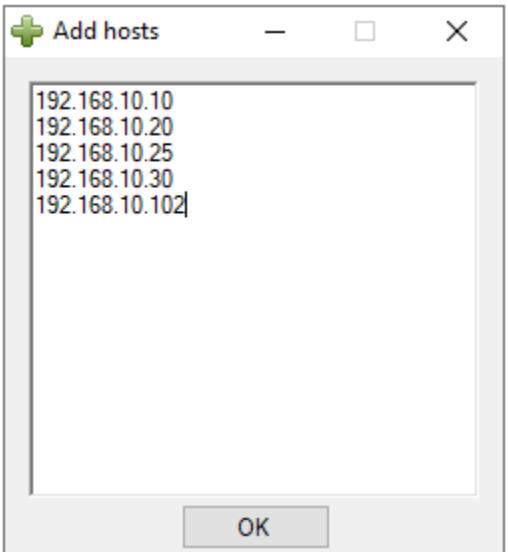
Add your machines to BatchPatch:

1. Go to **Grid → Add Hosts**



2. Enter each machine on its own line:

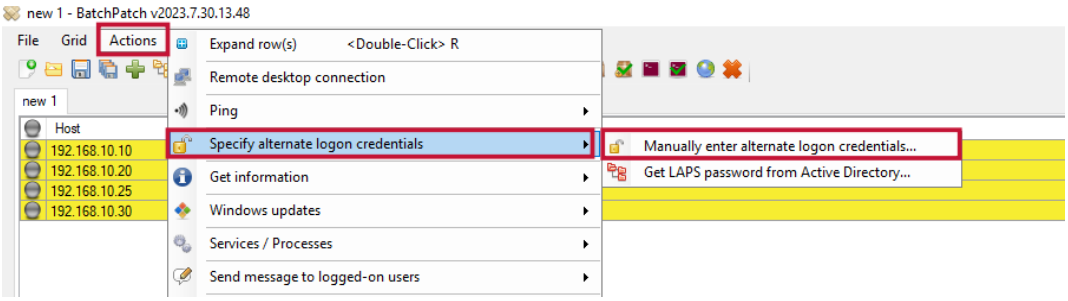
- 192.168.10.10
- 192.168.10.20
- 192.168.10.25
- 192.168.10.30
- 192.168.10.102



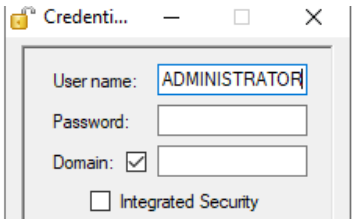
4. Click OK

Set credentials:

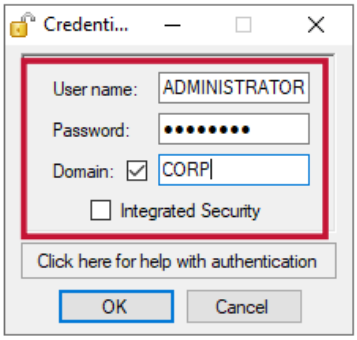
1. Select all hosts (Ctrl+A)
2. Go to **Actions → Click "Specify alternate logon credentials"**



3. Username: ADMINISTRATOR



4. Password: your domain admin password and Domain: corp.local



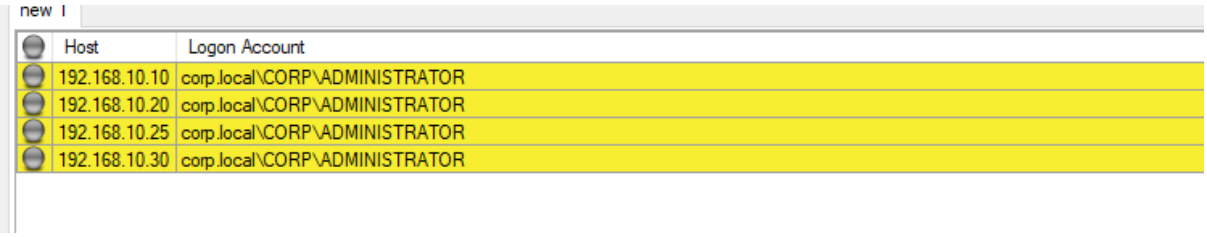
5. Click OK

Note: When BatchPatch was launched, it automatically prompted with **"PsExec filepath not detected"** dialog. We clicked OK and were presented with a file browser to locate PsExec.exe. PsTools was downloaded and extracted to C:\PSTools\ and PsExec path was set to C:\PSTools\PsExec.exe via the Settings → PsExec Settings menu in BatchPatch.

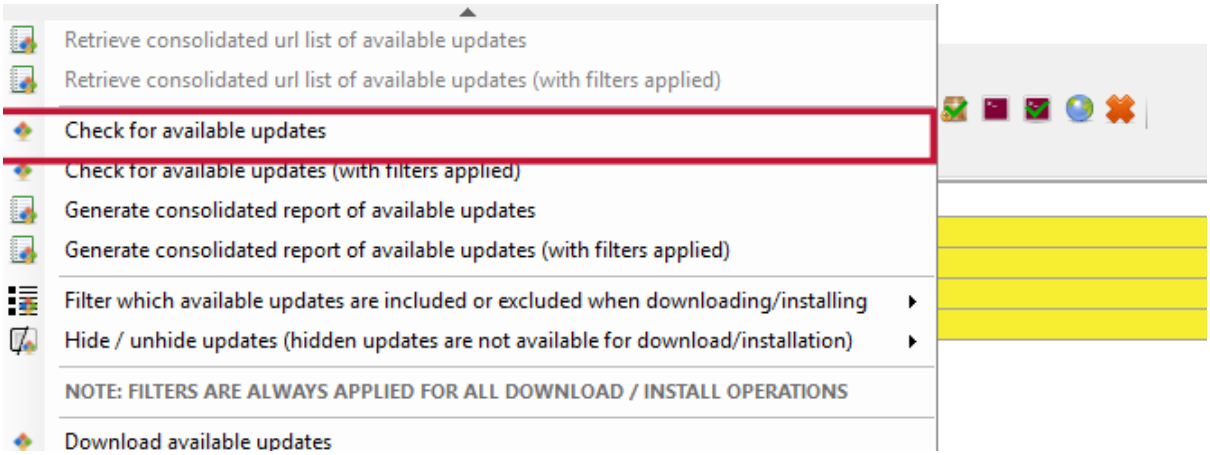
STEP 11 — SCAN FOR UPDATES AND PATCH REMOTELY

Scan all machines for missing patches:

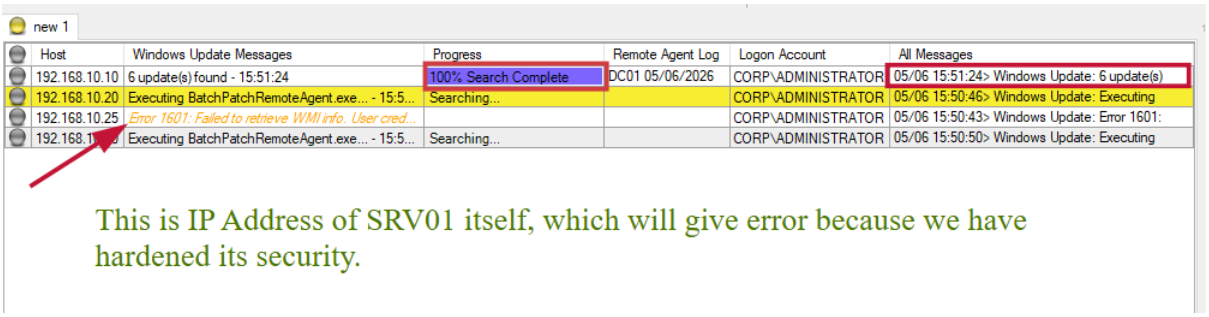
1. Select all hosts in BatchPatch (Ctrl+A)



2. Go to **Actions → Windows Updates → Check for Available Updates**



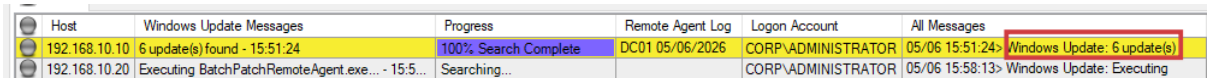
3. BatchPatch connects to each machine and queries Windows Update



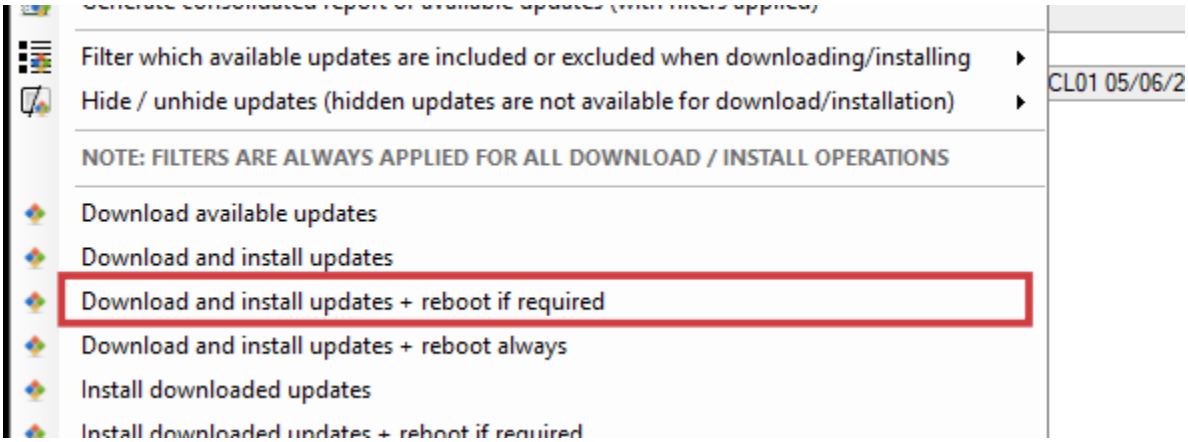
4. Wait 2–5 minutes — results appear in the grid showing how many updates are missing per machine

Install patches remotely:

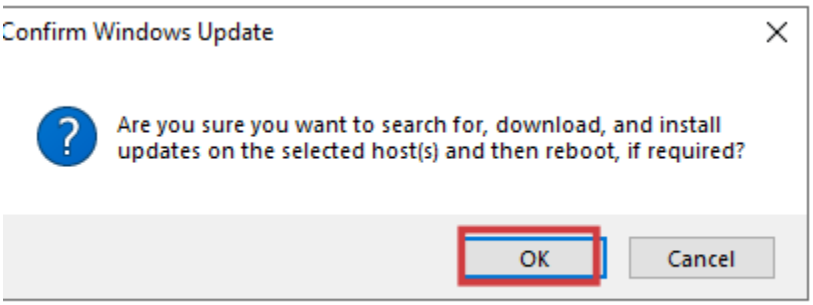
1. Select machines that show missing updates



2. Go to **Actions → Windows Update→ Download and Install**

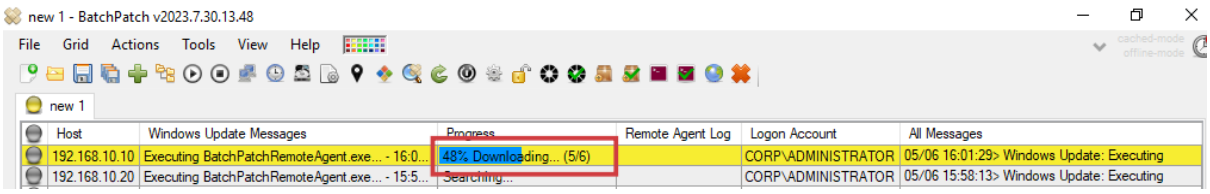


3. Check **Automatically reboot if required**



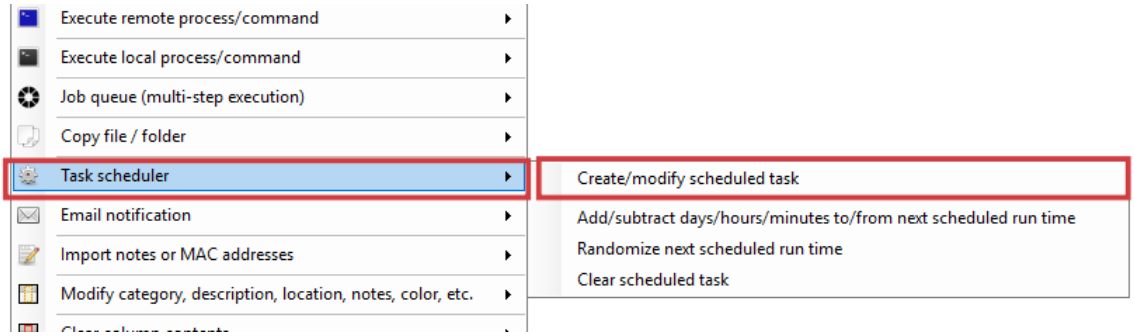
4. Click OK

5. BatchPatch pushes the updates — you see real-time status in the grid

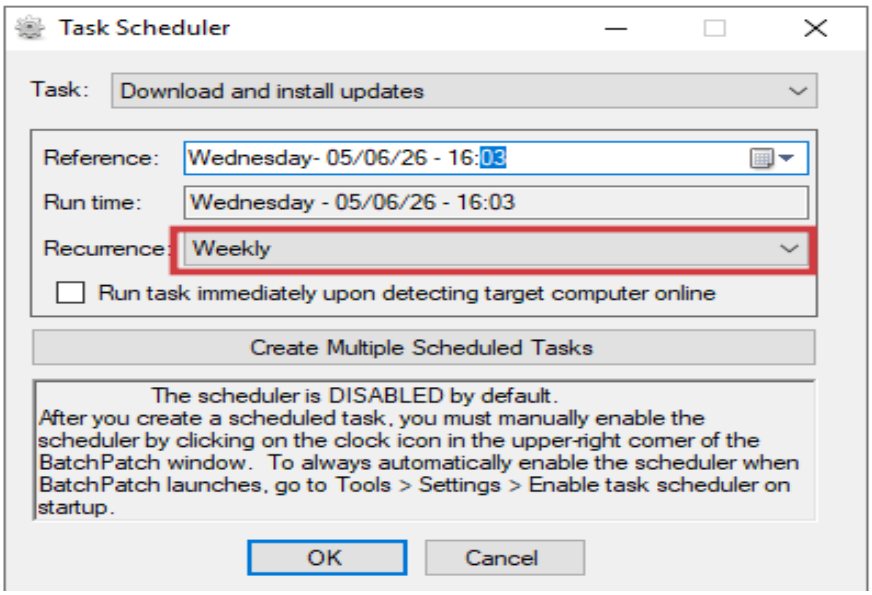


Schedule automated patching:

1. Select all hosts
2. Go to **Actions → Task Scheduler**



3. Set: Recurrence to Weekly



4. Click OK

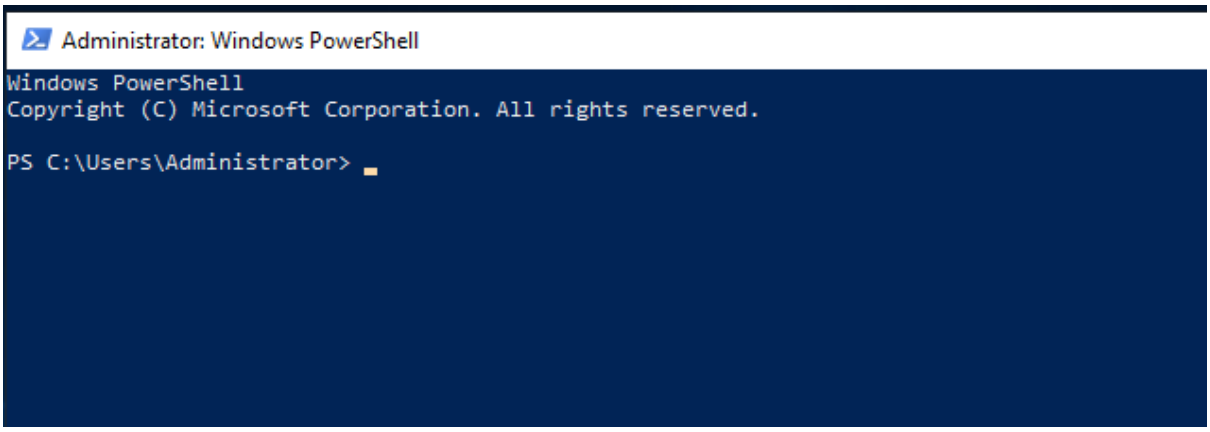
PHASE 6 — ADVANCED WINDOWS HARDENING

Do this on DC01 and SRV01.

DISABLE NTLM AUTHENTICATION

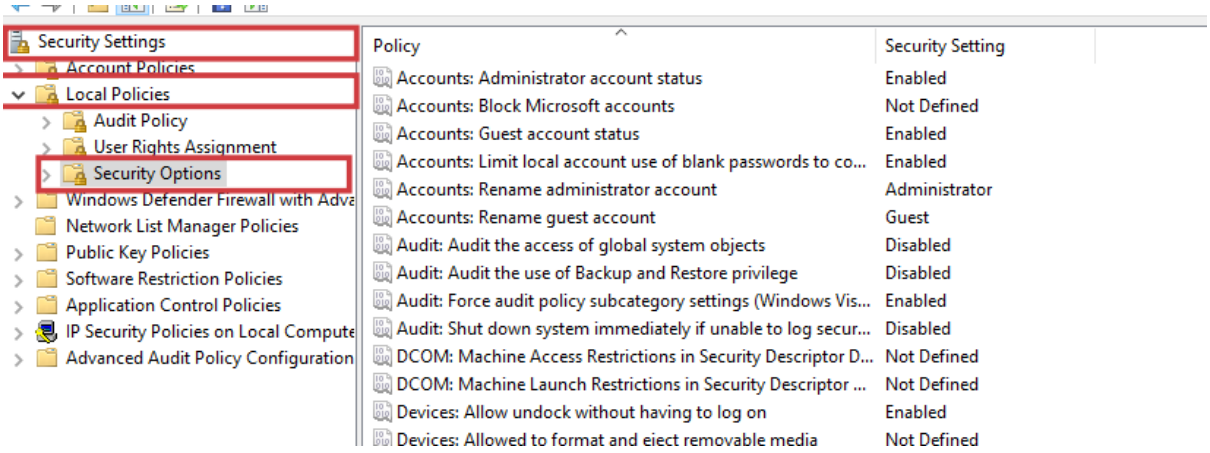
NTLM is vulnerable to Pass-the-Hash attacks. Disable it to force Kerberos.

On DC01 — PowerShell as Administrator:

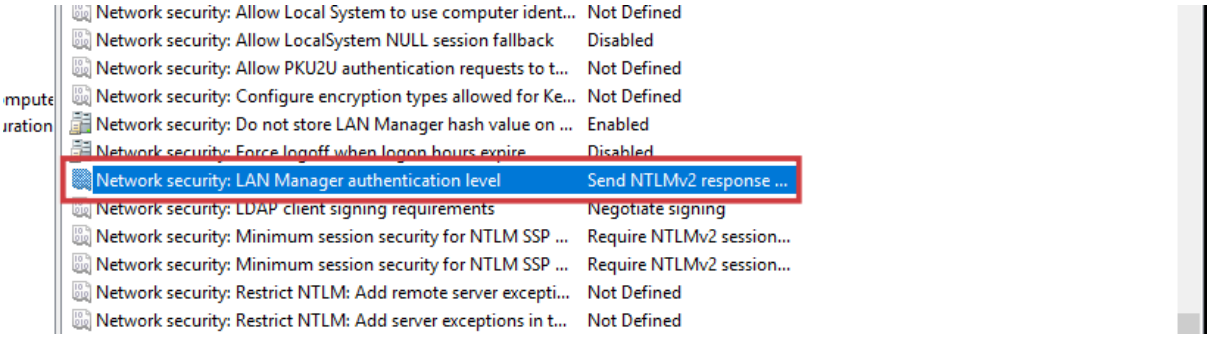


Type secpol.msc and press Enter

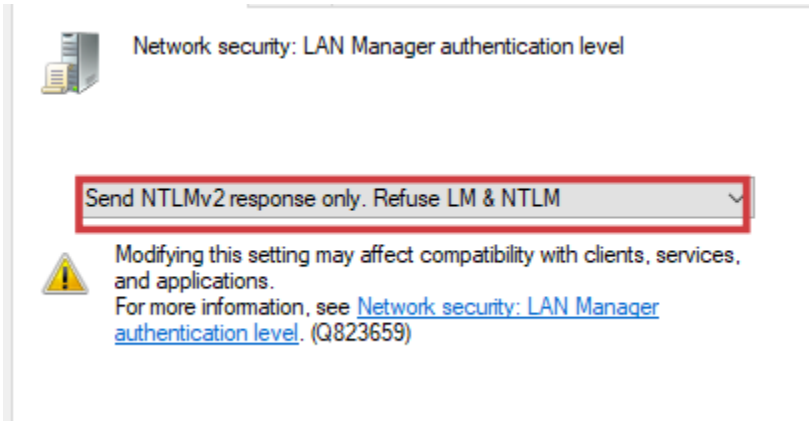
1. **Navigate to: Security Settings → Local Policies → Security Options**



2. **Find: Network security: LAN Manager authentication level**



3. **Double-click → set to: Send NTLMv2 response only. Refuse LM & NTLM**



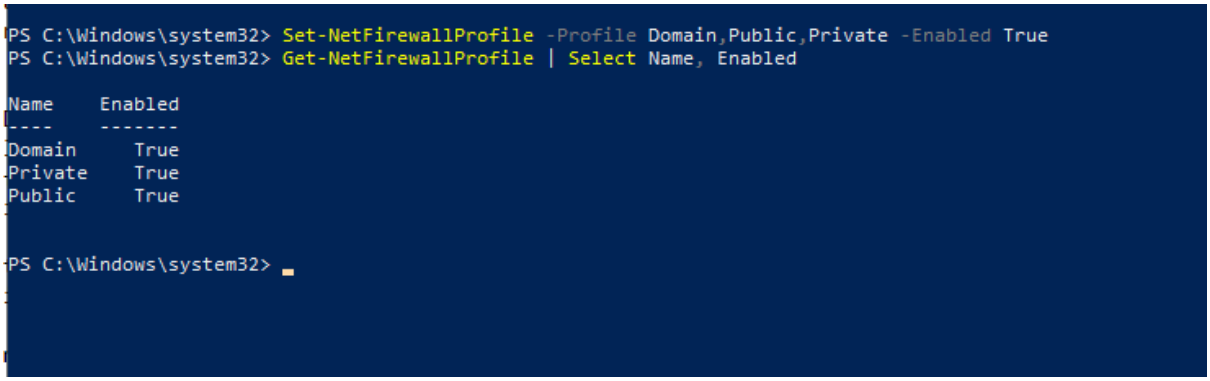
- **Now do the same steps in SRV01 Virtual Machine as well**

ENABLE AND CONFIGURE WINDOWS FIREWALL

On DC01 — PowerShell:

```
Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled True

Get-NetFirewallProfile | Select Name, Enabled
```

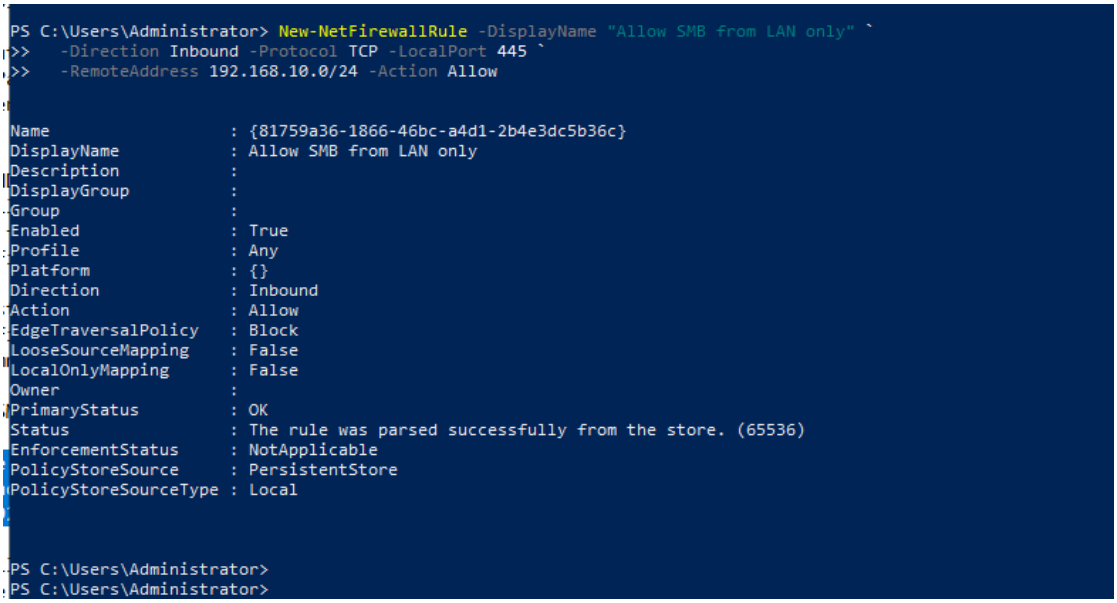


On SRV01 — same commands, plus add a specific rule to protect the file share:

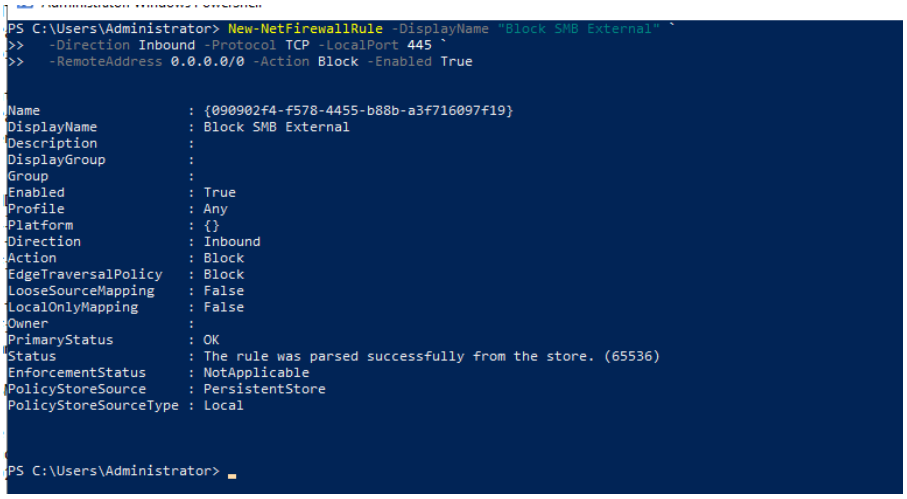
```
New-NetFirewallRule -DisplayName "Allow SMB from LAN only" `

  -Direction Inbound -Protocol TCP -LocalPort 445 `

  -RemoteAddress 192.168.10.0/24 -Action Allow
```



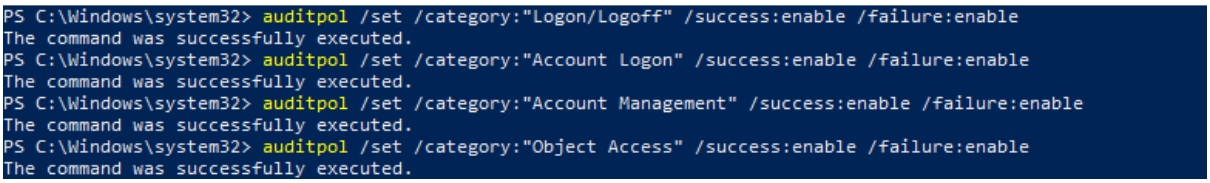
```
New-NetFirewallRule -DisplayName "Block SMB External" `
  -Direction Inbound -Protocol TCP -LocalPort 445 `
  -RemoteAddress 0.0.0.0/0 -Action Block -Enabled True
```

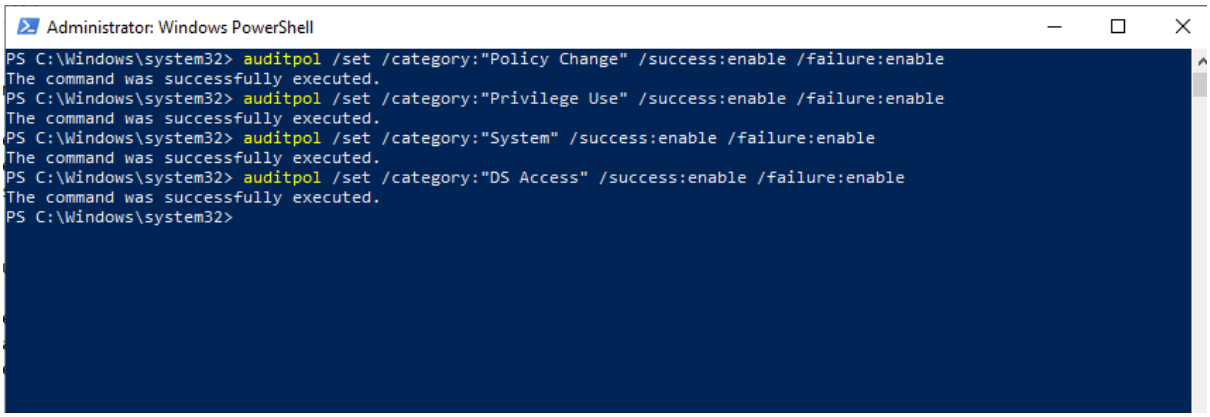


ENABLE ADVANCED AUDIT POLICIES

On DC01 — PowerShell as Administrator:

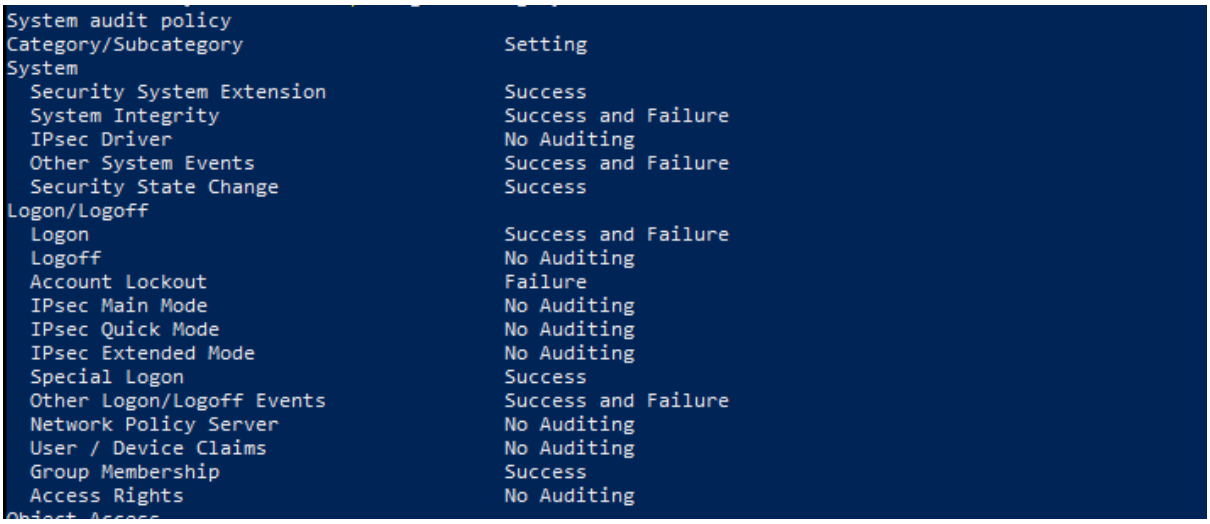
```
auditpol /set /category:"Logon/Logoff" /success:enable /failure:enable
auditpol /set /category:"Account Logon" /success:enable /failure:enable
auditpol /set /category:"Account Management" /success:enable /failure:enable
auditpol /set /category:"Object Access" /success:enable /failure:enable
auditpol /set /category:"Policy Change" /success:enable /failure:enable
auditpol /set /category:"Privilege Use" /success:enable /failure:enable
auditpol /set /category:"System" /success:enable /failure:enable
auditpol /set /category:"DS Access" /success:enable /failure:enable
```



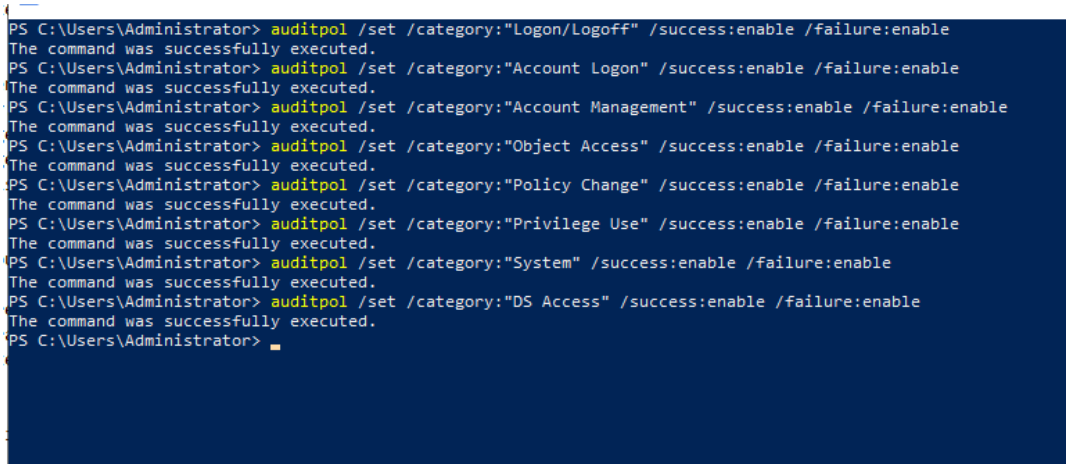


For Verification

auditpol /get /category:*



- Now Enter these commands in the SRV01 VM as well



PHASE 7 — WAZUH SIEM DEPLOYMENT

This is the biggest phase of Module 5. IDS01 becomes your full Wazuh SIEM server.

Note: Before Installation add a NAT Network Adapter on each machine.

INSTALL WAZUH SERVER ON IDS01

Go to IDS01



Introduction

Wazuh is an open-source security monitoring platform that can be used for intrusion detection, log analysis, vulnerability detection, and much more. It is a highly scalable tool that helps in ensuring the security of systems and applications. Wazuh integrates seamlessly with Elastic Stack (Elasticsearch, Logstash, Kibana) for powerful data analysis and visualization.

This guide will walk you through the steps required to install Wazuh on your system. Before proceeding with the Wazuh installation, you must ensure that your system meets the necessary requirements.

System Requirements

Before installing Wazuh, ensure your system meets the following requirements:

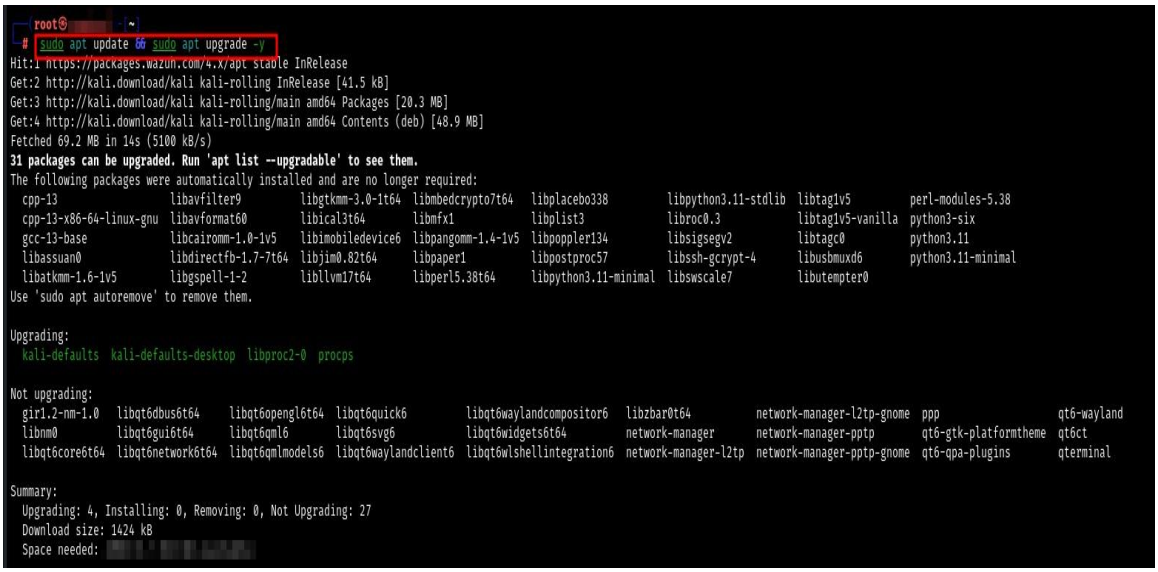
- CPU: Minimum 2 vCPUs (4 recommended)
- RAM: Minimum 4GB (8GB recommended)
- Storage: At least 20GB free space
- Network: Internet access for package downloads

Installation Steps

Step 1: Update the System

Before installation, update your package lists:

```
sudo apt update && sudo apt upgrade -y
```



Step 2: Curl and How to Install It

curl is a command-line tool and library for transferring data with URLs. It supports multiple protocols like HTTP, FTP, and more. It's widely used for downloading files, interacting with APIs, and making automated requests to servers. Since the Wazuh installation script requires curl to fetch files, it needs to be installed on your system if it’s not already.

Installing curl

If curl is not installed on your system, you can install it using the following command for Ubuntu or any Debian-based system:

```
sudo apt install curl
```



This command will install curl and its necessary dependencies. Once the installation is complete, you will be able to use curl for downloading the Wazuh installation script, as well as for other tasks like making API requests or automating file downloads.

Step 3: Installing Wazuh Using the Automated Script

Once curl is installed, you can proceed with installing Wazuh using the automated installation script. To install Wazuh, run the following command:

```
curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh && sudo bash
./wazuh-install.sh -a
```

This command performs the following tasks:

Downloads the installation script:

- curl -sO https://packages.wazuh.com/4.10/wazuh-install.sh: This fetches the Wazuh installation script from the official repository.

Executes the installation script:

- sudo bash ./wazuh-install.sh: Runs the script as a superuser (root) to ensure proper installation.

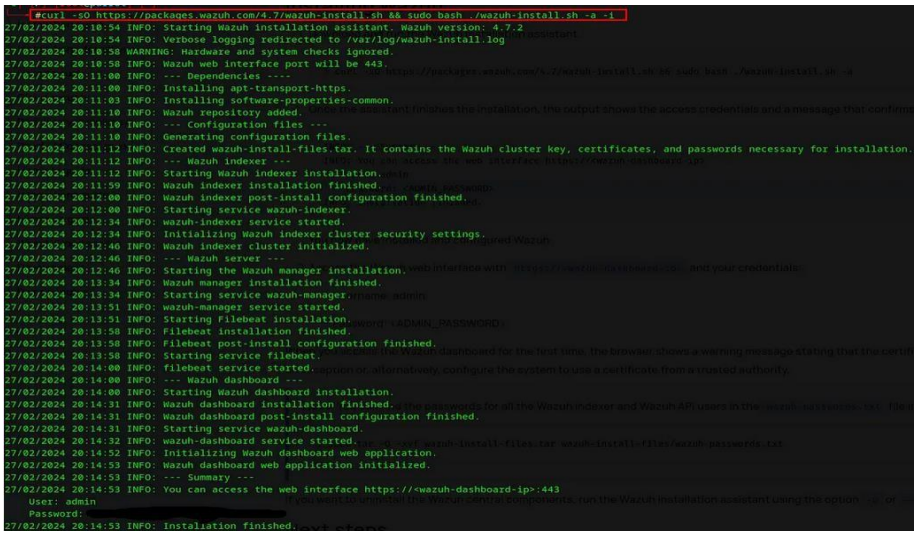
Explanation of the Flags

-a: The auto flag. This option tells the script to perform an automatic installation of Wazuh. It installs the Wazuh Manager, which is responsible for managing all security events from the agents deployed on your system.

-i: The install flag. This option triggers the installation process. It initiates the installation of Wazuh and all necessary dependencies, including configuration and setup.

Once the command is executed, the script will automatically download the necessary packages, configure Wazuh, and start the service. This process typically takes a few minutes to complete.

Once the command is executed, the script will automatically download the necessary packages, configure Wazuh, and start the service. This process typically takes a few minutes to complete.

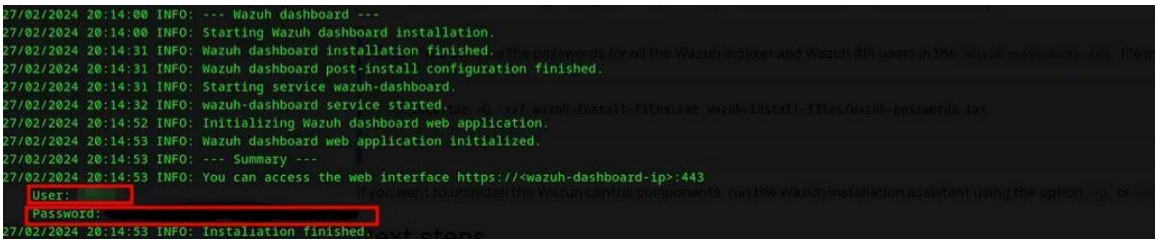


Step 4: Accessing the Wazuh Dashboard

Once the installation is complete, you will see your username and password displayed in the terminal. This login information is required to access the Wazuh dashboard. Here's how you can use it:

Username and Password

- After the installation is finished, the terminal will output your Wazuh **username** and **password**. These credentials are necessary to log into the Wazuh web interface.



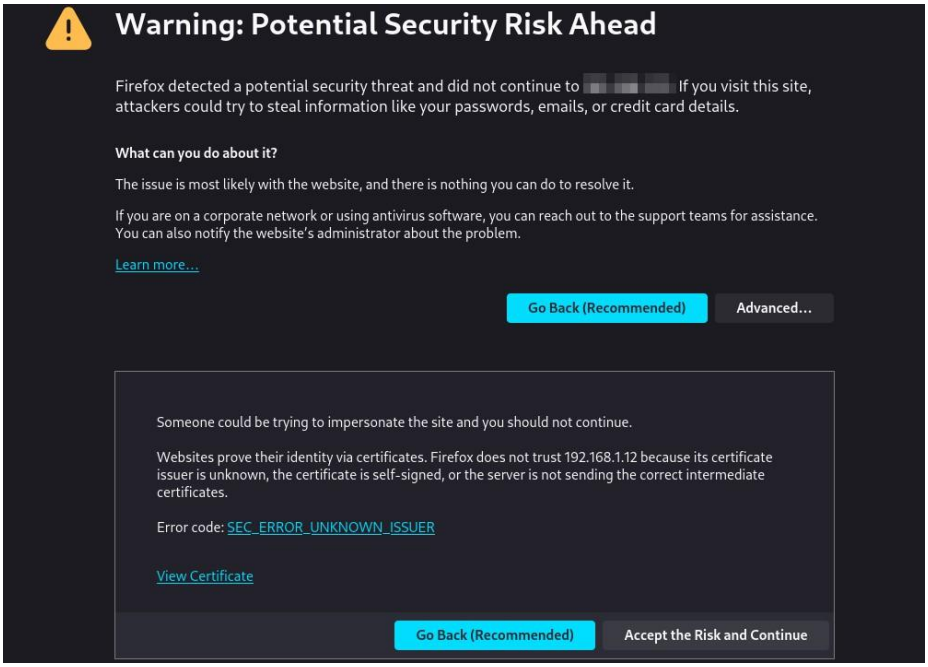
- Do not close the Terminal, First save your Wazuh Password

Accessing the Wazuh Dashboard

1. **Open a Web Browser**: Open your preferred web browser.
2. **Enter the Wazuh Dashboard URL**: In the browser's address bar, type the following URL to access the Wazuh dashboard:

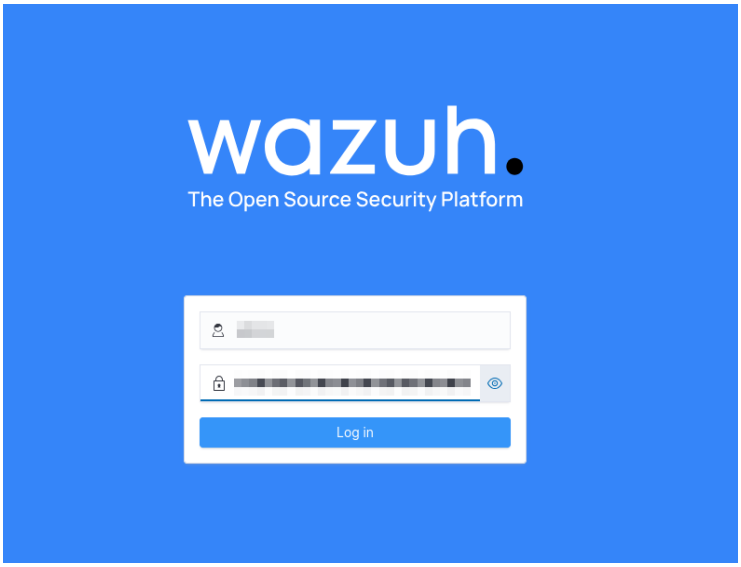
https://<your-server-ip>

Replace <your-server-ip> with the actual IP address or domain name of your Wazuh server.

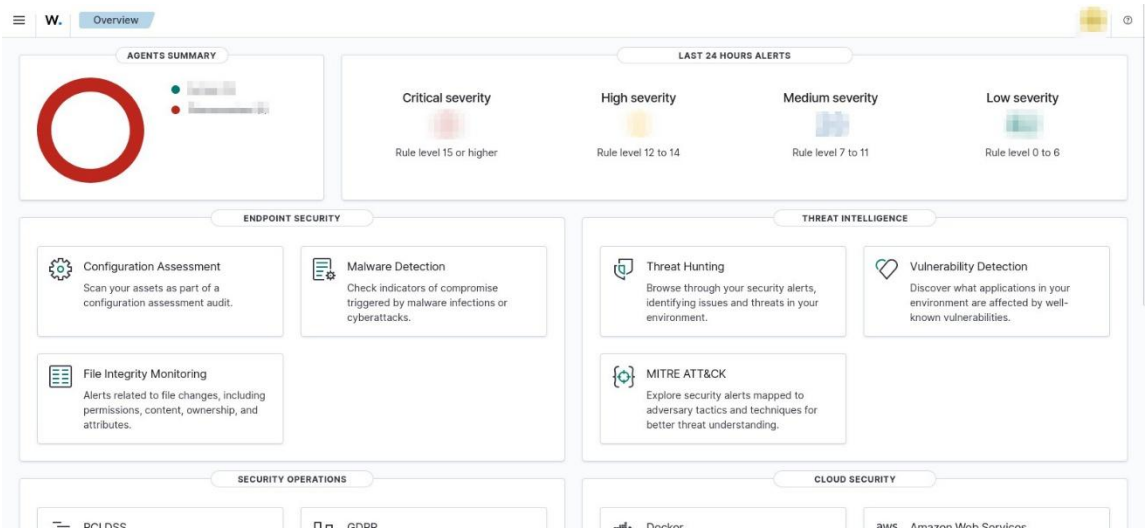


On entering your ip address, a warning will appear. Click on the **advanced** and then click on the **Accept the Risk and Continue**

3. **Login**: On the login page, enter the **username** and **password** that were displayed in the terminal after the installation.



4. **Dashboard Access:** After logging in, you will have access to the Wazuh dashboard where you can begin managing and monitoring your security environment.



Troubleshooting & Fixes

Here are some common issues and their solutions:

Issue: Wazuh Manager Not Starting

Run the following command

```
sudo journalctl -xe -u wazuh-manager
```

If the issue persists, try restarting:

```
sudo systemctl restart wazuh-manager
```

Issue: Wazuh Dashboard Not Accessible

Check if the service is running:

```
sudo systemctl status wazuh-dashboard
```

If not, start it:

```
sudo systemctl start wazuh-dashboard
```

Issue: Wazuh Indexer Not Working

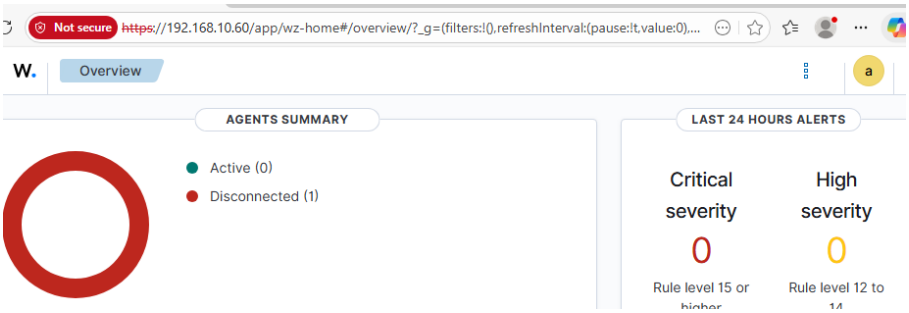
Run the following command

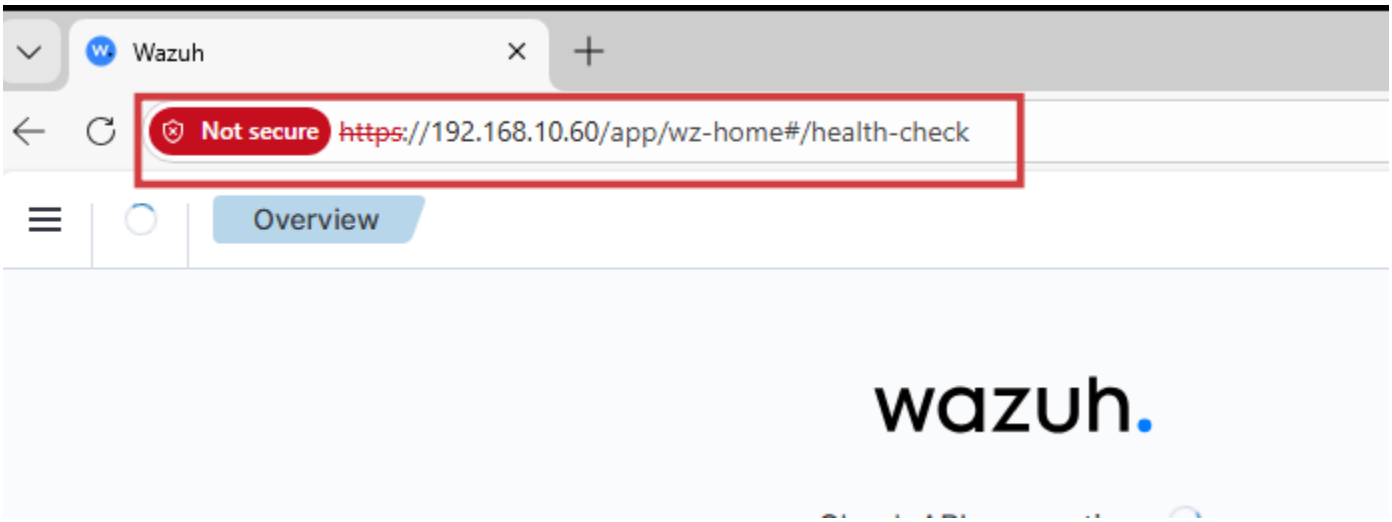
```
sudo systemctl restart wazuh-indexer
```

ACCESS WAZUH DASHBOARD

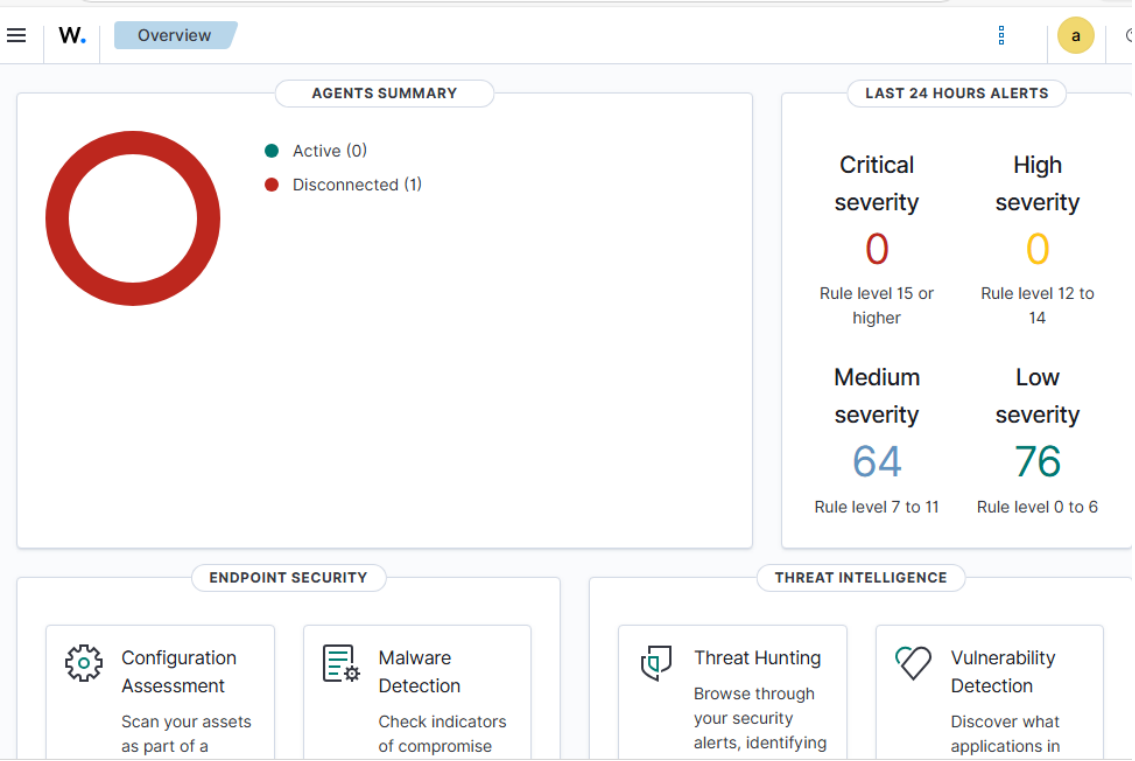
From ADMIN01 (or any machine with a browser):

1. Open browser
2. Go to: https://192.168.10.60 (IDS01's IP)





3. You will see a certificate warning — click **Advanced → Accept and Continue** (self-signed cert)
4. Login: Username admin → Password: the one saved from installation



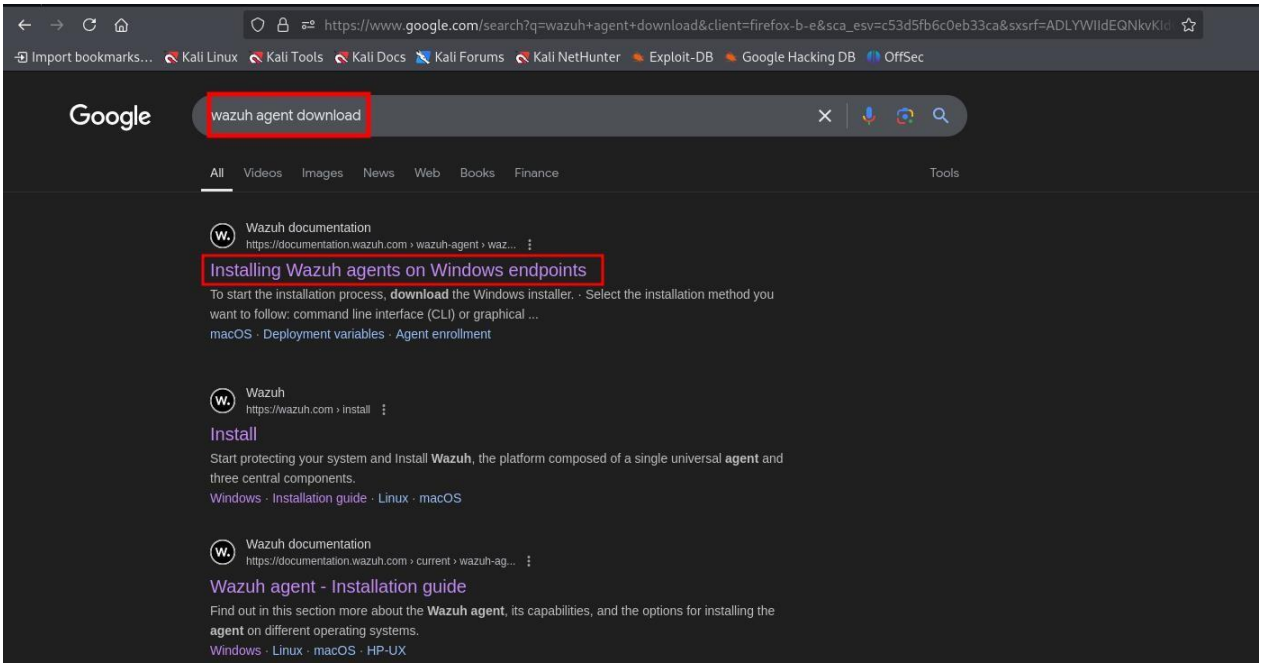
5. You are now in the Wazuh Dashboard

Connecting wazuh agent with the wazuh server

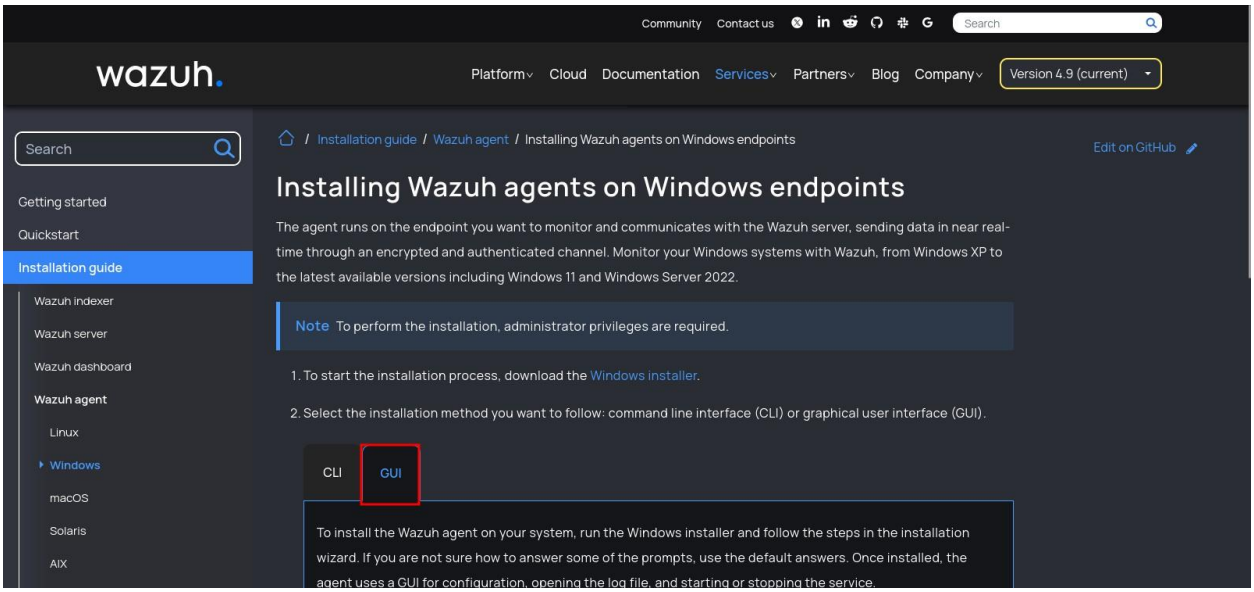


First install wazuh agent in the Windows virtual machine

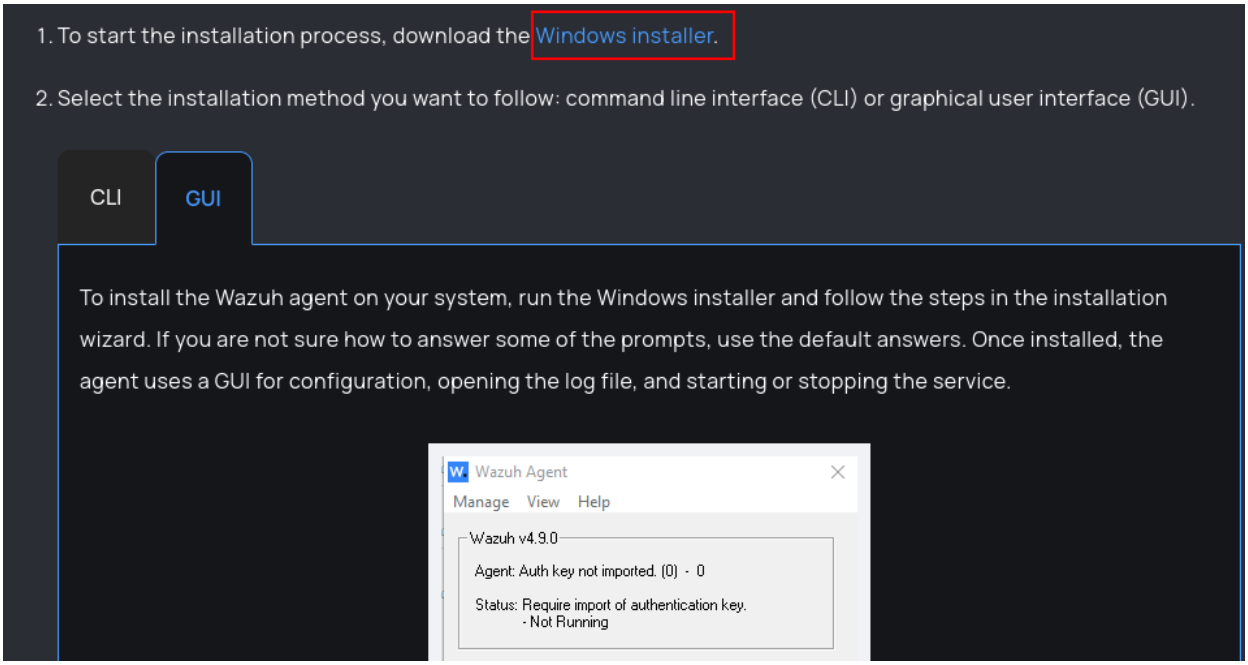
To install wazuh agent in the windows virtual machine. Search wazuh agent download in the browser of the virtual machine



Open this official website of Wazuh

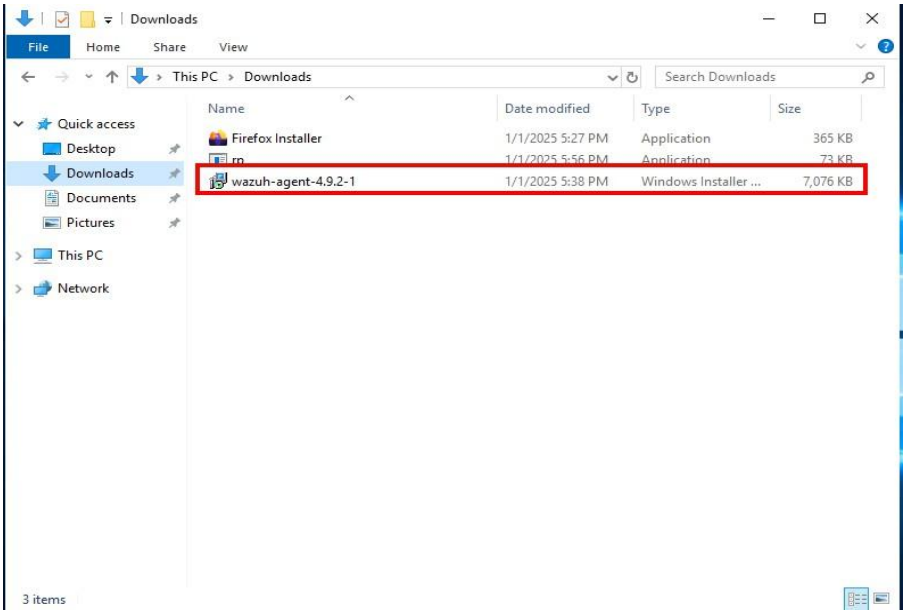


Select the GUI option and select the windows installer

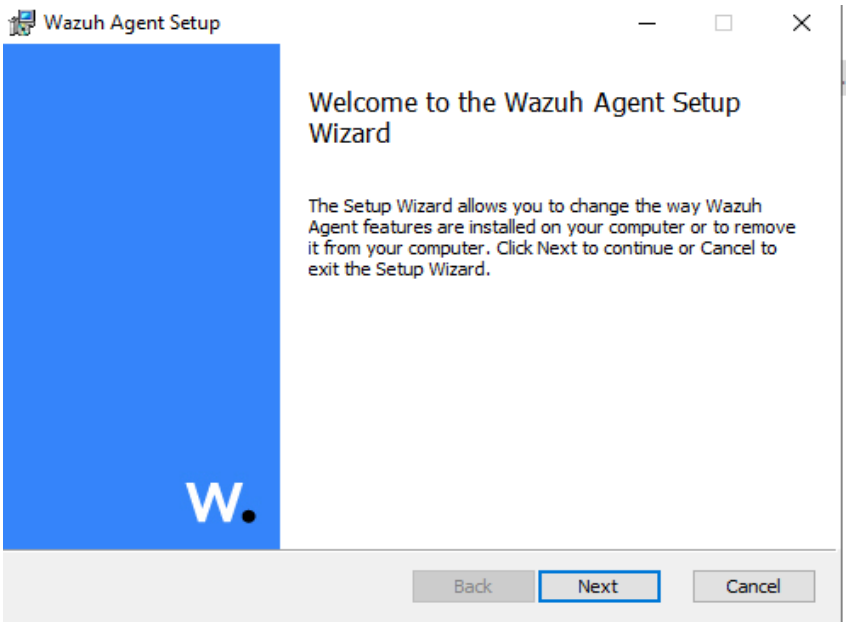


The download will begin automatically when you click the windows installer

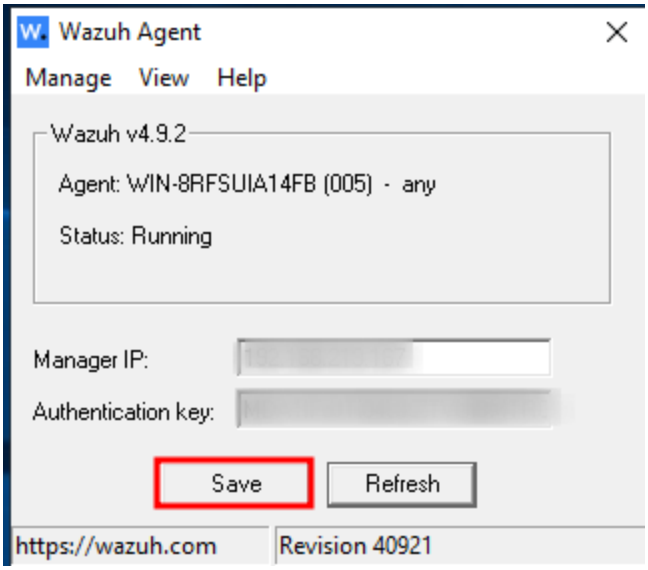
Run the wazuh agent installer and install it in your vm



Wazuh agent installation will start. Click next and install wazuh agent

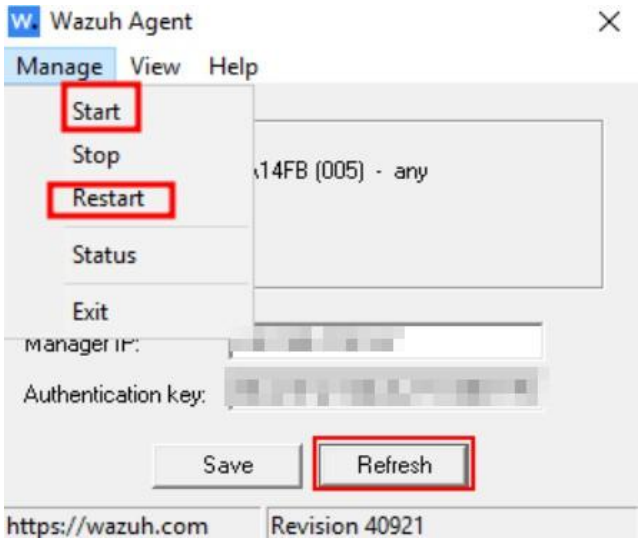


Open the wazuh agent after installation

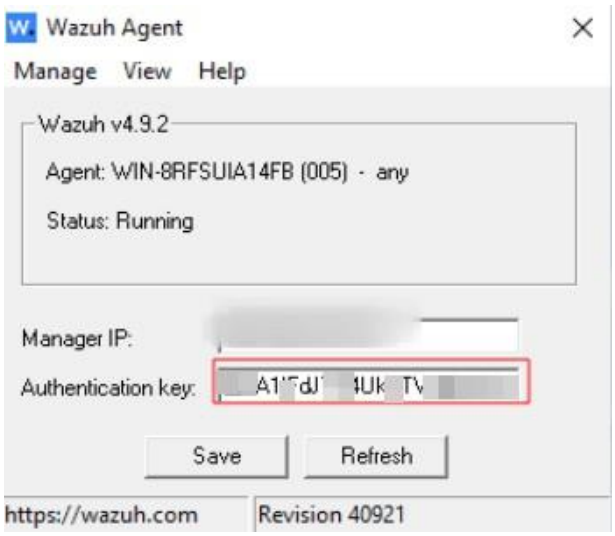


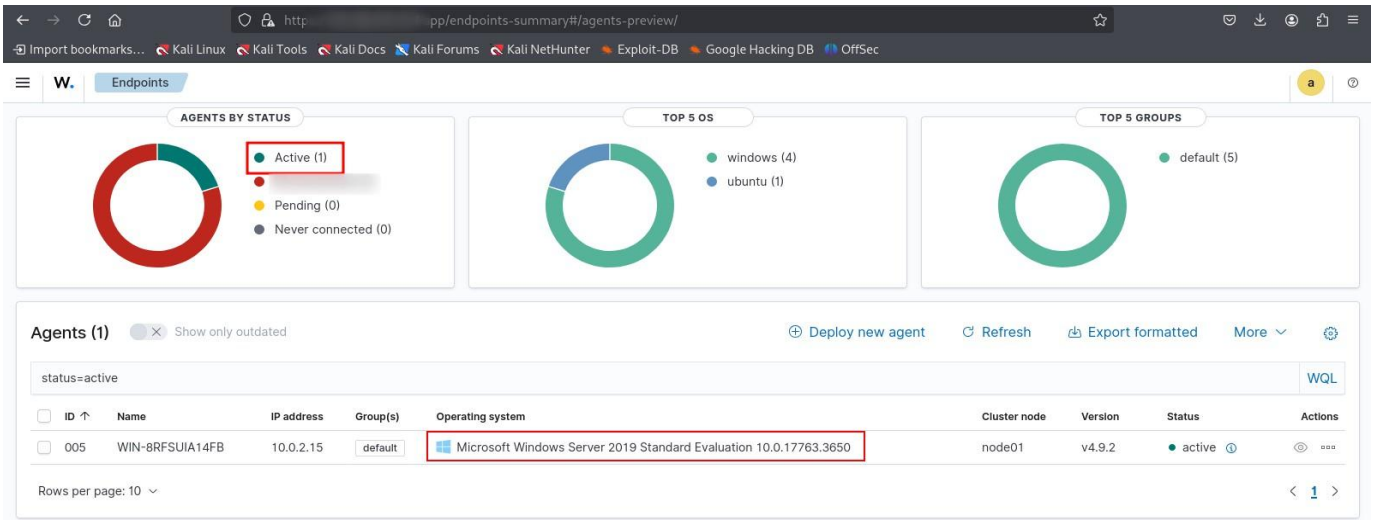
Enter the manager IP (IP of your machine where you have installed wazuh server): IP Address of IDS01

Click save



Click start, then restart and then refresh. It will automatically generate the authentication key when the wazuh agent is connected to the wazuh server





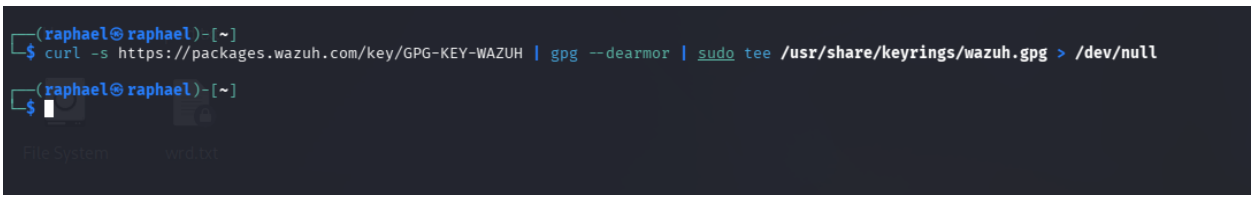
Now install Wazuh Agents in all the Virtual Machines and then configure Wazuh Agents in the same way given Above.

CONFIGURE WAZUH AGENT ON LINUX (IDS01 itself / ATTACKER monitoring)

If you also want to monitor the Kali ATTACKER machine:

On ATTACKER Kali machine

```
curl -s https://packages.wazuh.com/key/GPG-KEY-WAZUH | gpg --dearmor |
sudo tee /usr/share/keyrings/wazuh.gpg > /dev/null
```

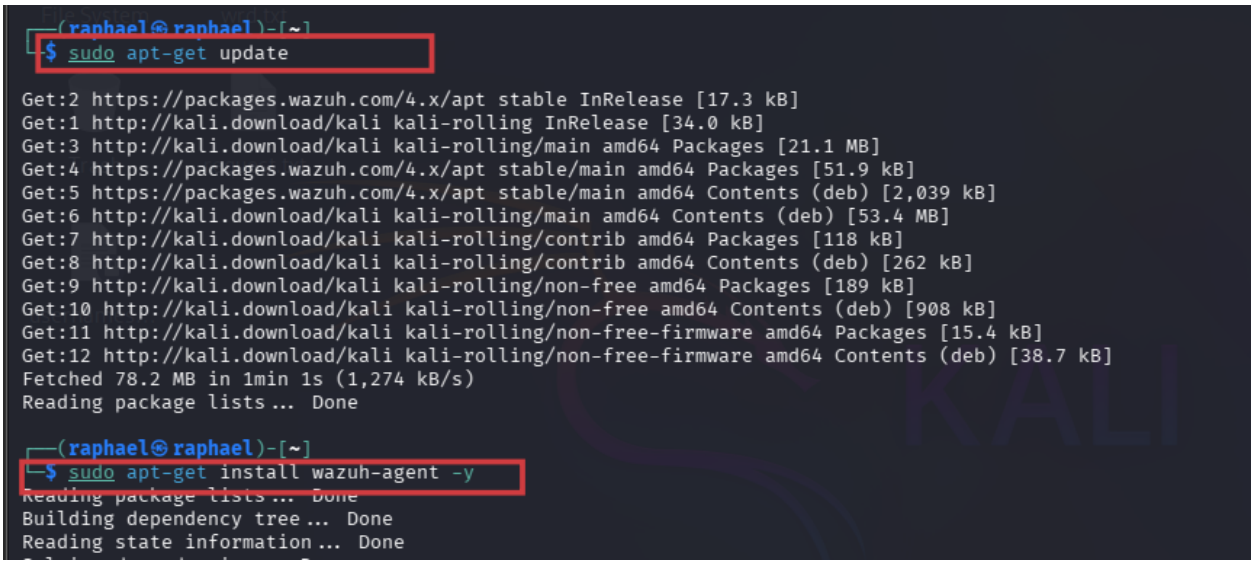



```
echo "deb [signed-by=/usr/share/keyrings/wazuh.gpg]
https://packages.wazuh.com/4.x/apt/ stable main" | sudo tee
/etc/apt/sources.list.d/wazuh.list
```




```
sudo apt-get update

sudo apt-get install wazuh-agent -y
```



Configure the agent to point to IDS01

```
sudo sed -i 's/MANAGER_IP/192.168.10.60/' /var/ossec/etc/ossec.conf
```

```
┌──(raphael㉿raphael)-[~]
└─$ sudo sed -i 's/MANAGER_IP/192.168.10.60/' /var/ossec/etc/ossec.conf
```

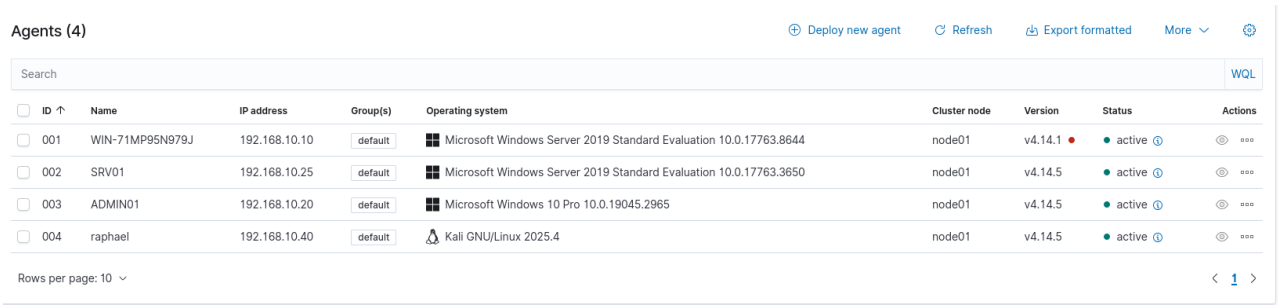
```
sudo systemctl start wazuh-agent

sudo systemctl enable wazuh-agent
```

```
┌──(raphael㉿raphael)-[~]
└─$ sudo systemctl start wazuh-agent

┌──(raphael㉿raphael)-[~]
└─$ sudo systemctl enable wazuh-agent
Created symlink '/etc/systemd/system/multi-user.target.wants/wazuh-agent.service' → '/usr/lib/systemd/system/wazuh-agent.service'.
```

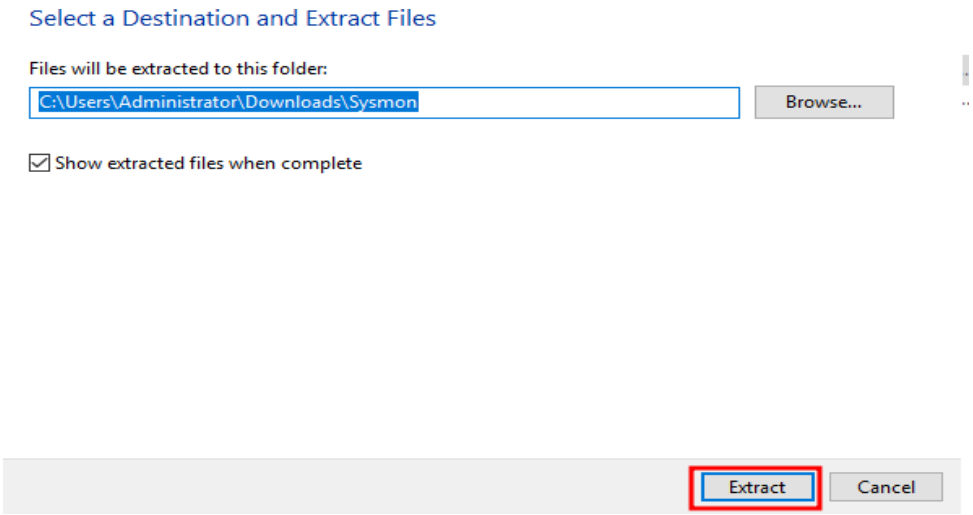
- You can see in the wazuh dashboard, Active Agents



Phase 8 – Sysmon Installation and Configuration with Wazuh

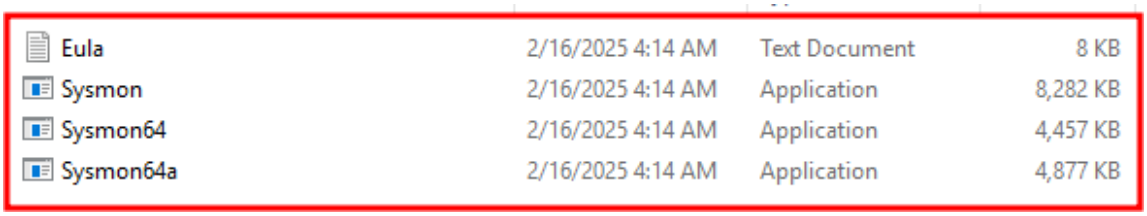
Sysmon (System Monitor) is a powerful Windows system service and device driver developed by Microsoft as part of the Sysinternals Suite. It is designed to provide detailed logging of system activity, which is crucial for security monitoring, threat detection, and forensic analysis. Sysmon operates at the kernel level, allowing it to capture a wide range of events with high granularity, making it an indispensable tool for security professionals.

Download Sysmon from: https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon



Extract the downloaded file.

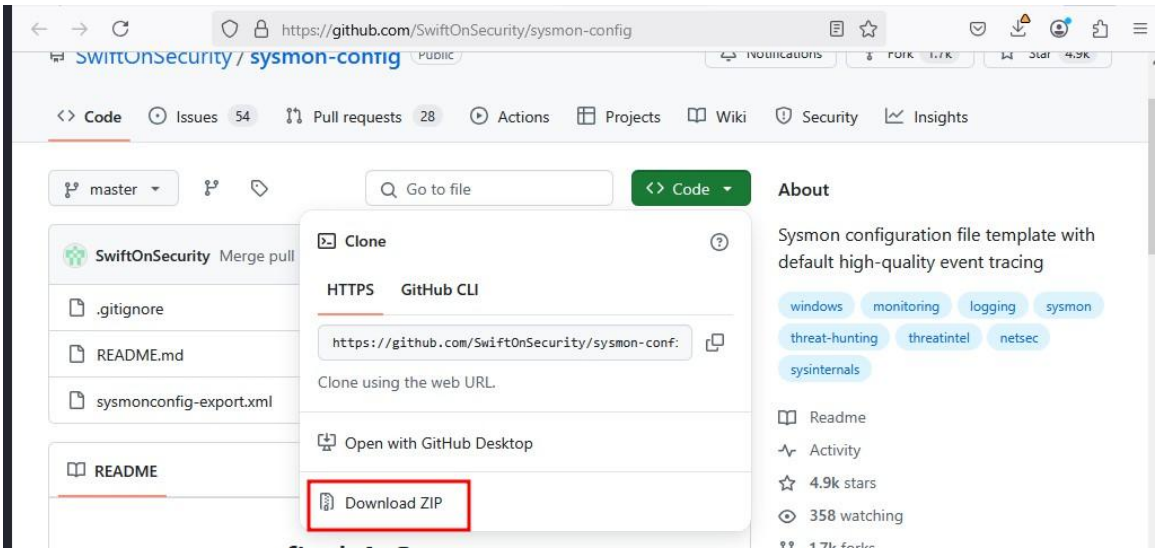
These are the files you will get when you extract the downloaded file.



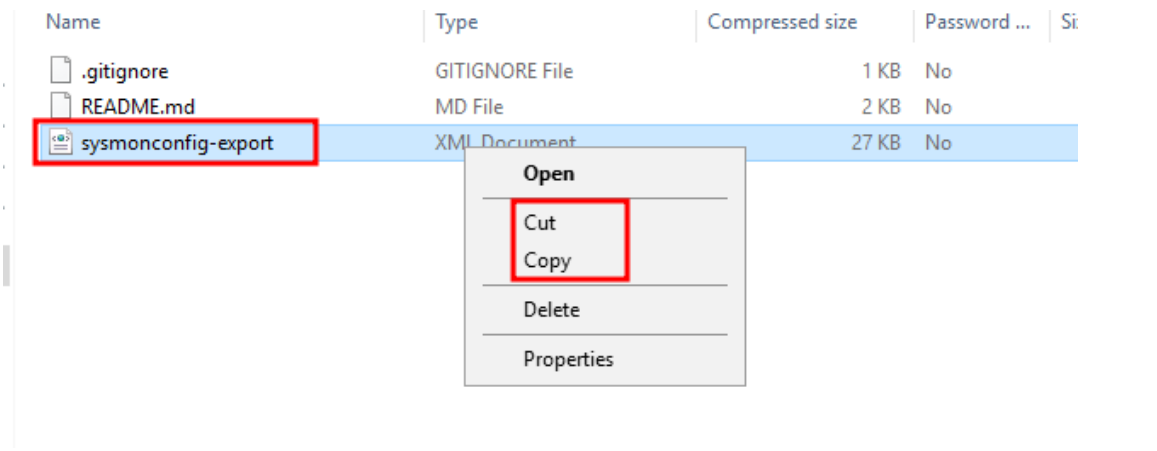
Configuring Sysmon

Download the Sysmon configuration file:

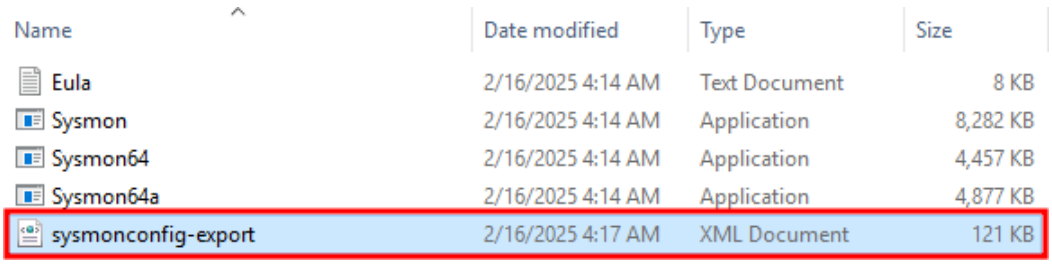
🔗 SwiftOnSecurity Sysmon Config: https://github.com/SwiftOnSecurity/sysmon-config



Extract the downloaded sysmon config zip file and copy the file sysmonconfig-export and paste it with the sysmon installation files.



Save the file with .xml in the same folder where sysmon.exe is downloaded

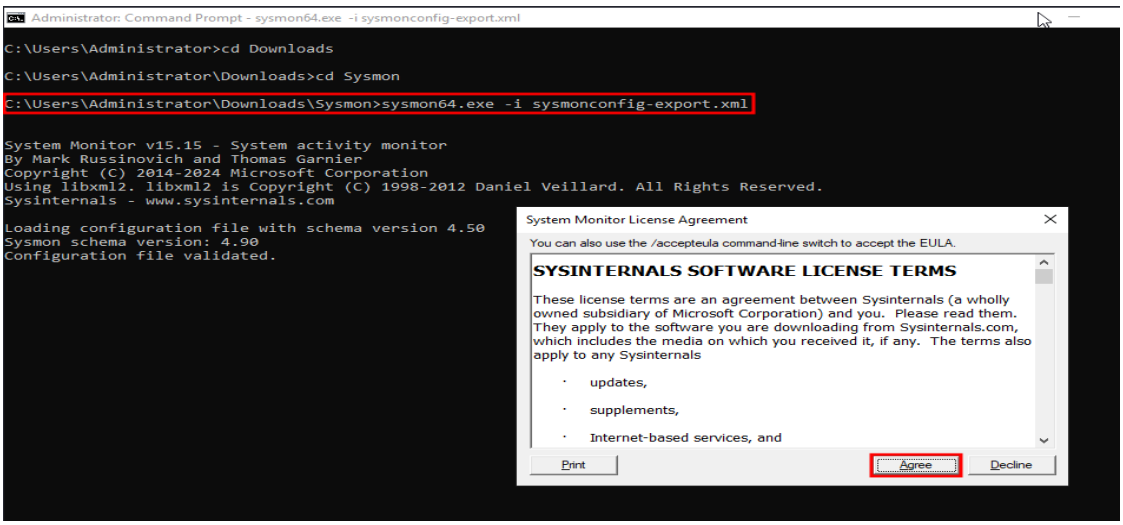


Name	Date modified	Type	Size
Eula	2/16/2025 4:14 AM	Text Document	8 KB
Sysmon	2/16/2025 4:14 AM	Application	8,282 KB
Sysmon64	2/16/2025 4:14 AM	Application	4,457 KB
Sysmon64a	2/16/2025 4:14 AM	Application	4,877 KB
sysmonconfig-export	2/16/2025 4:17 AM	XML Document	121 KB

Now I run cmd as an Administrator

Navigate to the directory where we have our executable and config file Run the following command in the command prompt

sysmon64.exe -i sysmonconfig-export.xml



Click on agree

If the execution is successful, you will see this in your terminal.

```
Loading configuration file with schema version 4.50
Sysmon schema version: 4.90
Configuration file validated.
Sysmon64 installed.
SysmonDrv installed.
Starting SysmonDrv.
SysmonDrv started.
Starting Sysmon64..
Sysmon64 started.
```

Successful installation

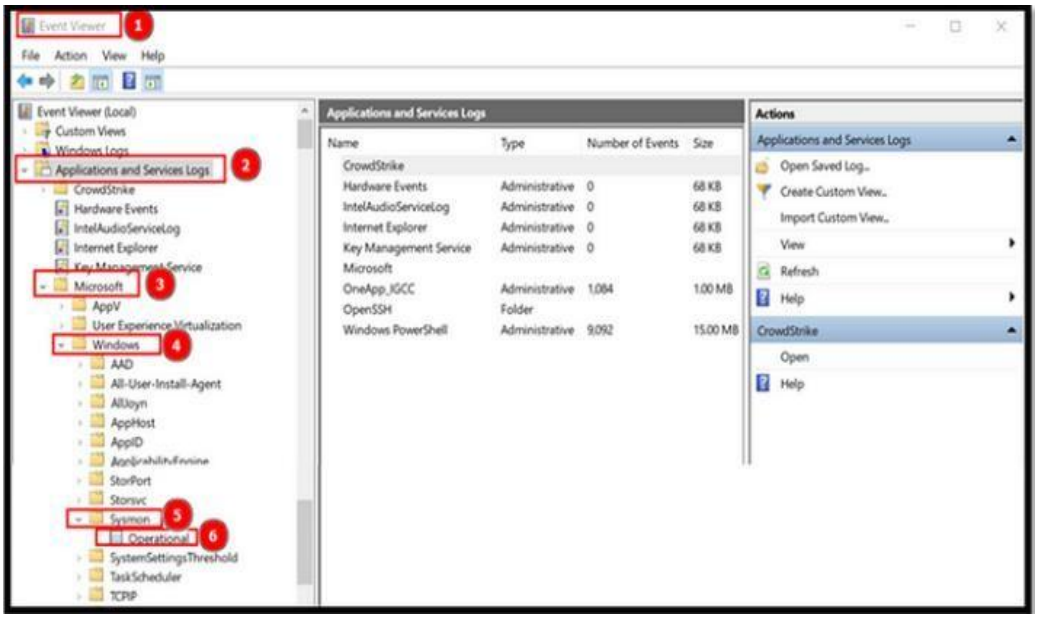
Sysmon doesn't require a reboot.

Confirm Sysmon Logs in Event Viewer

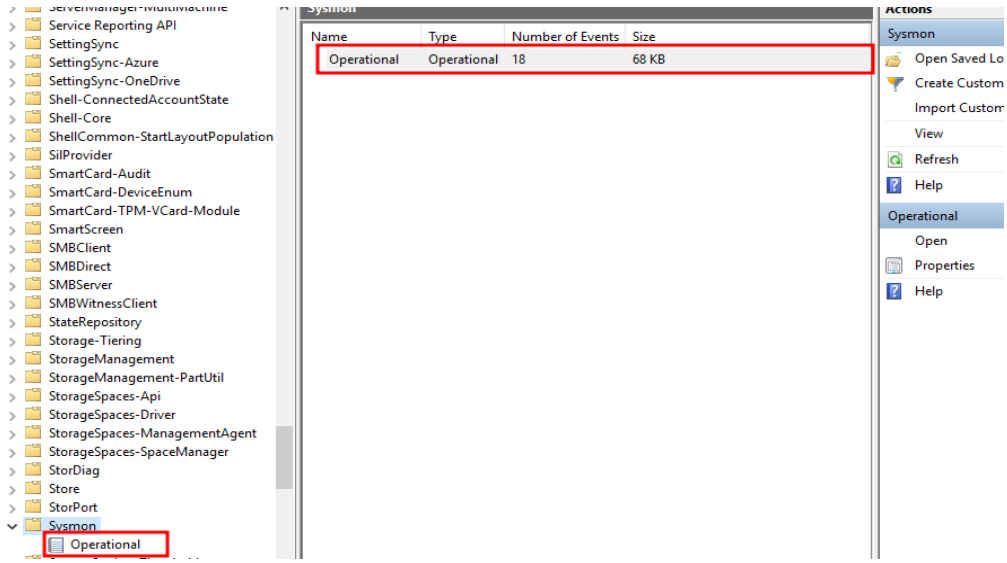
Open Event Viewer

Go to Application and Services

Expand Microsoft > Windows > System > Operational



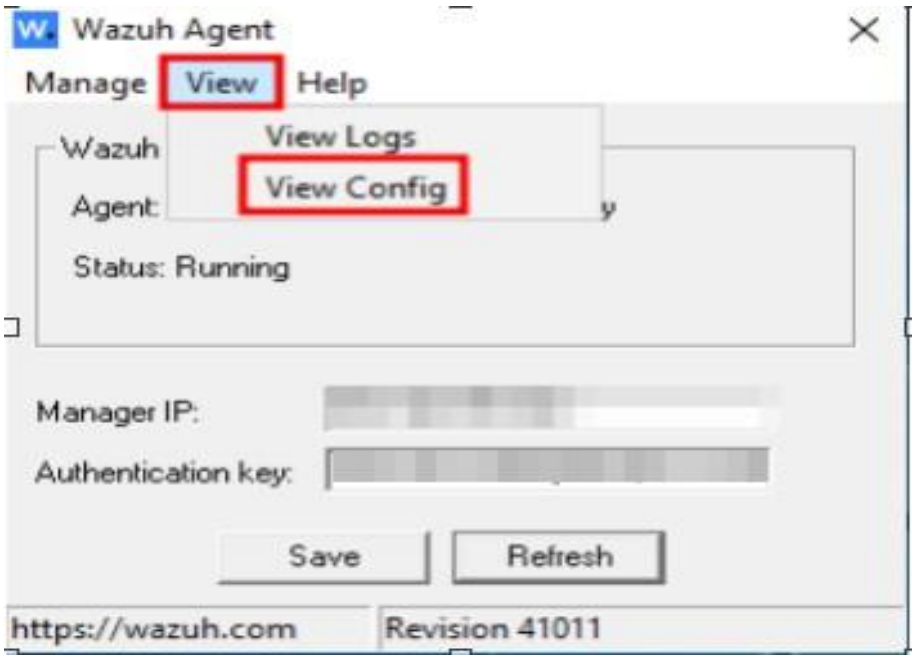
Sysmon in Event Viewer



4. Integrating Sysmon Logs into Wazuh

Modify the Wazuh agent configuration file:

C:\Program Files (x86)\ossec-agent\ossec.conf



Click view Config to edit configuration

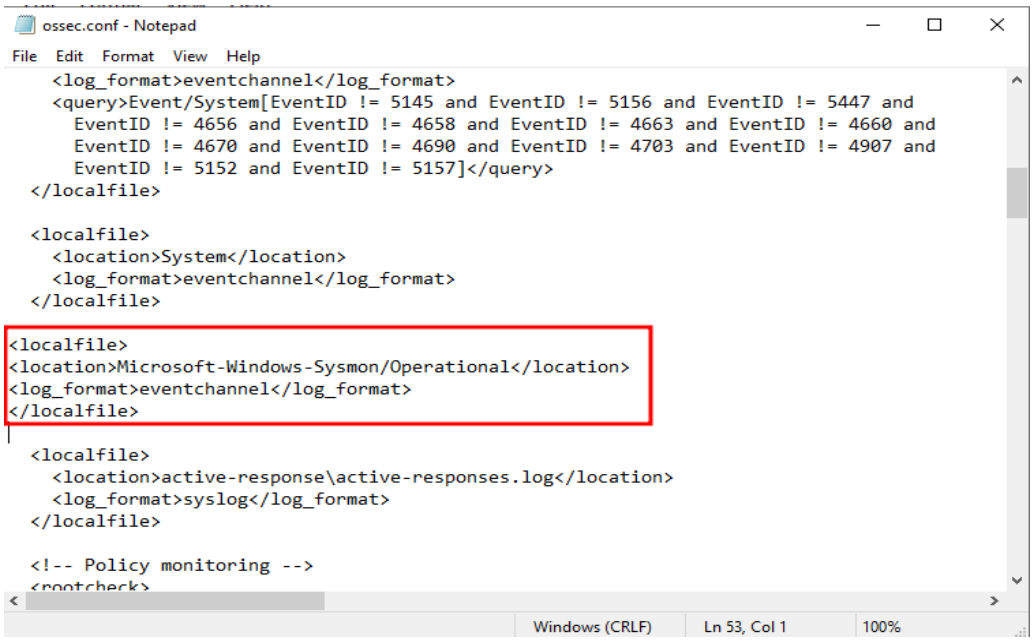
Write the following Command on Ossec.conf

```
<localfile>

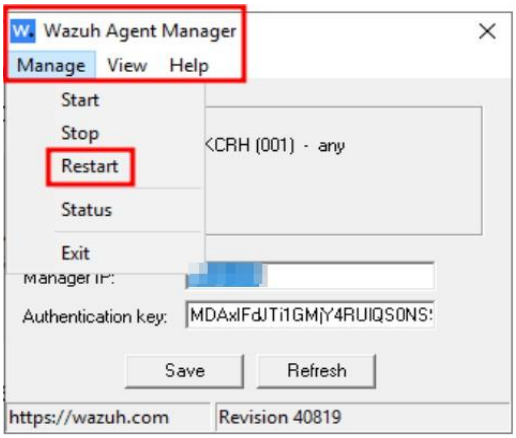
<log_format>eventchannel</log_format>

<location>Microsoft-Windows-Sysmon/Operational</location>

</localfile>
```



Now restart the agent:



Adding Wazuh Rules for Sysmon

Open the Wazuh rules file on the Wazuh manager:

```
$ sudo nano /var/ossec/rules/sysmon_rules.xml
```

Copy and paste the following Sysmon rules:

```
<!-- Log Sysmon Alerts -->

<group name="sysmon">

<rule id="101100" level="5">

<if_sid>61650</if_sid>

<description>Sysmon - Event 22: DNS Query.</description>

<options>no_full_log</options>

</rule>

<rule id="101101" level="5">

<if_sid>61603</if_sid>

<options>no_full_log</options>

<description>Sysmon - Event 1: Process creation.</description>

</rule>

<rule id="101102" level="5">

<if_sid>61604</if_sid>

<options>no_full_log</options>

<description>Sysmon - Event 2: A process changed a file creation
time.</description>

</rule>

<rule id="101103" level="5">
```

```
<if_sid>61605</if_sid>
<options>no_full_log</options>
<description>Sysmon - Event 3: Network connection.</description>
</rule>
<rule id="101104" level="5">
<if_sid>61606</if_sid>
<options>no_full_log</options>
<description>Sysmon - Event 4: Sysmon service state changed.
</description>
</rule>
<rule id="101105" level="5">
<if_sid>61607</if_sid>
<options>no_full_log</options>
<description>Sysmon - Event 5: Process terminated.</description>
</rule>
<rule id="101106" level="5">
<if_sid>61608</if_sid><options>no_full_log</options>
<description>Sysmon - Event 6: Driver loaded.</description>
</rule>
<rule id="101107" level="5">
<if_sid>61609</if_sid>
<options>no_full_log</options>
<description>Sysmon - Event 7: Image loaded.</description>
</rule>
<rule id="101108" level="5">
<if_sid>61610</if_sid>
<options>no_full_log</options>
<description>Sysmon - Event 8: CreateRemoteThread.</description>
</rule>
<rule id="101109" level="5">
<if_sid>61611</if_sid>
<options>no_full_log</options>
<description>Sysmon - Event 9: RawAccessRead.</description>
</rule>
```

```
<rule id="101110" level="5">
<if_sid>61612</if_sid>
<options>no_full_log</options>
<description>Sysmon - Event 10: ProcessAccess.</description>
</rule>
<rule id="101111" level="5">
<if_sid>61613</if_sid>
<options>no_full_log</options>
<description>Sysmon - Event 11: FileCreate.</description>
</rule>
<rule id="101112" level="5">
<if_sid>61614</if_sid>
<options>no_full_log</options>
<description>Sysmon - Event 12: RegistryEvent (Object create and
delete).</description>
</rule>
<rule id="101113" level="5">
<if_sid>61615</if_sid>
<options>no_full_log</options>
<description>Sysmon - Event 13: RegistryEvent (Value Set).
</description>
</rule>
<rule id="101114" level="5">
<if_sid>61616</if_sid>
<options>no_full_log</options>
<description>Sysmon - Event 14: RegistryEvent (Key and Value
Rename).</description>
</rule>
<rule id="101115" level="5">
<if_sid>61617</if_sid><options>no_full_log</options>
<description>Sysmon - Event 15: FileCreateStreamHash.
</description>
</rule>
</group>
```

copy the whole and paste it in the sysmon_rules.xml file

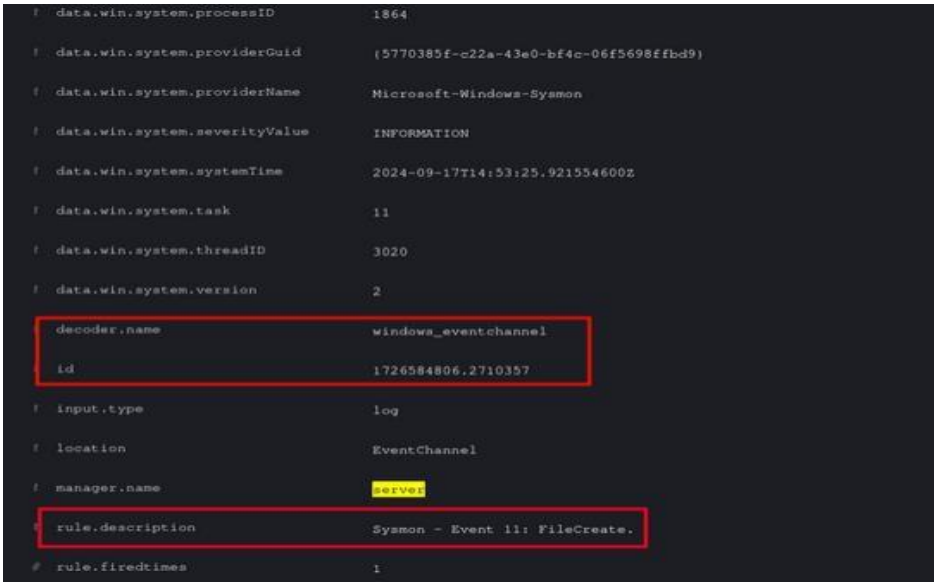
After creating a rule file. Enter this command in the terminal

```
sudo systemctl restart wazuh-manager
```

Now Go to Wazuh dashboard and you can see logs



Time	rule.description	rule.level	rule.id
Sep 17, 2024 @ 10:53:26.922	Sysmon - Event 11: FileCreate.	5	101111
Sep 17, 2024 @ 10:53:08.950	Sysmon - Event 10: ProcessAccess.	5	101110
Sep 17, 2024 @ 10:53:07.715	Wazuh agent started.	3	503
Sep 17, 2024 @ 10:37:09.033	Wazuh agent stopped.	3	506
Sep 17, 2024 @ 10:37:00.560	Sysmon - Event 13: RegistryEvent (Value Set).	5	101113
Sep 17, 2024 @ 10:37:00.559	Sysmon - Event 7: Image loaded.	5	101107
Sep 17, 2024 @ 10:36:59.574	Software protection service scheduled successfully.	3	60642
Sep 17, 2024 @ 10:36:58.515	Windows System error event	5	61102
Sep 17, 2024 @ 10:36:44.984	Sysmon - Event 1: Process creation.	5	101101

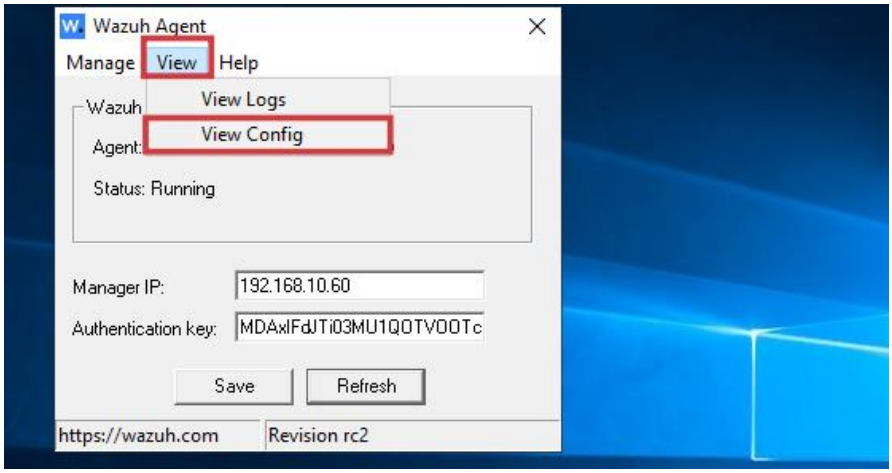


data.win.system.processID	1864
data.win.system.providerGuid	{5770385f-c22a-43e0-bf4c-06f5698ffbd9}
data.win.system.providerName	Microsoft-Windows-Sysmon
data.win.system.severityValue	INFORMATION
data.win.system.systemTime	2024-09-17T14:53:25.921554600Z
data.win.system.task	11
data.win.system.threadID	3020
data.win.system.version	2
decoder.name	windows_eventchannel
id	1726584806.2710357
input.type	log
location	EventChannel
manager.name	server
rule.description	Sysmon - Event 11: FileCreate.
rule.firedtimes	1

CONFIGURE LOG COLLECTION ON WAZUH AGENTS

On each Windows machine (DC01, SRV01, CL01) — edit the Wazuh agent config:

Go to Wazuh-Agent → View → View Config



Find the <localfile> section and make sure these entries exist (add any that are missing):

```
<localfile>
  <log_format>eventchannel</log_format>
  <location>Security</location>
</localfile>

<localfile>
  <log_format>eventchannel</log_format>
  <location>System</location>
</localfile>

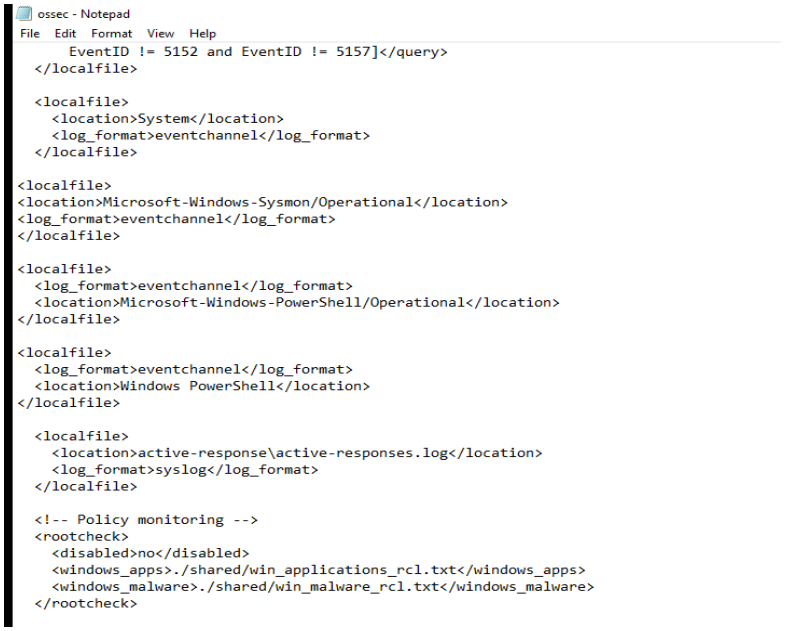
<localfile>
  <log_format>eventchannel</log_format>
  <location>Application</location>
</localfile>

<localfile>
  <log_format>eventchannel</log_format>
  <location>Microsoft-Windows-Sysmon/Operational</location>
```

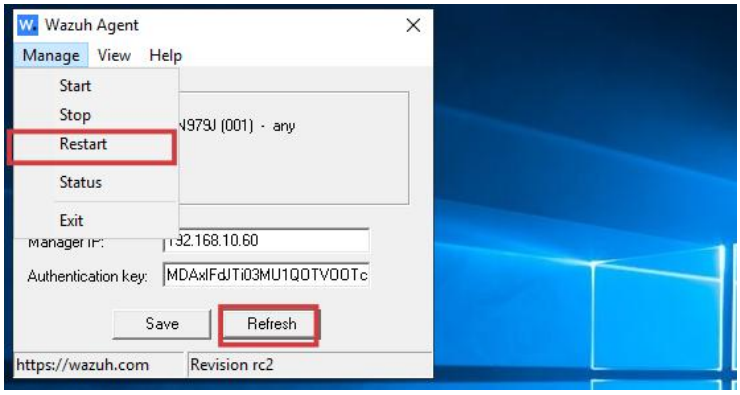
```
</localfile>


<localfile>
  <log_format>eventchannel</log_format>
  <location>Microsoft-Windows-PowerShell/Operational</location>
</localfile>


<localfile>
  <log_format>eventchannel</log_format>
  <location>Windows PowerShell</location>
</localfile>
```



Save the file → Restart Wazuh service:



CREATE CUSTOM DETECTION RULES IN WAZUH

SSH into IDS01 or work directly on its terminal:

```
sudo nano /var/ossec/etc/rules/local_rules.xml
```



Delete any existing content and paste these complete custom rules:

```
<group name="local,security,">


  <!-- RULE 1: Brute Force Detection — 5 failed logins in 60 seconds -->

  <rule id="100001" level="10" frequency="5" timeframe="60">

    <if_matched_sid>100002</if_matched_sid>

    <description>Brute Force Attack: Multiple failed logins detected on
same account</description>

    <mitre>

      <id>T1110</id>

    </mitre>

    <group>authentication_failures,pci_dss_10.2.4,pci_dss_10.2.5,</group>

  </rule>


  <!-- RULE 2: Single Failed Login — lower severity -->

  <rule id="100002" level="5">

    <if_sid>60104</if_sid>

    <description>Failed login attempt detected — possible unauthorized
access</description>

    <mitre>

      <id>T1110</id>

    </mitre>

    <group>authentication_failures,</group>

  </rule>


  <!-- RULE 3: SMB Activity Detection from external-like sources -->
```

```
  <rule id="100003" level="8">
    <if_sid>18107</if_sid>
    <description>SMB Lateral Movement: SMB access attempt
detected</description>
    <mitre>
      <id>T1021.002</id>
    </mitre>
    <group>smb_activity,lateral_movement,</group>
  </rule>

  <!-- RULE 4: CrackMapExec SMB Enumeration Detection -->
  <rule id="100004" level="12">
    <if_sid>18101,18104,18107</if_sid>
    <match>crackmapexec|cme|SMB scan</match>
    <description>SMB Enumeration Tool Detected — possible
CrackMapExec</description>
    <mitre>
      <id>T1021.002</id>
    </mitre>
    <group>smb_activity,attack_tool,</group>
  </rule>

  <!-- RULE 5: PowerShell Suspicious Execution -->
  <rule id="100005" level="10">
    <if_sid>91802</if_sid>
    <match>-EncodedCommand|-enc|-nop|-noni|bypass|hidden|IEX|Invoke-
Expression|DownloadString|WebClient</match>
    <description>Suspicious PowerShell Execution — possible PowerShell
abuse or malware</description>
    <mitre>
      <id>T1059.001</id>
    </mitre>
    <group>powershell_abuse,</group>
  </rule>
```

```
  <!-- RULE 6: PowerShell Download Cradle -->
  <rule id="100006" level="13">
    <if_sid>91802</if_sid>
    <match>Net.WebClient|Invoke-
WebRequest|DownloadFile|DownloadString|Start-BitsTransfer</match>
    <description>PowerShell Download Cradle Detected — possible dropper or
C2 activity</description>
    <mitre>
      <id>T1059.001</id>
    </mitre>
    <group>powershell_abuse,download_cradle,</group>
  </rule>

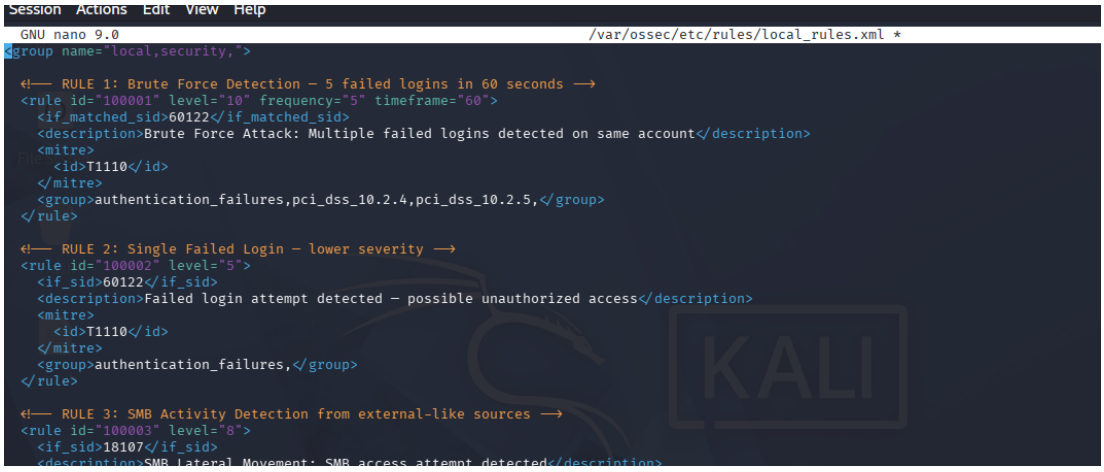

  <!-- RULE 7: Nmap Network Scan Detection -->
  <rule id="100007" level="8">
    <if_sid>40101,40111</if_sid>
    <description>Network Scan Detected — possible Nmap
reconnaissance</description>
    <mitre>
      <id>T1046</id>
    </mitre>
    <group>network_scan,reconnaissance,</group>
  </rule>


  <!-- RULE 8: Account Lockout -->
  <rule id="100008" level="9">
    <if_sid>60204</if_sid>
    <description>Account Lockout Triggered — account locked due to failed
login attempts</description>
    <mitre>
      <id>T1110</id>
    </mitre>
    <group>account_lockout,authentication_failures,</group>
  </rule>
```

```
  <!-- RULE 9: New User Created in AD -->
  <rule id="100009" level="7">
    <if_sid>60123</if_sid>
    <description>New Domain User Account Created — verify this is
authorized</description>
    <mitre>
      <id>T1136.002</id>
    </mitre>
    <group>account_management,</group>
  </rule>

  <!-- RULE 10: Admin Group Membership Change -->
  <rule id="100010" level="11">
    <if_sid>60123</if_sid>
    <match>Domain Admins|Enterprise Admins|Administrators</match>
    <description>Privileged Group Membership Changed — high priority review
required</description>
    <mitre>
      <id>T1098</id>
    </mitre>
    <group>account_management,privilege_escalation,</group>
  </rule>

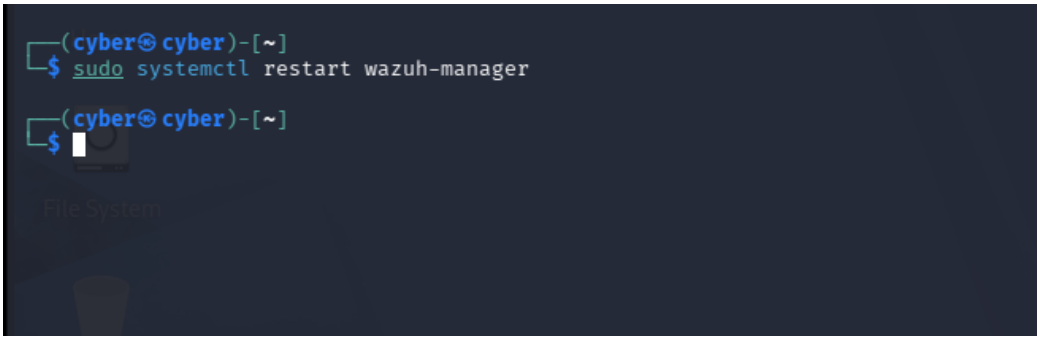
</group>
```



Save the file (Ctrl+S and Ctrl + X).

Restart Wazuh manager to load the rules:

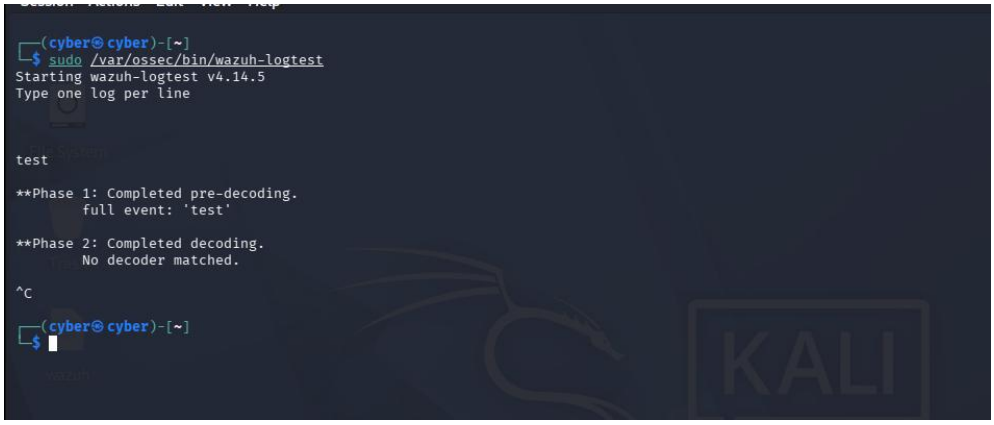
```
sudo systemctl restart wazuh-manager
```



Verify rules loaded without errors

```
sudo /var/ossec/bin/wazuh-logtest
```

Type: test



Press Ctrl+C to exit

Verify your custom rules are loaded:

```
sudo grep -r "100001\|100002\|100003\|100004\|100005" /var/ossec/logs/ossec.log | tail -20
```

PHASE 9 — MITRE ATT&CK MAPPING

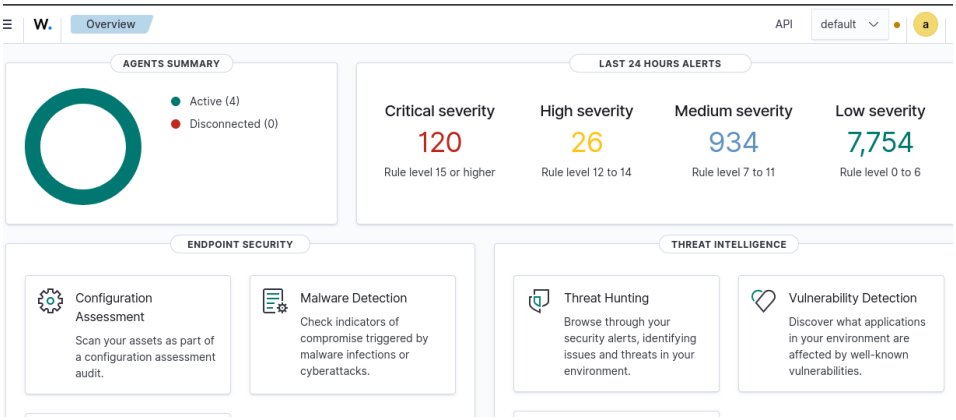
UNDERSTAND AND VERIFY YOUR MITRE MAPPINGS

The rules you created above already contain MITRE ATT&CK tags. Here is the full mapping reference:

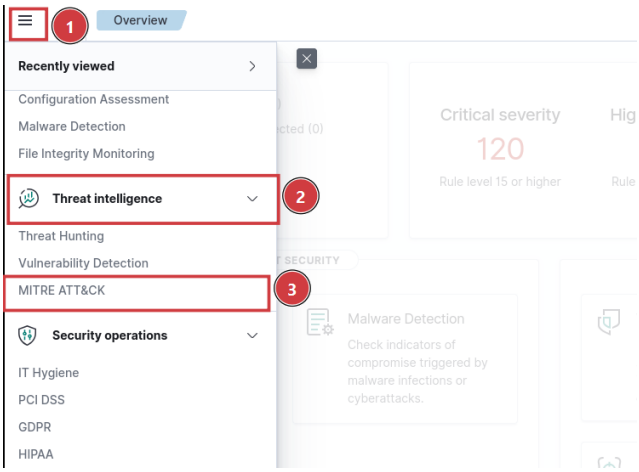
Rule ID	What It Detects	MITRE Technique	Tactic
100001	Brute Force (5+ fails/60s)	T1110 — Brute Force	Credential Access
100002	Single failed login	T1110 — Brute Force	Credential Access
100003	SMB access attempt	T1021.002 — SMB/Windows Admin Shares	Lateral Movement
100004	CrackMapExec SMB	T1021.002 — SMB/Windows Admin Shares	Lateral Movement
100005	Suspicious PowerShell	T1059.001 — PowerShell	Execution
100006	PS Download Cradle	T1059.001 — PowerShell	Execution
100007	Network Scan	T1046 — Network Service Scanning	Discovery
100008	Account Lockout	T1110 — Brute Force	Credential Access
100009	New AD User	T1136.002 — Domain Account	Persistence
100010	Admin group change	T1098 — Account Manipulation	Persistence

Verify MITRE integration in Wazuh Dashboard:

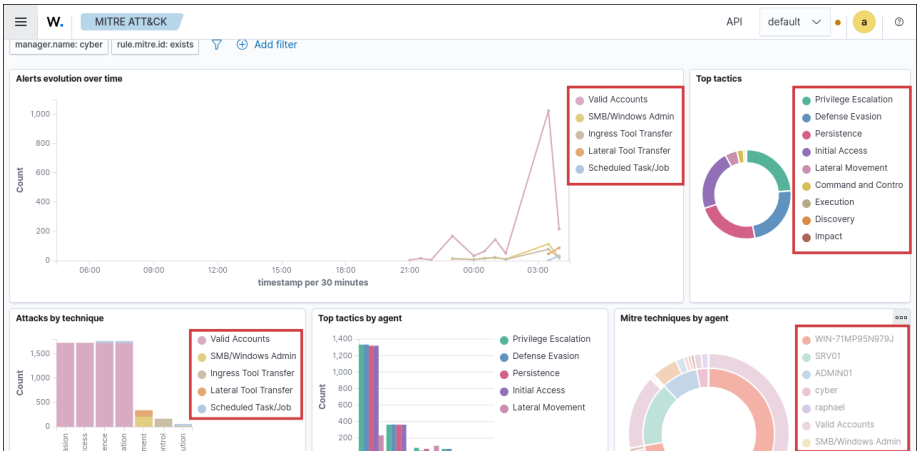
1. **Open Wazuh Dashboard → https://192.168.10.60**



2. **Click MITRE ATT&CK in left menu**



3. **You will see the ATT&CK matrix with highlighted techniques**



4. **After running attacks (Phase 10 below), these techniques light up showing which ones triggered**

PHASE 10 — ATTACK SIMULATION FROM KALI

Go to the ATTACKER machine (Kali Linux at 192.168.10.40)

UPGRADE ATTACKER TOOLS

On ATTACKER Kali — open terminal:

sudo apt-get update && sudo apt-get upgrade -y

```
┌──(raphael㉿raphael)-[~]
└─$ sudo apt-get update && sudo apt-get upgrade -y
[sudo] password for raphael:
Hit:2 https://packages.wazuh.com/4.x/apt stable InRelease
Ign:1 http://mirror.yer.az/kali kali-rolling InRelease
Ign:1 http://mirror.yer.az/kali kali-rolling InRelease
Ign:1 http://mirror.yer.az/kali kali-rolling InRelease
Err:1 http://mirror.yer.az/kali kali-rolling InRelease
  Could not connect to mirror.yer.az:80 (62.212.239.34). - connect (111: Connection refused)
  Unable to connect to mirror.yer.az:http:
Reading package lists ... Done
W: Failed to fetch http://http.kali.org/kali/dists/kali-rolling/InRelease  Unable to connect to mirror.yer.az:http:
W: Some index files failed to download. They have been ignored, or old ones used instead.
Reading package lists ... Done
Building dependency tree ... Done
Reading state information ... Done
Calculating upgrade ... Done
The following packages were automatically installed and are no longer required:
  bloodhound.py curlftpfs libaudio2 libavfilter10 libavformat61 libconfig-inifiles-perl libcrypt-dev libfuse2t64 libgav1-1 libio-pty-perl libipc-run-p
  libmjpegutils-2.1-0t64 libmpeg2encpp-2.1-0t64 libmplex2-2.1-0t64 libmupdf25.1 libpocketsphinx3 libpostal-data libpostal1 libpostproc58 libsimdutf27
  libsphinxbase3t64 libswscale8 libteamdctl0 libvdpau-va-gl1 pocketsphinx-en-us postgresql-common-dev python3-aiocache python3-aiomcache python3-fs
  python3-wapiti-arsenic python3-yaswfp ruby-unf-ext
Use 'sudo apt autoremove' to remove them.
The following packages have been kept back:
```

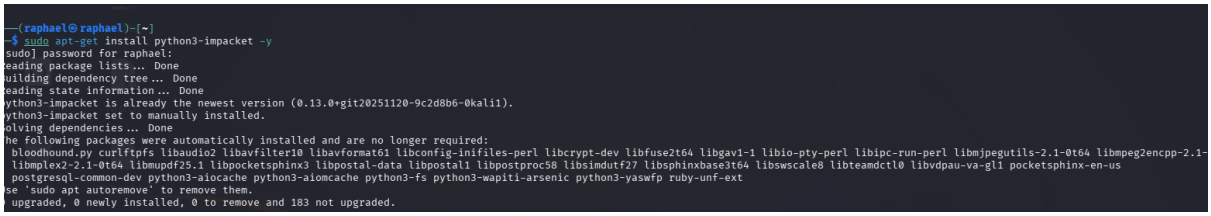
sudo apt-get install crackmapexec -y

```
┌──(raphael㉿raphael)-[~]
└─$ sudo apt-get install crackmapexec -y
[sudo] password for raphael:
Reading package lists ... Done
Building dependency tree ... Done
Reading state information ... Done
Solving dependencies ... Done
The following packages were automatically installed and are no longer required:
  bloodhound.py curlftpfs libaudio2 libavfilter10 libavformat61 libconfig-inifiles-perl libcrypt-dev libfuse2t64 libgav1-1
  libmjpegutils-2.1-0t64 libmpeg2encpp-2.1-0t64 libmplex2-2.1-0t64 libmupdf25.1 libpocketsphinx3 libpostal-data libpostal1
  libsphinxbase3t64 libswscale8 libteamdctl0 libvdpau-va-gl1 pocketsphinx-en-us postgresql-common-dev python3-aiocache pyt
  python3-wapiti-arsenic python3-yaswfp ruby-unf-ext
Use 'sudo apt autoremove' to remove them.
The following additional packages will be installed:
  python3-aioconsole python3-pywerview python3-terminaltables3
Suggested packages:
  python3-terminaltables3-doc
The following NEW packages will be installed:
  crackmapexec python3-aioconsole python3-pywerview python3-terminaltables3
0 upgraded, 4 newly installed, 0 to remove and 183 not upgraded.
Need to get 728 kB of archives.
```

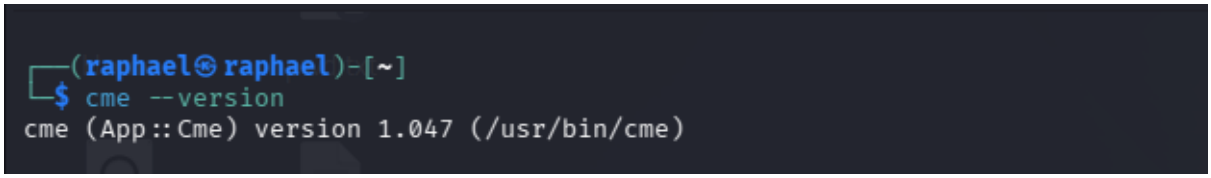
sudo apt-get install hydra -y

```
┌──(raphael㉿raphael)-[~]
└─$ sudo apt-get install hydra -y
Reading package lists ... Done
Building dependency tree ... Done
Reading state information ... Done
hydra is already the newest version (9.6-3).
hydra set to manually installed.
Solving dependencies ... Done
The following packages were automatically installed and are no longer required:
  bloodhound.py curlftpfs libaudio2 libavfilter10 libavformat61 libconfig-inifiles-perl libcrypt-dev libfuse2t64 libgav1-1 libio-pty-perl libipc-run-pe
  libmjpegutils-2.1-0t64 libmpeg2encpp-2.1-0t64 libmplex2-2.1-0t64 libmupdf25.1 libpocketsphinx3 libpostal-data libpostal1 libpostproc58 libsimdutf27
  libsphinxbase3t64 libswscale8 libteamdctl0 libvdpau-va-gl1 pocketsphinx-en-us postgresql-common-dev python3-aiocache python3-aiomcache python3-fs
  python3-wapiti-arsenic python3-yaswfp ruby-unf-ext
```

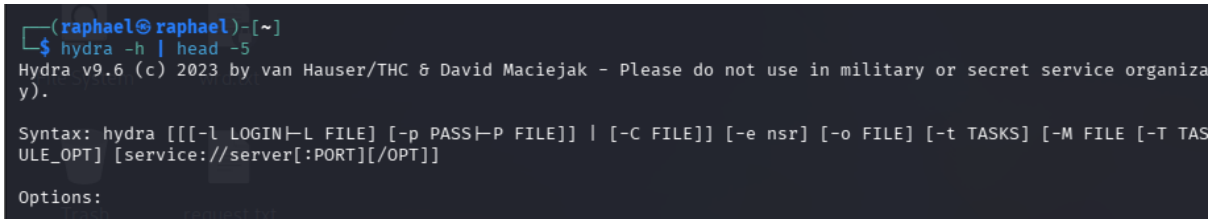
sudo apt-get install python3-impacket -y



cme –version

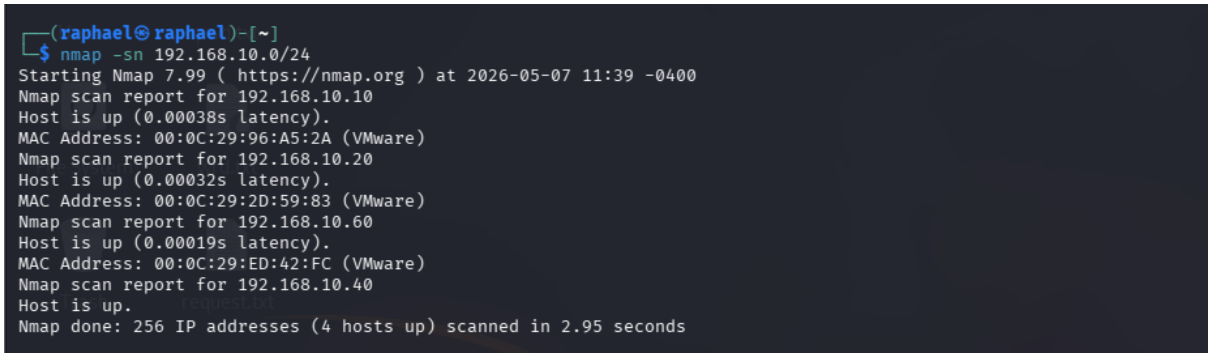


hydra -h | head -5



ATTACK 1: NETWORK RECONNAISSANCE (T1046)

nmap -sn 192.168.10.0/24



nmap -sV -sC -O 192.168.10.10

```
┌──(raphael㉿raphael)-[~]
└─$ nmap -sV -sC -O 192.168.10.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 11:40 -0400
Nmap scan report for 192.168.10.10
Host is up (0.00079s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT     STATE SERVICE       VERSION
22/tcp   open  ssh           OpenSSH for_Windows_9.5 (protocol 2.0)
53/tcp   open  domain        Simple DNS Plus
80/tcp   open  http          Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
|_http-title: IIS Windows Server
| http-methods:
|_  Potentially risky methods: TRACE
88/tcp   open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-05-07 15:25:59Z)
135/tcp  open  msrpc         Microsoft Windows RPC
389/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: corp.local, Site: Default-First-Site-Name)
|_ssl-date: 2026-05-07T15:27:07+00:00; -14m21s from scanner time.
| ssl-cert: Subject:
| Subject Alternative Name: DNS:DC01.corp.local
| Not valid before: 2026-03-13T23:09:23
|_Not valid after:  2027-03-13T23:09:23
445/tcp  open  microsoft-ds?
464/tcp  open  kpasswd5?
593/tcp  open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp  open  ssl/ldap      Microsoft Windows Active Directory LDAP (Domain: corp.local, Site: Default-First-Site-Name)
```

nmap -A -p- 192.168.10.10 --max-retries 2

```
┌──(raphael㉿raphael)-[~]
└─$ nmap -A -p- 192.168.10.10 --max-retries 2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 11:53 -0400
Nmap scan report for 192.168.10.10
Host is up (0.00058s latency).
Not shown: 65512 filtered tcp ports (no-response)
PORT     STATE SERVICE       VERSION
22/tcp   open  ssh           OpenSSH for_Windows_9.5 (protocol 2.0)
53/tcp   open  domain        Simple DNS Plus
80/tcp   open  http          Microsoft IIS httpd 10.0
|_http-title: IIS Windows Server
|_http-server-header: Microsoft-IIS/10.0
| http-methods:
|_  Potentially risky methods: TRACE
88/tcp   open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-05-07 15:52:49Z)
135/tcp  open  msrpc         Microsoft Windows RPC
389/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: corp.local, Site: Default-First-Site-Name)
| ssl-cert: Subject:
| Subject Alternative Name: DNS:DC01.corp.local
| Not valid before: 2026-03-13T23:09:23
|_Not valid after:  2027-03-13T23:09:23
|_ssl-date: 2026-05-07T15:54:21+00:00; -2m13s from scanner time.
445/tcp  open  microsoft-ds?
464/tcp  open  kpasswd5?
```

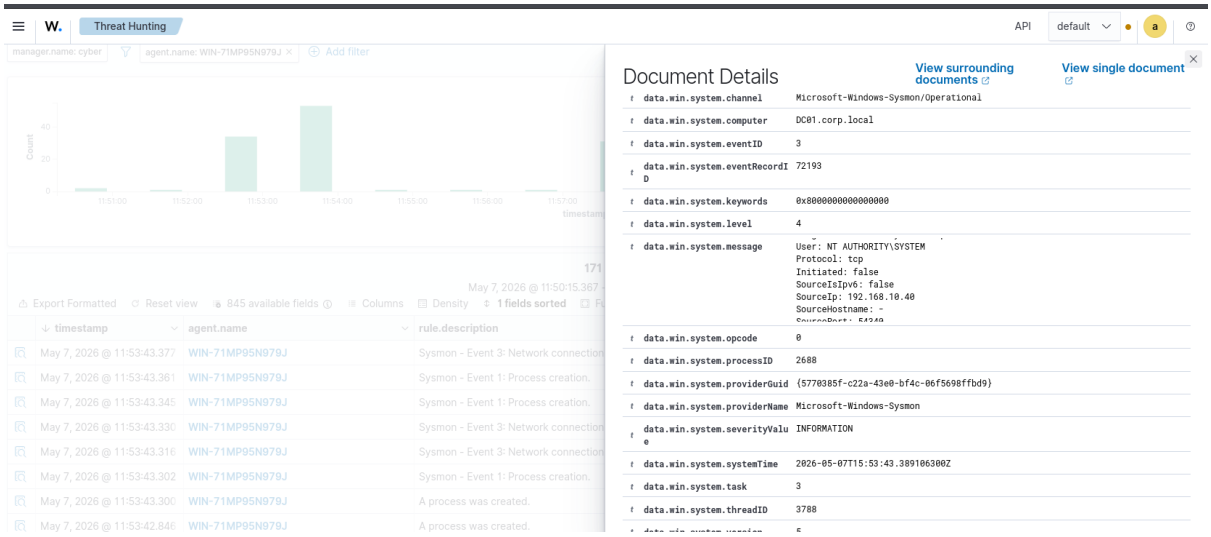
nmap -p 139,445 --script smb-os-discovery 192.168.10.25

```
┌──(raphael㉿raphael)-[~]
└─$ nmap -p 139,445 --script smb-os-discovery 192.168.10.25
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 11:58 -0400
Nmap scan report for 192.168.10.25
Host is up (0.00068s latency).

PORT    STATE SERVICE
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:DD:E0:15 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.73 seconds
```

What to observe: Go to Wazuh Dashboard → Security Events → filter by agent DC01 → you should see scan alerts triggering within 1–2 minutes.



ATTACK 2: SMB ENUMERATION (T1021.002)

nmap --script smb-enum-shares,smb-enum-users -p 445 192.168.10.10

```
┌──(raphael㉿raphael)-[~]
└─$ nmap --script smb-enum-shares,smb-enum-users -p 445 192.168.10.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 12:12 -0400
Nmap scan report for 192.168.10.10
Host is up (0.00037s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:96:A5:2A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.73 seconds
```

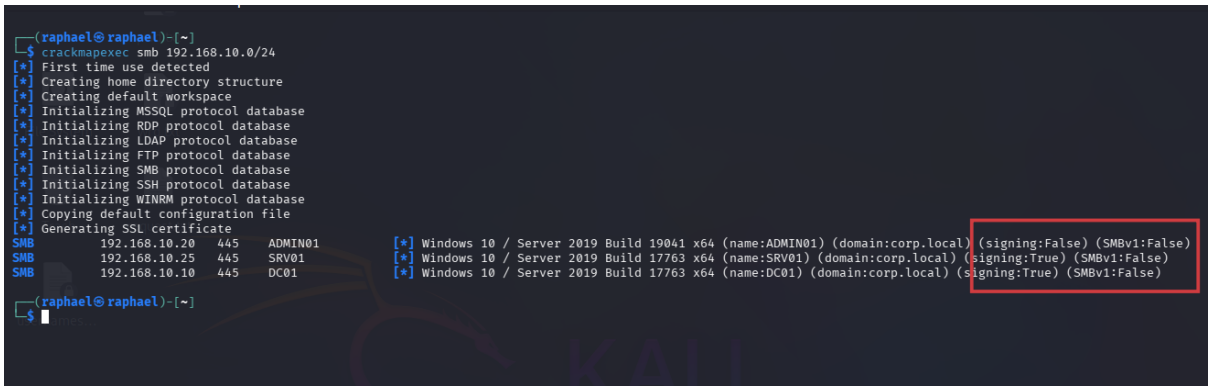
nmap --script smb-enum-shares,smb-enum-users -p 445 192.168.10.25

```
┌──(raphael㉿raphael)-[~]
└─$ nmap --script smb-enum-shares,smb-enum-users -p 445 192.168.10.25
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 12:12 -0400
Nmap scan report for 192.168.10.25
Host is up (0.00028s latency).

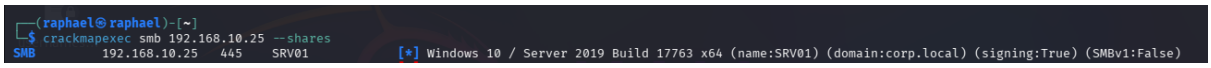
PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:DD:E0:15 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.72 seconds
```

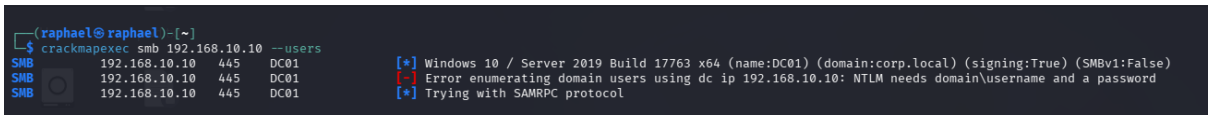
crackmapexec smb 192.168.10.0/24



crackmapexec smb 192.168.10.25 --shares



crackmapexec smb 192.168.10.10 --users



Expected results: FinanceData share should NOT be accessible anonymously. SMB enumeration will be logged by Suricata AND by Wazuh. Check both dashboards.

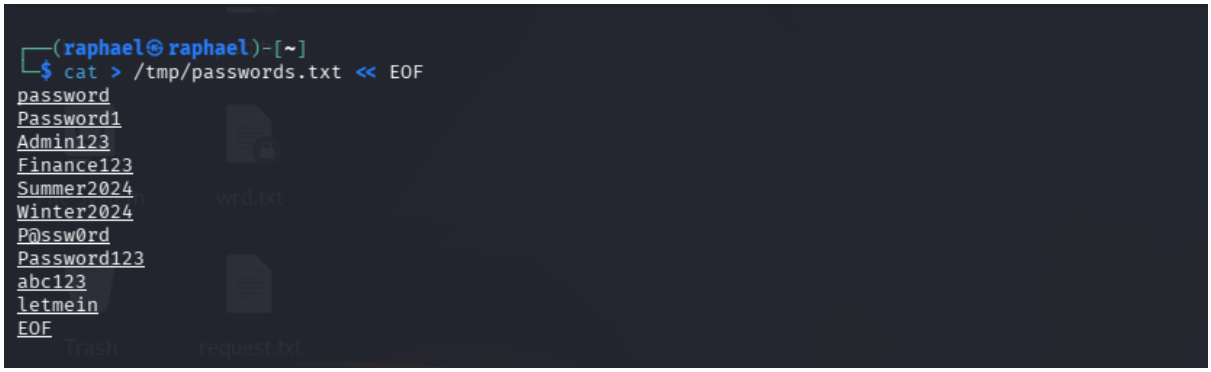


ATTACK 3: BRUTE FORCE ATTACK (T1110)

This attack tests your account lockout policy and your Wazuh brute force detection rule.

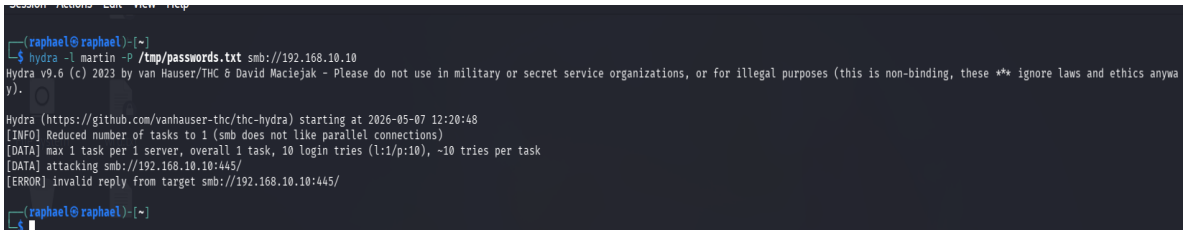
Create a password list on Kali:

```
cat > /tmp/passwords.txt << EOF
password
Password1
Finance123
Summer2024
Winter2024
P@ssw0rd
Password123
abc123
letmein
Admin123
EOF
```



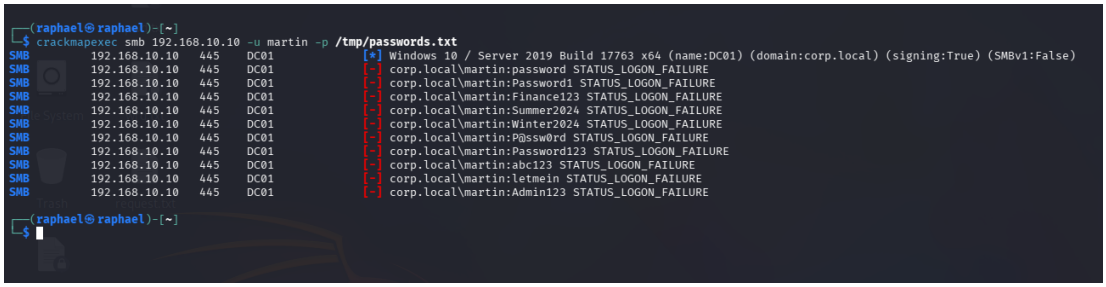
Run Hydra brute force against SMB:

```
hydra -l martin -P /tmp/passwords.txt smb://192.168.10.10
```



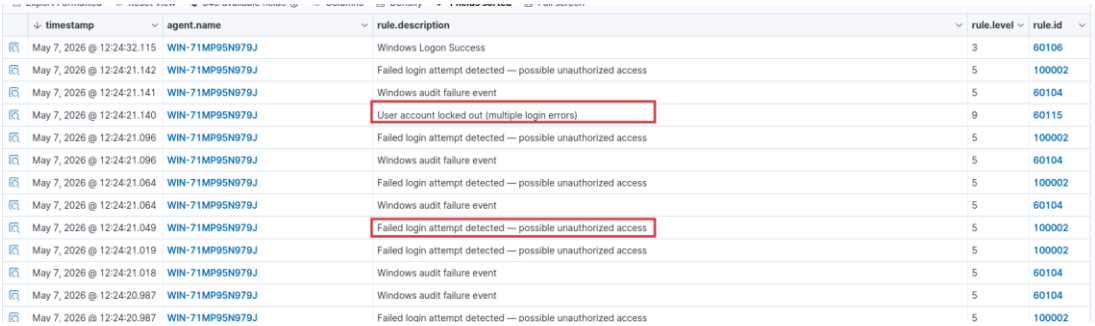
Run CrackMapExec brute force:

```
crackmapexec smb 192.168.10.10 -u martin -p /tmp/passwords.txt
```



What to observe:

- **After 5 failed attempts: martin's account locks out (GPO from Module 2)**
- **In Wazuh Dashboard → Rule 100008 fires (Account Lockout)**
- **On DC01 → Event Viewer → Windows Logs → Security: Event ID 4625 (failed logins) and 4740 (account locked)**

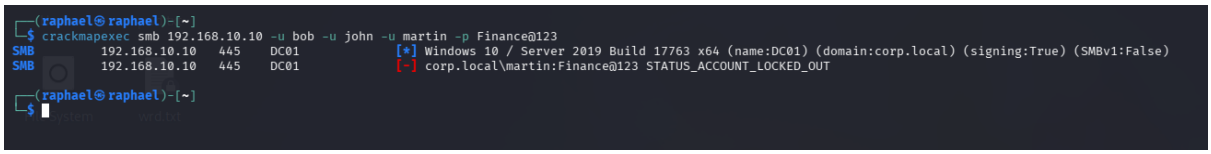


timestamp	agent.name	rule.description	rule.level	rule.id
May 7, 2026 @ 12:24:32.115	WIN-71MP95N979J	Windows Logon Success	3	60106
May 7, 2026 @ 12:24:21.142	WIN-71MP95N979J	Failed login attempt detected — possible unauthorized access	5	100002
May 7, 2026 @ 12:24:21.141	WIN-71MP95N979J	Windows audit failure event	5	60104
May 7, 2026 @ 12:24:21.140	WIN-71MP95N979J	User account locked out (multiple login errors)	9	60115
May 7, 2026 @ 12:24:21.096	WIN-71MP95N979J	Failed login attempt detected — possible unauthorized access	5	100002
May 7, 2026 @ 12:24:21.096	WIN-71MP95N979J	Windows audit failure event	5	60104
May 7, 2026 @ 12:24:21.064	WIN-71MP95N979J	Failed login attempt detected — possible unauthorized access	5	100002
May 7, 2026 @ 12:24:21.064	WIN-71MP95N979J	Windows audit failure event	5	60104
May 7, 2026 @ 12:24:21.049	WIN-71MP95N979J	Failed login attempt detected — possible unauthorized access	5	100002
May 7, 2026 @ 12:24:21.019	WIN-71MP95N979J	Failed login attempt detected — possible unauthorized access	5	100002
May 7, 2026 @ 12:24:21.018	WIN-71MP95N979J	Windows audit failure event	5	60104
May 7, 2026 @ 12:24:20.987	WIN-71MP95N979J	Windows audit failure event	5	60104
May 7, 2026 @ 12:24:20.987	WIN-71MP95N979J	Failed login attempt detected — possible unauthorized access	5	100002

ATTACK 4: CRACKMAPEXEC ADVANCED CREDENTIAL ATTACKS

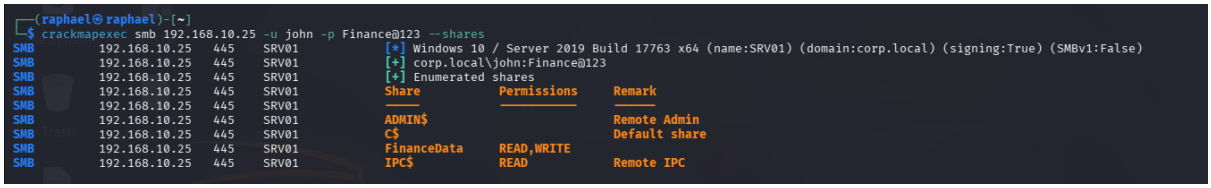
Password spray — try one password against all users

```
crackmapexec smb 192.168.10.10 -u bob -u john -u martin -p Finance@123
```

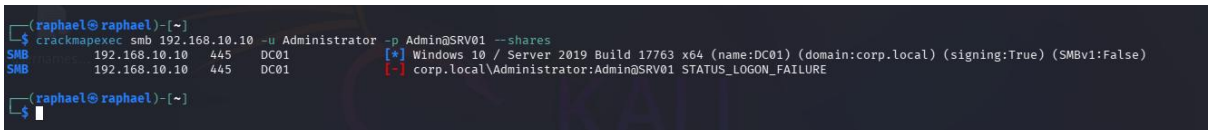


Try to list shares with valid credential

```
crackmapexec smb 192.168.10.25 -u john -p Finance@123 --shares
```




```
crackmapexec smb 192.168.10.10 -u Administrator -p Admin@SRV01 --shares
```




```
crackmapexec smb 192.168.10.10 -u Administrator -p YourAdminPass --
loggedon-users
```



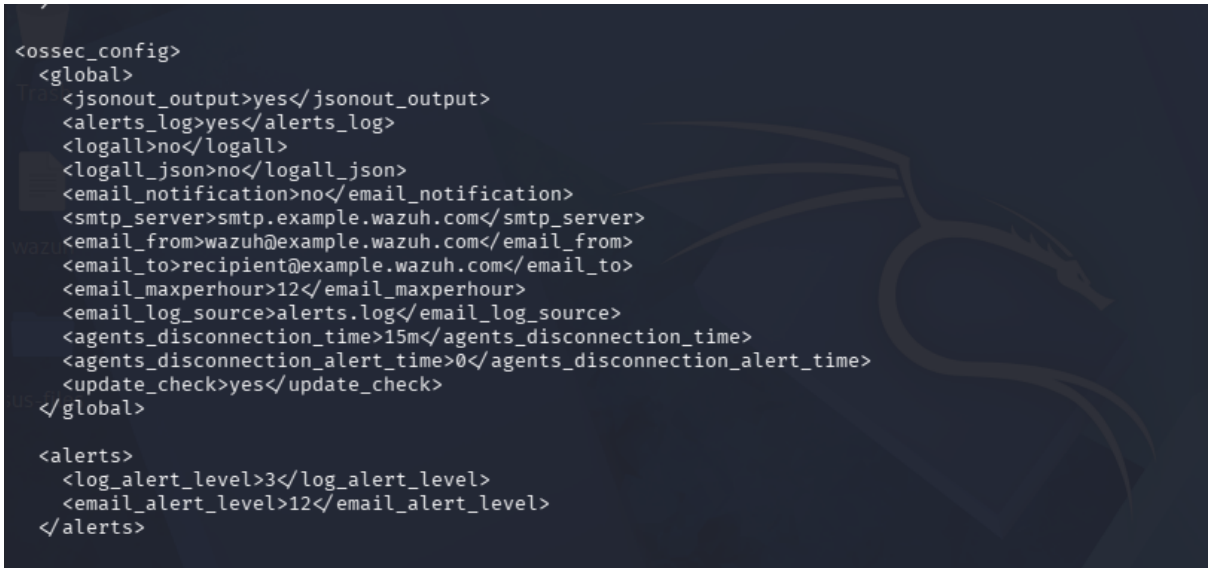
PHASE 11 — ACTIVE RESPONSE (AUTO-BLOCK ATTACKER)

This is done on IDS01 — Wazuh's Active Response automatically blocks the attacker's IP.

CONFIGURE ACTIVE RESPONSE IN WAZUH

On IDS01 — edit the Wazuh manager configuration:

```
sudo nano /var/ossec/etc/ossec.conf
```



Find the </global> closing tag, and BEFORE it, add these sections (or find existing <active-response> blocks and modify them):

```
<!-- Command definition -->

<command>

  <name>firewall-drop</name>

  <executable>firewall-drop</executable>

  <timeout_allowed>yes</timeout_allowed>

</command>


<!-- Active Response: Auto-block on brute force -->

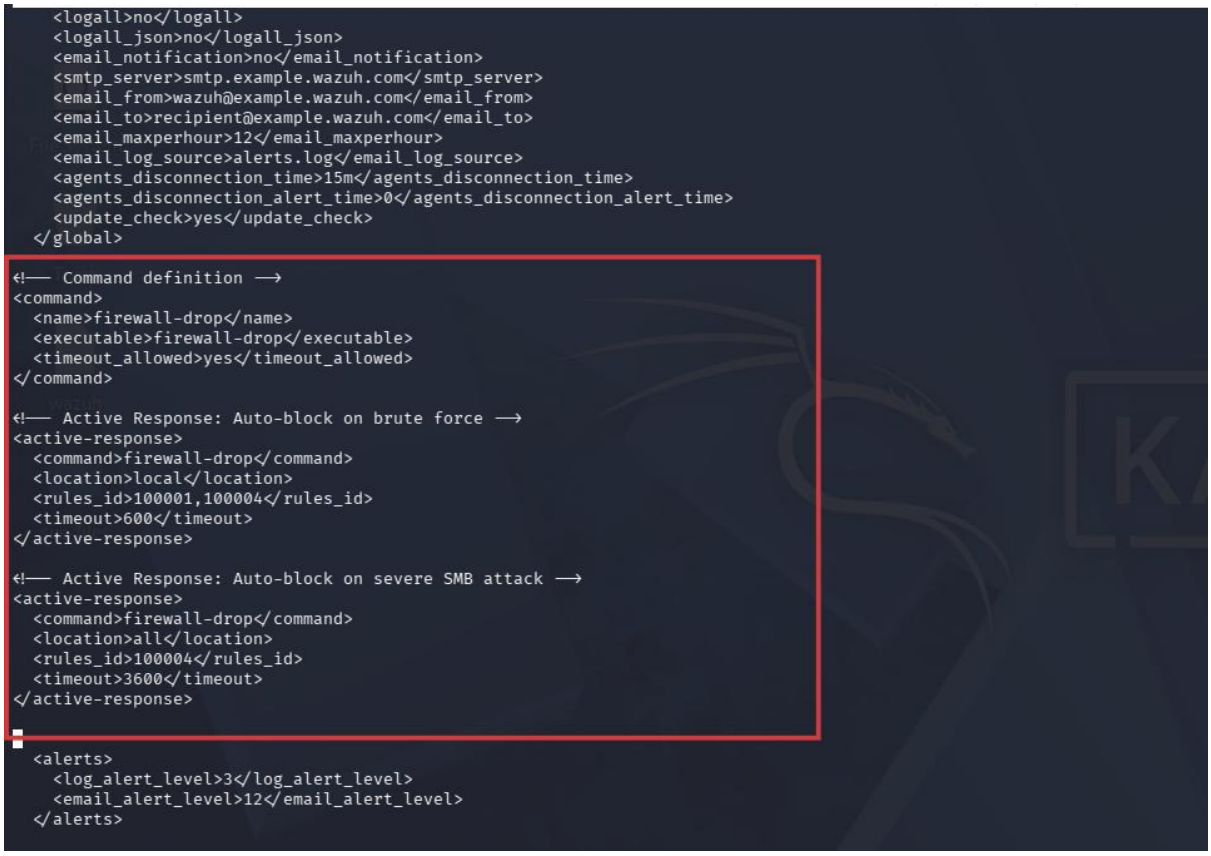
<active-response>

  <command>firewall-drop</command>

  <location>local</location>
```

```
  <rules_id>100001, 100002,100004</rules_id>
  <timeout>600</timeout>
</active-response>

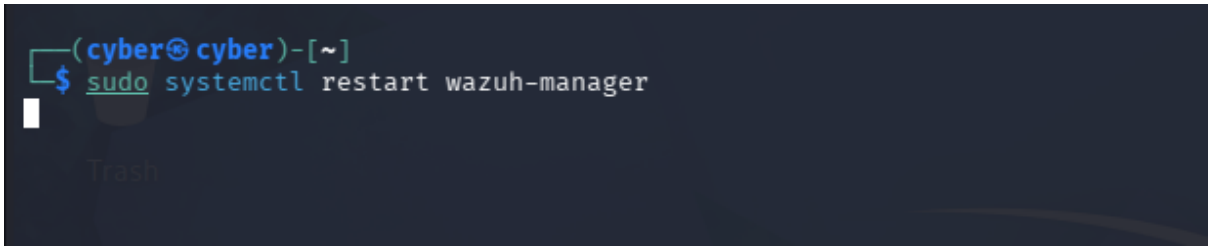
<!-- Active Response: Auto-block on severe SMB attack -->
<active-response>
  <command>firewall-drop</command>
  <location>all</location>
  <rules_id>100004</rules_id>
  <timeout>3600</timeout>
</active-response>
```



Explanation of the config:

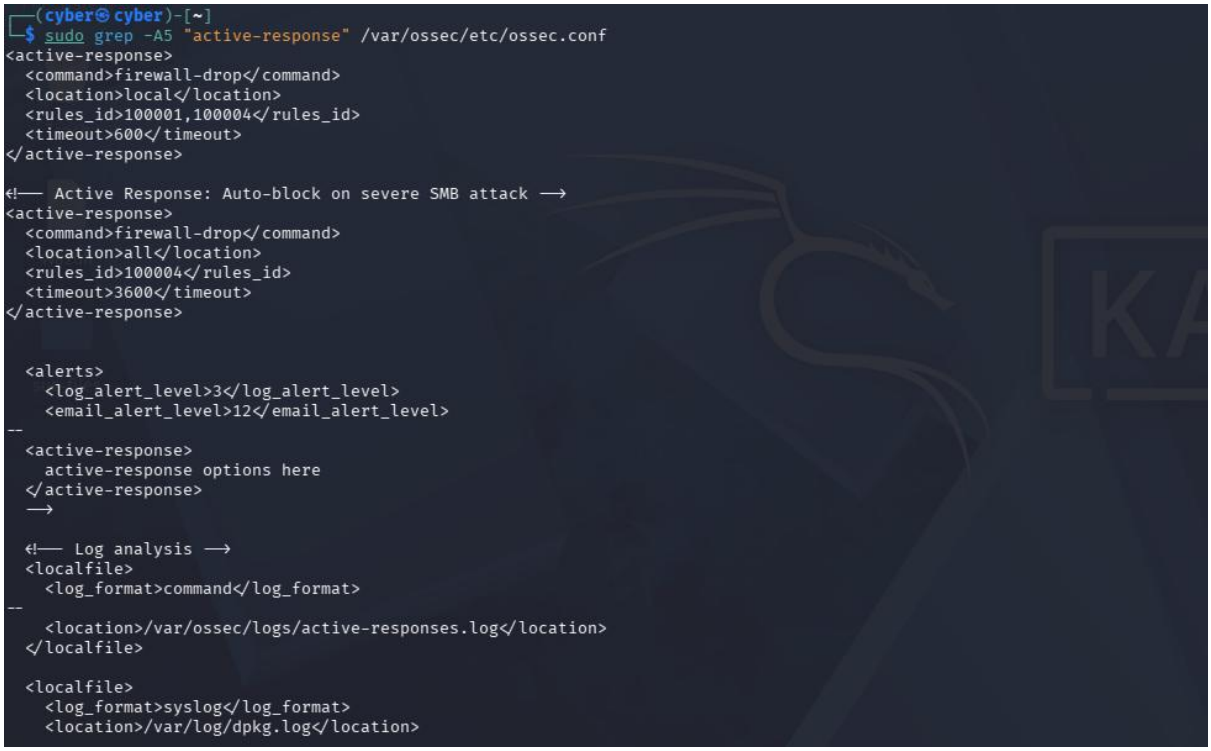
- **firewall-drop = the built-in Wazuh command that runs iptables to block the IP**
- **location: local = blocks on the Wazuh server itself**
- **location: all = blocks on ALL agents**
- **rules_id = which rule triggers the block**
- **timeout = how long the block lasts in seconds (600 = 10 min, 3600 = 1 hour)**

```
sudo systemctl restart wazuh-manager
```



Verify active response is configured:

```
sudo grep -A5 "active-response" /var/ossec/etc/ossec.conf
```



Conclusion

This module demonstrated a comprehensive approach to Windows endpoint security. Role-Based Access Control was implemented to enforce least privilege on shared resources. The Microsoft Security Compliance Toolkit was used to identify and remediate misconfigurations against the official baseline. BatchPatch enabled centralized patch management across all machines. Advanced hardening measures — including NTLM restriction, firewall rules, and audit policy enforcement — reduced the attack surface. Wazuh with Sysmon provided full visibility into system activity, while custom detection rules mapped to MITRE ATT&CK ensured structured threat coverage. Active Response was configured to automatically block attackers upon detection, completing an end-to-end defensive cycle.